

GS++ control deltas github 29.05.26 & 01.07.26

Inhalte

- [Entfernte Anforderungen](#)
- [Neue Anforderungen](#)
- [Veränderte Anforderungsattribute](#)

Als Maß für die Ähnlichkeit zwischen Anforderungen wird die [Kosinus-Ähnlichkeit](#) (cos-sim) verwendet.

Entfernte Anforderungen

[Zurück zu Inhalte](#)

Anzahl entfernter Anforderungen: 81

🗄 BER.5.1.1 Rollenbasierte Berechtigung (normal-SdT)

Berechtigung SOLLTE Berechtigungen rollenbasiert zuweisen.

BER.5.1.1 UUID vom 29.05.26 ist gleich BER.4.1.1 UUID vom 01.07.26; cos-sim = 1.0

BER.4.1.1 Rollenbasierte Berechtigung (normal-SdT) vom 01.07.26

Berechtigung SOLLTE Berechtigungen rollenbasiert zuweisen.

🗄 BER.5.1.2 JIT-/JEA-Berechtigungen (erhöht)

Berechtigung KANN die Berechtigung zum Zeitpunkt des Zugriffs für {besonders kritische Ressourcen oder Zugänge} aktivieren.

BER.5.1.2 UUID vom 29.05.26 ist gleich BER.4.1.2 UUID vom 01.07.26; cos-sim = 1.0

BER.4.1.2 JIT-/JEA-Berechtigungen (erhöht) vom 01.07.26

Berechtigung KANN die Berechtigung zum Zeitpunkt des Zugriffs für {besonders kritische Ressourcen oder Zugänge} aktivieren.

🗄 BER.5.3.1 Überprüfung tatsächlicher Berechtigungen (normal-SdT)

Berechtigung SOLLTE dokumentierte und tatsächlich vergebene Berechtigungen {regelmäßig} auf Übereinstimmung überprüfen.

BER.5.3.1 UUID vom 29.05.26 ist gleich BER.4.3.1 UUID vom 01.07.26; cos-sim = 1.0

BER.4.3.1 Überprüfung tatsächlicher Berechtigungen (normal-SdT) vom 01.07.26

Berechtigung SOLLTE dokumentierte und tatsächlich vergebene Berechtigungen {regelmäßig} auf Übereinstimmung überprüfen.

🗄 BER.7.1 Etablierte Algorithmen bei der Schlüsselerzeugung (normal-SdT)

Berechtigung SOLLTE die ausschließliche Verwendung etablierter kryptografischer Algorithmen bei der Schlüsselerzeugung nach {einem anerkannten Standard} verankern.

BER.7.1 UUID vom 29.05.26 ist gleich BER.6.1 UUID vom 01.07.26; cos-sim = 1.0

BER.6.1 Etablierte Algorithmen bei der Schlüsselerzeugung (normal-SdT) vom 01.07.26

Berechtigung SOLLTE die ausschließliche Verwendung etablierter kryptografischer Algorithmen bei der Schlüsselerzeugung nach {einem anerkannten Standard} verankern.

▣ **BER.7.2 Schlüssellänge (normal-SdT)**

Berechtigung SOLLTE die Schlüssellängen nach {einem anerkannten Standard} bei der Schlüsselerzeugung zuweisen.

BER.7.2 UUID vom 29.05.26 ist gleich BER.6.2 UUID vom 01.07.26; cos-sim = 1.0

BER.6.2 Schlüssellänge (normal-SdT) vom 01.07.26

Berechtigung SOLLTE die Schlüssellängen nach {einem anerkannten Standard} bei der Schlüsselerzeugung zuweisen.

▣ **BER.7.3 Verzeichnis öffentlicher Schlüssel (normal-SdT)**

Berechtigung SOLLTE zu jedem öffentlichen Schlüssel die dazugehörige Identität, das Ablaufdatum, den Nutzungszweck, die Schlüsselart und den Algorithmus bei der Schlüsselbeglaubigung dokumentieren.

BER.7.3 UUID vom 29.05.26 ist gleich BER.6.3 UUID vom 01.07.26; cos-sim = 1.0

BER.6.3 Verzeichnis öffentlicher Schlüssel (normal-SdT) vom 01.07.26

Berechtigung SOLLTE zu jedem öffentlichen Schlüssel die dazugehörige Identität, das Ablaufdatum, den Nutzungszweck, die Schlüsselart und den Algorithmus bei der Schlüsselbeglaubigung dokumentieren.

▣ **BER.7.4 Erzeugung auf sicheren IT-Systemen (normal-SdT)**

Berechtigung SOLLTE die Verwendung eines IT-Systems, welches mindestens dasselbe Schutzniveau bietet, für das der Schlüssel eingesetzt werden soll, bei der Schlüsselerzeugung verankern.

BER.7.4 UUID vom 29.05.26 ist gleich BER.6.4 UUID vom 01.07.26; cos-sim = 1.0

BER.6.4 Erzeugung auf sicheren IT-Systemen (normal-SdT) vom 01.07.26

Berechtigung SOLLTE die Verwendung eines IT-Systems, welches mindestens dasselbe Schutzniveau bietet, für das der Schlüssel eingesetzt werden soll, bei der Schlüsselerzeugung verankern.

▣ **BER.7.5 Kriterien für die Qualität von Zufallszahlen (normal-SdT)**

Berechtigung SOLLTE {Kriterien} für die Qualität von Zufallszahlen bei der Schlüsselerzeugung verankern.

BER.7.5 UUID vom 29.05.26 ist gleich BER.6.5 UUID vom 01.07.26; cos-sim = 1.0

BER.6.5 Kriterien für die Qualität von Zufallszahlen (normal-SdT) vom 01.07.26

Berechtigung SOLLTE {Kriterien} für die Qualität von Zufallszahlen bei der Schlüsselerzeugung verankern.

BER.7.6 Etablierte Algorithmen beim Transport (normal-SdT)

Berechtigung SOLLTE die ausschließliche Verwendung etablierter kryptografischer Algorithmen beim Transport geheimer Schlüssel verankern.

BER.7.6 UUID vom 29.05.26 ist gleich BER.6.6 UUID vom 01.07.26; cos-sim = 1.0

BER.6.6 Etablierte Algorithmen beim Transport (normal-SdT) vom 01.07.26

Berechtigung SOLLTE die ausschließliche Verwendung etablierter kryptografischer Algorithmen beim Transport geheimer Schlüssel verankern.

BER.7.7 Kein Transport privater Schlüssel (erhöht)

Berechtigung KANN den Export privater Schlüssel durch {eine zuständige Person oder Rolle} autorisieren.

BER.7.7 UUID vom 29.05.26 ist gleich BER.6.7 UUID vom 01.07.26; cos-sim = 1.0

BER.6.7 Kein Transport privater Schlüssel (erhöht) vom 01.07.26

Berechtigung KANN den Export privater Schlüssel durch {eine zuständige Person oder Rolle} autorisieren.

BER.7.8 Etablierte Algorithmen bei der Schlüsselnutzung (normal-SdT)

Berechtigung SOLLTE die ausschließliche Verwendung etablierter Algorithmen bei der Schlüsselnutzung verankern.

BER.7.8 UUID vom 29.05.26 ist gleich BER.6.8 UUID vom 01.07.26; cos-sim = 1.0

BER.6.8 Etablierte Algorithmen bei der Schlüsselnutzung (normal-SdT) vom 01.07.26

Berechtigung SOLLTE die ausschließliche Verwendung etablierter Algorithmen bei der Schlüsselnutzung verankern.

BER.7.9 Zweckbindung (normal-SdT)

Berechtigung SOLLTE Verstöße gegen die Zweckbindung bei der Schlüsselnutzung untersagen.

BER.7.9 UUID vom 29.05.26 ist gleich BER.6.9 UUID vom 01.07.26; cos-sim = 1.0

BER.6.9 Zweckbindung (normal-SdT) vom 01.07.26

Berechtigung SOLLTE Verstöße gegen die Zweckbindung bei der Schlüsselnutzung untersagen.

BER.7.10 Abgelaufene Schlüssel (normal-SdT)

Berechtigung SOLLTE die Nutzung des Schlüssels zur Verschlüsselung oder Signierung nach Ablauf der Nutzungszeit untersagen.

BER.7.10 UUID vom 29.05.26 ist gleich BER.6.10 UUID vom 01.07.26; cos-sim = 1.0

BER.6.10 Abgelaufene Schlüssel (normal-SdT) vom 01.07.26

Berechtigung SOLLTE die Nutzung des Schlüssels zur Verschlüsselung oder Signierung nach Ablauf der Nutzungszeit untersagen.

❏ **BER.7.11 Integrität (normal-SdT)**

Berechtigung SOLLTE die Verifikation der Integrität geheimer Schlüssel vor jeder Nutzung verankern.

BER.7.11 UUID vom 29.05.26 ist gleich BER.6.11 UUID vom 01.07.26; cos-sim = 1.0

BER.6.11 Integrität (normal-SdT) vom 01.07.26

Berechtigung SOLLTE die Verifikation der Integrität geheimer Schlüssel vor jeder Nutzung verankern.

❏ **BER.7.12 Authentizität (normal-SdT)**

Berechtigung SOLLTE die Verifikation der Authentizität öffentlicher Schlüssel vor jeder Nutzung verankern.

BER.7.12 UUID vom 29.05.26 ist gleich BER.6.12 UUID vom 01.07.26; cos-sim = 1.0

BER.6.12 Authentizität (normal-SdT) vom 01.07.26

Berechtigung SOLLTE die Verifikation der Authentizität öffentlicher Schlüssel vor jeder Nutzung verankern.

❏ **BER.7.13 Gültigkeit (normal-SdT)**

Berechtigung SOLLTE die Verifikation der Gültigkeit des Schlüssels vor jeder Nutzung verankern.

BER.7.13 UUID vom 29.05.26 ist gleich BER.6.13 UUID vom 01.07.26; cos-sim = 1.0

BER.6.13 Gültigkeit (normal-SdT) vom 01.07.26

Berechtigung SOLLTE die Verifikation der Gültigkeit des Schlüssels vor jeder Nutzung verankern.

❏ **BER.7.14 Schlüssel vor Ablauf prüfen (normal-SdT)**

Berechtigung SOLLTE Schlüssel auf das baldige Auslaufen der Nutzungszeit {regelmäßig} überprüfen.

BER.7.14 UUID vom 29.05.26 ist gleich BER.6.14 UUID vom 01.07.26; cos-sim = 1.0

BER.6.14 Schlüssel vor Ablauf prüfen (normal-SdT) vom 01.07.26

Berechtigung SOLLTE Schlüssel auf das baldige Auslaufen der Nutzungszeit {regelmäßig} überprüfen.

❏ **BER.7.15 Vorgehensweise nach Nutzung (normal-SdT)**

Berechtigung SOLLTE eine Vorgehensweise zur Außerbetriebnahme geheimer Schlüssel , sobald sie nicht mehr benötigt werden, verankern.

BER.7.15 UUID vom 29.05.26 ist gleich BER.6.15 UUID vom 01.07.26; cos-sim = 1.0

BER.6.15 Vorgehensweise nach Nutzung (normal-SdT) vom 01.07.26

Berechtigung SOLLTE eine Vorgehensweise zur Außerbetriebnahme geheimer Schlüssel , sobald sie nicht mehr benötigt werden, verankern.

❏ **BER.7.16 Vorgaben für die Schlüsselbeglaubigung (normal-SdT)**

Berechtigung SOLLTE Vorgaben für die Schlüsselbeglaubigung verankern.

BER.7.16 UUID vom 29.05.26 ist gleich BER.6.16 UUID vom 01.07.26; cos-sim = 1.0

BER.6.16 Vorgaben für die Schlüsselbeglaubigung (normal-SdT) vom 01.07.26

Berechtigung SOLLTE Vorgaben für die Schlüsselbeglaubigung verankern.

BER.7.16.1 Zertifizierungsstelle (normal-SdT)

Berechtigung SOLLTE die Beglaubigung von Schlüsseln {einer zuständigen Person oder Rolle} zuweisen.

BER.7.16.1 UUID vom 29.05.26 ist gleich BER.6.16.1 UUID vom 01.07.26; cos-sim = 1.0

BER.6.16.1 Zertifizierungsstelle (normal-SdT) vom 01.07.26

Berechtigung SOLLTE die Beglaubigung von Schlüsseln {einer zuständigen Person oder Rolle} zuweisen.

BER.7.16.2 Beglaubigung (normal-SdT)

Berechtigung SOLLTE den Schlüssel anhand der Vorgaben für die Schlüsselbeglaubigung bei Beantragung einer Beglaubigung testen.

BER.7.16.2 UUID vom 29.05.26 ist gleich BER.6.16.2 UUID vom 01.07.26; cos-sim = 1.0

BER.6.16.2 Beglaubigung (normal-SdT) vom 01.07.26

Berechtigung SOLLTE den Schlüssel anhand der Vorgaben für die Schlüsselbeglaubigung bei Beantragung einer Beglaubigung testen.

BER.7.16.3 Erneuerung (normal-SdT)

Berechtigung SOLLTE den Schlüssel anhand der Vorgaben für die Schlüsselbeglaubigung bei Erneuerung einer Beglaubigung testen.

BER.7.16.3 UUID vom 29.05.26 ist gleich BER.6.16.3 UUID vom 01.07.26; cos-sim = 1.0

BER.6.16.3 Erneuerung (normal-SdT) vom 01.07.26

Berechtigung SOLLTE den Schlüssel anhand der Vorgaben für die Schlüsselbeglaubigung bei Erneuerung einer Beglaubigung testen.

BER.7.16.4 Revocation (normal-SdT)

Berechtigung SOLLTE den Schlüssel anhand der Vorgaben für die Schlüsselbeglaubigung bei Revocation einer Beglaubigung testen.

BER.7.16.4 UUID vom 29.05.26 ist gleich BER.6.16.4 UUID vom 01.07.26; cos-sim = 1.0

BER.6.16.4 Revocation (normal-SdT) vom 01.07.26

Berechtigung SOLLTE den Schlüssel anhand der Vorgaben für die Schlüsselbeglaubigung bei Revocation einer Beglaubigung testen.

BER.7.16.5 Beglaubigungsstatus (normal-SdT)

Berechtigung SOLLTE den Beglaubigungsstatus des Schlüssels im Verzeichnis öffentlicher Schlüssel dokumentieren.

BER.7.16.5 UUID vom 29.05.26 ist gleich BER.6.16.5 UUID vom 01.07.26; cos-sim = 1.0

BER.6.16.5 Beglaubigungsstatus (normal-SdT) vom 01.07.26

Berechtigung SOLLTE den Beglaubigungsstatus des Schlüssels im Verzeichnis öffentlicher Schlüssel dokumentieren.

BER.7.16.6 Revocationstatus (normal-SdT)

Berechtigung SOLLTE den Revocationstatus des Schlüssels im Verzeichnis öffentlicher Schlüssel dokumentieren.

BER.7.16.6 UUID vom 29.05.26 ist gleich BER.6.16.6 UUID vom 01.07.26; cos-sim = 1.0

BER.6.16.6 Revocationstatus (normal-SdT) vom 01.07.26

Berechtigung SOLLTE den Revocationstatus des Schlüssels im Verzeichnis öffentlicher Schlüssel dokumentieren.

GC.3.2 Analyse der internen interessierten Parteien (normal-SdT)

Governance und Compliance MUSS ein Verfahren zum Ermitteln aller internen interessierten Parteien und ihrer Bedürfnisse und Erwartungen an das Informationssicherheitsmanagement der Institution verankern.

GC.3.2 UUID vom 29.05.26 ist gleich GC.4.2 UUID vom 01.07.26; cos-sim = 0.8

GC.4.2 Analyse der internen interessierten Parteien (normal-SdT) vom 01.07.26

Governance und Compliance MUSS alle internen interessierten Parteien sowie ihre Bedürfnisse und Erwartungen an das Informationssicherheitsmanagement der Institution analysieren.

GC.6.1.1 Festlegung einer Sicherheitsstrategie (normal-SdT)

Governance und Compliance SOLLTE eine grundlegende Strategie zur Erreichung der Ziele für die Informationssicherheit gemeinsam mit der Institutionsleitung festlegen.

GC.6.1.1 UUID vom 29.05.26 ist gleich GC.5.1.1 UUID vom 01.07.26; cos-sim = 1.0

GC.5.1.1 Festlegung einer Sicherheitsstrategie (normal-SdT) vom 01.07.26

Governance und Compliance MUSS eine grundlegende Strategie zur Erreichung der Ziele für die Informationssicherheit gemeinsam mit der Institutionsleitung festlegen.

GC.6.1.2 Verpflichtung der Institutionsleitung (normal-SdT)

Governance und Compliance MUSS die Verpflichtung der Institutionsleitung formal zuweisen.

GC.6.1.2 UUID vom 29.05.26 ist gleich GC.5.1.2 UUID vom 01.07.26; cos-sim = 0.91

GC.5.1.2 Verpflichtung der Institutionsleitung (normal-SdT) vom 01.07.26

Governance und Compliance MUSS die Verpflichtung der Institutionsleitung zuweisen.

GC.6.1.3 Erstellung einer Sicherheitsleitlinie (normal-SdT)

Governance und Compliance MUSS eine für die Institution passende Sicherheitsleitlinie festlegen.

GC.6.1.3 UUID vom 29.05.26 ist gleich GC.5.1.3 UUID vom 01.07.26; cos-sim = 1.0

GC.5.1.3 Erstellung einer Sicherheitsleitlinie (normal-SdT) vom 01.07.26

Governance und Compliance MUSS eine für die Institution passende Sicherheitsleitlinie festlegen.

GC.6.1.4 Freigabe der Sicherheitsleitlinie (normal-SdT)

Governance und Compliance MUSS die festgelegte Sicherheitsleitlinie durch die Institutionsleitung autorisieren.

GC.6.1.4 UUID vom 29.05.26 ist gleich GC.5.1.4 UUID vom 01.07.26; cos-sim = 1.0

GC.5.1.4 Freigabe der Sicherheitsleitlinie (normal-SdT) vom 01.07.26

Governance und Compliance MUSS die festgelegte Sicherheitsleitlinie durch die Institutionsleitung autorisieren.

GC.7.1.3 Vertragliche Verpflichtungen (normal-SdT)

Governance und Compliance SOLLTE die Zusammenstellung vertraglicher Verpflichtungen, welche die Verarbeitung von Informationen durch die Institution betreffen, dokumentieren.

GC.7.1.3 UUID vom 29.05.26 ist gleich GC.3.1.3 UUID vom 01.07.26; cos-sim = 0.8

GC.3.1.3 Vertragliche Verpflichtungen (normal-SdT) vom 01.07.26

Governance und Compliance SOLLTE vertragliche Verpflichtungen, welche die Verarbeitung von Informationen durch die Institution betreffen, analysieren.

GC.7.1.4 Prävention von Verstößen (normal-SdT)

Governance und Compliance SOLLTE Verfahren zur Prävention gegen Verstöße verankern.

GC.7.1.4 UUID vom 29.05.26 ist gleich GC.3.1.4 UUID vom 01.07.26; cos-sim = 1.0

GC.3.1.4 Prävention von Verstößen (normal-SdT) vom 01.07.26

Governance und Compliance SOLLTE Verfahren zur Prävention gegen Verstöße verankern.

GC.8.1.1 Festlegung von Rollen und Zuständigkeiten (normal-SdT)

Governance und Compliance MUSS die Rollen und Zuständigkeiten im Rahmen des ISMS inklusive ihrer Kompetenzen bzw. Befugnisse zuweisen.

GC.8.1.1 UUID vom 29.05.26 ist gleich GC.9.1.1 UUID vom 01.07.26; cos-sim = 1.0

GC.9.1.1 Festlegung von Rollen und Zuständigkeiten (normal-SdT) vom 01.07.26

Governance und Compliance MUSS die {Rollen und Zuständigkeiten} im Rahmen des ISMS inklusive ihrer Kompetenzen bzw. Befugnisse zuweisen.

GC.8.1.1.1 Informationssicherheitsbeauftragter (normal-SdT)

Governance und Compliance MUSS die Rolle des Informationssicherheitsbeauftragten {einer unabhängigen Person} , welche unmittelbar der Institutionsleitung unterstellt ist, zuweisen.

GC.8.1.1.1 UUID vom 29.05.26 ist gleich GC.9.1.1.1 UUID vom 01.07.26; cos-sim = 0.83

GC.9.1.1.1 Informationssicherheitsbeauftragter (normal-SdT) vom 01.07.26

Governance und Compliance MUSS die Zuständigkeit für Informationssicherheit (einer unabhängigen Person) , welche unmittelbar der Institutionsleitung unterstellt ist, zuweisen.

▣ **GC.8.1.1.1 Vorspracherecht des Informationssicherheitsbeauftragten (normal-SdT)**

Governance und Compliance MUSS das direkte Vorspracherecht des ISB bei der Institutionsleitung verankern.

GC.8.1.1.1 UUID vom 29.05.26 ist gleich GC.9.1.1.2 UUID vom 01.07.26; cos-sim = 0.94

GC.9.1.1.2 Vorspracherecht (normal-SdT) vom 01.07.26

Governance und Compliance MUSS das direkte Vorspracherecht des Informationssicherheitsbeauftragten bei der Institutionsleitung verankern.

▣ **GC.8.1.2 Stellvertreterregelungen (normal-SdT)**

Governance und Compliance MUSS Stellvertreterregelungen für alle relevanten Rollen und Zuständigkeiten im ISMS zuweisen.

GC.8.1.2 UUID vom 29.05.26 ist gleich GC.9.1.1.2 UUID vom 01.07.26; cos-sim = 1.0

GC.9.1.1.2 Stellvertreterregelungen (normal-SdT) vom 01.07.26

Governance und Compliance MUSS Stellvertreterregelungen für alle relevanten Rollen und Zuständigkeiten im ISMS zuweisen.

▣ **GC.8.1.3 Vermeidung von Interessenkonflikten (normal-SdT)**

Governance und Compliance MUSS Maßnahmen zur Vermeidung von Interessenkonflikten bei der Festlegung von Rollen und Zuständigkeiten des ISMS festlegen.

GC.8.1.3 UUID vom 29.05.26 ist gleich GC.9.1.1.3 UUID vom 01.07.26; cos-sim = 1.0

GC.9.1.1.3 Vermeidung von Interessenkonflikten (normal-SdT) vom 01.07.26

Governance und Compliance MUSS Maßnahmen zur Vermeidung von Interessenkonflikten bei der Festlegung von Rollen und Zuständigkeiten des ISMS festlegen.

▣ **GC.8.1.4 Festlegung einer Sicherheitsorganisation (normal-SdT)**

Governance und Compliance MUSS die Sicherheitsorganisation für das ISMS mit den festgelegten Rollen, Zuständigkeiten sowie Gremien festlegen.

GC.8.1.4 UUID vom 29.05.26 ist gleich GC.9.1 UUID vom 01.07.26; cos-sim = 0.91

GC.9.1 Festlegung einer Sicherheitsorganisation (normal-SdT) vom 01.07.26

Governance und Compliance MUSS die Sicherheitsorganisation für das ISMS unter Einbezug von Rollen, Zuständigkeiten sowie Gremien festlegen.

▣ **GC.8.1.5 Sicherstellung der Qualifikation (normal-SdT)**

Governance und Compliance MUSS für jeden Rollen- und Verantwortungsträger die erforderlichen Anforderungen und Fähigkeiten festlegen.

GC.8.1.5 UUID vom 29.05.26 ist gleich GC.9.1.1.4 UUID vom 01.07.26; cos-sim = 1.0

GC.9.1.1.4 Sicherstellung der Qualifikation (normal-SdT) vom 01.07.26

Governance und Compliance MUSS für jeden Rollen- und Verantwortungsträger die erforderlichen Anforderungen und Fähigkeiten festlegen.

GC.8.1.6 Ressourcen für den Informationssicherheitsbeauftragten (normal-SdT)

Governance und Compliance MUSS dem Informationssicherheitsbeauftragten {hinreichende} Ressourcen zuweisen.

GC.8.1.6 UUID vom 29.05.26 ist gleich GC.9.1.1.1.1 UUID vom 01.07.26; cos-sim = 1.0

GC.9.1.1.1.1 Ressourcen für den Informationssicherheitsbeauftragten (normal-SdT) vom 01.07.26

Governance und Compliance MUSS dem Informationssicherheitsbeauftragten hinreichende Ressourcen zuweisen.

GC.9.1.2 Kommunikation im Projektmanagement (normal-SdT)

Governance und Compliance MUSS bei sicherheitsrelevanten Projekten die Beteiligung {der relevanten Sicherheitsorgane} zu festgelegten Zeitpunkten im Projektverlauf verankern.

GC.9.1.2 UUID vom 29.05.26 ist gleich GC.10.1.2 UUID vom 01.07.26; cos-sim = 1.0

GC.10.1.2 Kommunikation im Projektmanagement (normal-SdT) vom 01.07.26

Governance und Compliance MUSS bei sicherheitsrelevanten Projekten die Beteiligung {der relevanten Sicherheitsorgane} zu festgelegten Zeitpunkten im Projektverlauf verankern.

GC.9.1.3 Dokumentenlenkung (normal-SdT)

Governance und Compliance MUSS ein Verfahren zur Lenkung der Dokumente im Rahmen des ISMS über den kompletten Lebenszyklus von Dokumenten verankern.

GC.9.1.3 UUID vom 29.05.26 ist gleich GC.11.1 UUID vom 01.07.26; cos-sim = 0.92

GC.11.1 Dokumentenlenkung (normal-SdT) vom 01.07.26

Governance und Compliance MUSS ein Verfahren zur Lenkung der Dokumente im Rahmen des ISMS über ihren kompletten Lebenszyklus hinweg verankern.

GC.10.2 Freigabe von Vorgehensweisen (normal-SdT)

Governance und Compliance MUSS die Verfahren für das ISMS durch die Institutionsleitung autorisieren.

GC.10.2 UUID vom 29.05.26 ist gleich GC.1.2 UUID vom 01.07.26; cos-sim = 0.88

GC.1.2 Freigabe des ISMS (normal-SdT) vom 01.07.26

Governance und Compliance MUSS alle festgelegten Verfahren für das ISMS durch die Institutionsleitung autorisieren.

KONF.11.8.1 Einschränkung von Zonentransfers (normal-SdT)

Konfiguration für DNS-Server SOLLTE Zonentransfers einschränken.

KONF.11.8.1 UUID vom 29.05.26 ist gleich KONF.11.7.1 UUID vom 01.07.26; cos-sim = 1.0

KONF.11.7.1 Einschränkung von Zonentransfers (normal-SdT) vom 01.07.26
Konfiguration für DNS-Server SOLLTE Zonentransfers einschränken.

📦 KONF.11.8.2 Einschränkung von TK-Verbindungen (normal-SdT)

Konfiguration für TK-Anwendungen SOLLTE unerwünschte TK-Verbindungen einschränken.

KONF.11.8.2 UUID vom 29.05.26 ist gleich KONF.11.7.2 UUID vom 01.07.26; cos-sim = 1.0

KONF.11.7.2 Einschränkung von TK-Verbindungen (normal-SdT) vom 01.07.26
Konfiguration für TK-Anwendungen SOLLTE unerwünschte TK-Verbindungen einschränken.

📦 KONF.11.8.2.1 Einschränkung der TK-Gegenstellen (normal-SdT)

Konfiguration für TK-Anwendungen SOLLTE Verbindungen mit externen Gegenstellen einschränken.

KONF.11.8.2.1 UUID vom 29.05.26 ist gleich KONF.11.7.2.1 UUID vom 01.07.26; cos-sim = 1.0

KONF.11.7.2.1 Einschränkung der TK-Gegenstellen (normal-SdT) vom 01.07.26
Konfiguration für TK-Anwendungen SOLLTE Verbindungen mit externen Gegenstellen einschränken.

📦 KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest) (erhöht)

Konfiguration für Anwendungen KANN schützenswerte Daten bei der Speicherung (at-rest) verschlüsseln.

KONF.11.9 UUID vom 29.05.26 ist gleich KONF.11.8 UUID vom 01.07.26; cos-sim = 1.0

KONF.11.8 Verschlüsselung schützenswerter Daten (at-rest) (erhöht) vom 01.07.26
Konfiguration für Anwendungen KANN schützenswerte Daten bei der Speicherung (at-rest) verschlüsseln.

📦 PERF.1.1.1 Auswertung der Gefährdungslage (normal-SdT)

Monitoring-Evaluation SOLLTE die Gefährdungslage in Bezug auf geänderte Rahmenbedingungen überprüfen.

📦 PERF.1.1.2 Auswertung des Umsetzungsplans (normal-SdT)

Monitoring-Evaluation SOLLTE den Umsetzungsplan in Bezug auf den Fortschritt, die Einhaltung von Fristen und der inhaltlichen Korrektheit {regelmäßig} überprüfen.

PERF.1.1.2 UUID vom 29.05.26 ist gleich PERF.1.2 UUID vom 01.07.26; cos-sim = 0.42

PERF.1.2 Evaluation des Umsetzungsplans (normal-SdT) vom 01.07.26
Monitoring-Evaluation MUSS die {regelmäßige} Überprüfung und Fortschreibung des Umsetzungsplans in Bezug auf Fortschritt, Fristeinhaltung und inhaltlicher Korrektheit verankern.

📦 PERF.1.1.3 Auswertung von Auditergebnissen (normal-SdT)

Monitoring-Evaluation SOLLTE die Umsetzung von festgelegten Maßnahmen aus Auditergebnissen überprüfen.

❏ **PERF.1.1.4 Auswertung von Sicherheitsvorfällen (normal-SdT)**

Monitoring-Evaluation SOLLTE umgesetzte Maßnahmen als Folge von Sicherheitsvorfällen überprüfen.

❏ **PERF.5.1.1 Ergebnisse von Folgemaßnahmen (normal-SdT)**

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der den Status von Folgemaßnahmen vorangegangener Managementbewertungen enthält, dokumentieren.

PERF.5.1.1 UUID vom 29.05.26 ist gleich PERF.4.1.1 UUID vom 01.07.26; cos-sim = 0.8

PERF.4.1.1 Ergebnisse von Folgemaßnahmen (normal-SdT) vom 01.07.26

Monitoring-Evaluation SOLLTE den Status von Folgemaßnahmen vorangegangener Managementbewertungen als Ergebnis der Überprüfung in einem Managementbericht dokumentieren.

❏ **PERF.5.1.2 Geänderte Rahmenbedingungen (normal-SdT)**

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der geänderte Rahmenbedingungen mit Auswirkungen auf das Informationssicherheitsmanagement berücksichtigt, dokumentieren.

PERF.5.1.2 UUID vom 29.05.26 ist gleich PERF.4.1.2 UUID vom 01.07.26; cos-sim = 0.7

PERF.4.1.2 Geänderte Rahmenbedingungen (normal-SdT) vom 01.07.26

Monitoring-Evaluation SOLLTE veränderte Rahmenbedingungen mit Auswirkungen auf das Informationssicherheitsmanagement als Ergebnis der Überprüfung in einem Managementbericht dokumentieren.

❏ **PERF.5.1.3 Erfolge und Probleme (normal-SdT)**

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der bisherige Erfolge und Probleme (z. B. Sicherheitsvorfälle) beim Informationssicherheitsprozess berücksichtigt, dokumentieren.

PERF.5.1.3 UUID vom 29.05.26 ist gleich PERF.4.1.3 UUID vom 01.07.26; cos-sim = 0.82

PERF.4.1.3 Erfolge und Probleme (normal-SdT) vom 01.07.26

Monitoring-Evaluation SOLLTE bisherige Erfolge und Probleme (z. B. Sicherheitsvorfälle) beim Informationssicherheitsprozess als Ergebnis der Überprüfung in einem Managementbericht dokumentieren.

❏ **PERF.5.1.4 Interne Überprüfungen und Audits (normal-SdT)**

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der Ergebnisse interner Überprüfungen und Audits enthält, dokumentieren.

PERF.5.1.4 UUID vom 29.05.26 ist gleich PERF.4.1.4 UUID vom 01.07.26; cos-sim = 0.67

PERF.4.1.4 Interne Überprüfungen und Audits (normal-SdT) vom 01.07.26

Monitoring-Evaluation SOLLTE Auditberichte als Ergebnis der Überprüfung in einem Managementbericht dokumentieren.

❏ **PERF.5.1.5 Eignungsprüfung bisheriger Sicherheitsmaßnahmen (normal-SdT)**

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der eine Bewertung enthält, ob sich die Sicherheitsmaßnahmen zur Erreichung der Sicherheitsziele als geeignet erwiesen haben oder ob Maßnahmen geändert oder ergänzt werden müssen, dokumentieren.

PERF.5.1.5 UUID vom 29.05.26 ist gleich PERF.4.1.5 UUID vom 01.07.26; cos-sim = 0.69

PERF.4.1.5 Eignungsprüfung bisheriger Sicherheitsmaßnahmen (normal-SdT) vom 01.07.26

Monitoring-Evaluation SOLLTE eine Evaluation der Eignung umgesetzter Sicherheitsmaßnahmen zur Erreichung der Sicherheitsziele oder ob Maßnahmen geändert oder ergänzt werden müssen als Ergebnis der Überprüfung in einem Managementbericht dokumentieren.

▣ PERF.5.1.6 Rückmeldung von Stakeholdern (normal-SdT)

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der Rückmeldungen von Kunden, Geschäftspartnern, Mitarbeitern oder der Öffentlichkeit zu Sicherheitsaspekten bei der Bewertung berücksichtigt, dokumentieren.

PERF.5.1.6 UUID vom 29.05.26 ist gleich PERF.4.1.6 UUID vom 01.07.26; cos-sim = 0.83

PERF.4.1.6 Rückmeldung von Stakeholdern (normal-SdT) vom 01.07.26

Monitoring-Evaluation SOLLTE die Bewertung von Rückmeldungen von Kunden, Geschäftspartnern, Mitarbeitern oder der Öffentlichkeit zu Sicherheitsaspekten als Ergebnis der Überprüfung in einem Managementbericht dokumentieren.

▣ PERF.5.1.7 Status des Realisierungsplans (normal-SdT)

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der Berichte über die Reduzierung bestehender Umsetzungsdefizite und der damit verbundenen Risiken (Status des Realisierungsplans) dokumentieren.

PERF.5.1.7 UUID vom 29.05.26 ist gleich PERF.4.1.7 UUID vom 01.07.26; cos-sim = 0.38

PERF.4.1.7 Status des Realisierungsplans (normal-SdT) vom 01.07.26

Monitoring-Evaluation SOLLTE die erfolgreiche Umsetzung von Maßnahmen und des damit verringerten Risikos (Status des Umsetzungsplans) als Ergebnis der Überprüfung in einem Managementbericht dokumentieren.

▣ PERF.5.1.8 Verbesserungen (normal-SdT)

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der die Ergebnisse der Bewertung in Form von Verbesserungen in das ISMS einfließen lässt, dokumentieren.

PERF.5.1.8 UUID vom 29.05.26 ist gleich PERF.4.1.8 UUID vom 01.07.26; cos-sim = 0.5

PERF.4.1.8 Verbesserungen (normal-SdT) vom 01.07.26

Monitoring-Evaluation SOLLTE die aufgrund der Überprüfung abgeleitete Verbesserungen des ISMS als Ergebnis der Überprüfung in einem Managementbericht dokumentieren.

▣ PERF.5.1.9 Maßnahmenvorschläge (normal-SdT)

Monitoring-Evaluation MUSS die Ergebnisse dieser Überprüfungen in einem Managementbericht, der priorisierte Maßnahmenvorschläge mit realistischen Abschätzungen zum erwarteten Umsetzungsaufwand enthält, dokumentieren.

PERF.5.1.9 UUID vom 29.05.26 ist gleich PERF.4.1.9 UUID vom 01.07.26; cos-sim = 0.78

PERF.4.1.9 Maßnahmenvorschläge (normal-SdT) vom 01.07.26

Monitoring-Evaluation MUSS priorisierte Maßnahmenvorschläge mit realistischen Abschätzungen zum erwarteten Umsetzungsaufwand als Ergebnis der Überprüfung in einem Managementbericht dokumentieren.

PERF.5.2 Bericht an die Institutionsleitung (normal-SdT)

Monitoring-Evaluation MUSS die Institutionsleitung über den Stand des Managementsystems {regelmäßig} anhand des Managementberichtes informieren.

PERF.5.2 UUID vom 29.05.26 ist gleich PERF.4.2 UUID vom 01.07.26; cos-sim = 1.0

PERF.4.2 Bericht an die Institutionsleitung (normal-SdT) vom 01.07.26

Monitoring-Evaluation MUSS die Institutionsleitung über den Stand des Managementsystems {regelmäßig} anhand des Managementberichtes informieren.

PERF.6.1 Sicherheitsvorfälle (normal-SdT)

Monitoring-Evaluation MUSS effektive Monitoring-Methoden und -tools zur {regelmäßigen} Überwachung der Informationssicherheit verankern.

PERF.6.1 UUID vom 29.05.26 ist gleich PERF.5.1 UUID vom 01.07.26; cos-sim = 0.89

PERF.5.1 Methoden und Tools (normal-SdT) vom 01.07.26

Monitoring-Evaluation MUSS effektive Monitoring-Methoden und -tools zur {regelmäßigen} Überwachung der Informationssicherheit verankern.

PERF.6.1.1 Sicherheitsvorfälle (normal-SdT)

Monitoring-Evaluation MUSS Sicherheitsvorfälle überwachen.

PERF.6.1.2 Schwachstellen (normal-SdT)

Monitoring-Evaluation MUSS einen Umgang mit Schwachstellen festlegen.

PERF.6.1.3 Bedrohungen (normal-SdT)

Monitoring-Evaluation MUSS einen Umgang zur Erkennung und Reaktion auf neu auftretende Bedrohungen festlegen.

PERF.7.1 Aktualität der Anforderungen (normal-SdT)

Monitoring-Evaluation MUSS die Aktualität der Anforderungen {regelmäßig} überprüfen.

PERF.7.1 UUID vom 29.05.26 ist gleich PERF.1.3 UUID vom 01.07.26; cos-sim = 1.0

PERF.1.3 Aktualität der Anforderungen (normal-SdT) vom 01.07.26

Monitoring-Evaluation MUSS die Aktualität der Anforderungen {regelmäßig} überprüfen.

STM.4.2 Dokumentation relevanter Assets (normal-SdT)

Strukturmodellierung MUSS alle Assets mit Relevanz für die betrachteten Geschäftsprozesse dokumentieren.

STM.4.3 Mapping des Assets auf die Zielobjektkategorien (normal-SdT)

Strukturmodellierung MUSS allen relevanten Assets passende Zielobjektkategorien zuweisen.

STM.4.3 UUID vom 29.05.26 ist gleich STM.2.1.3 UUID vom 01.07.26; cos-sim = 0.86

STM.2.1.3 Mapping der Assets auf Zielobjektkategorien (normal-SdT) vom 01.07.26

Strukturmodellierung MUSS allen relevanten Assets eine oder mehrere Zielobjektkategorien zuweisen.

STM.5.2 Vererbung von Zielobjektkategorien (normal-SdT)

Strukturmodellierung MUSS die Ergänzung der zuvor zugeordneten Zielobjektkategorien um diejenigen Kategorien die in der Zielobjekthierarchie übergeordnet sind ausführen.

STM.5.2 UUID vom 29.05.26 ist gleich STM.2.1.4.1 UUID vom 01.07.26; cos-sim = 0.45

STM.2.1.4.1 Vererbung von Zielobjektkategorien (normal-SdT) vom 01.07.26

Strukturmodellierung MUSS die in der Hierarchie übergeordneten Zielobjektkategorien ebenfalls dem jeweiligen Asset die in der Zielobjekthierarchie übergeordnet sind zuweisen.

STM.5.3 Konsolidierung und Redundanzprüfung (normal-SdT)

Strukturmodellierung MUSS eine Konsolidierung und Redundanzprüfung des Anforderungspakets ausführen.

STM.5.3 UUID vom 29.05.26 ist gleich STM.2.1.4.2 UUID vom 01.07.26; cos-sim = 1.0

STM.2.1.4.2 Konsolidierung und Redundanzprüfung (normal-SdT) vom 01.07.26

Strukturmodellierung MUSS eine Konsolidierung und Redundanzprüfung des Anforderungspakets ausführen.

STM.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie (normal-SdT)

Strukturmodellierung MUSS die Modellierung aller weiteren Anforderungen denen kein Zielobjektkategorie zugeordnet ist ausführen.

STM.5.4 UUID vom 29.05.26 ist gleich STM.2.1.5 UUID vom 01.07.26; cos-sim = 0.88

STM.2.1.5 Modellierung der Anforderungen ohne Zielobjektkategorie (normal-SdT) vom 01.07.26

Strukturmodellierung MUSS alle weiteren Anforderungen denen keine Zielobjektkategorie zugeordnet ist modellieren.

STM.6.1 Auf Grund anforderungsloser Assets (normal-SdT)

Strukturmodellierung MUSS die Ergänzung des Anforderungspakets um Anforderungen für die es keine passenden Anforderungen gibt ausführen.

STM.6.1 UUID vom 29.05.26 ist gleich STM.2.1.6 UUID vom 01.07.26; cos-sim = 0.57

STM.2.1.6 Aufgrund anforderungsloser Assets (normal-SdT) vom 01.07.26

Strukturmodellierung MUSS für Assets, für die es noch keine passenden GS++-Anforderungen gibt, zusätzliche Anforderungen dem Anforderungspaket zuweisen.

STM.6.2 Auf Grund externer Verpflichtungen (normal-SdT)

Strukturmodellierung MUSS die Ergänzung des Anforderungspakets um Anforderungen für Assets die sich aus dem individuellen Compliance-Umfeld der Institution ergeben ausführen.

STM.6.2 UUID vom 29.05.26 ist gleich STM.2.1.7 UUID vom 01.07.26; cos-sim = 0.5

STM.2.1.7 Aufgrund externer Verpflichtungen (normal-SdT) vom 01.07.26

Strukturmodellierung MUSS für das individuelle Compliance-Umfeld der Institution zusätzliche Anforderungen dem Anforderungspaket zuweisen.

STM.7.1 Überprüfung des gesetzten Sicherheitsniveaus (normal-SdT)

Strukturmodellierung MUSS die initiale Einstufung der Sicherheitsniveaus der Anforderungen im Anforderungspaket überprüfen.

STM.7.1 UUID vom 29.05.26 ist gleich STM.3.1 UUID vom 01.07.26; cos-sim = 0.87

STM.3.1 Überprüfung des gesetzten Sicherheitsniveaus (normal-SdT) vom 01.07.26

Strukturmodellierung SOLLTE die initiale Einstufung der Sicherheitsniveaus der Anforderungen im Anforderungspaket bei Abweichungen des Kontextes der Institution überprüfen.

STM.8.1 Risikobetrachtung bei fehlenden Anforderungen (normal-SdT)

Strukturmodellierung MUSS eine Risikobetrachtung für die Assets, für die keine einschlägigen Anforderungen identifiziert werden konnten, oder die einen hohen Schutzbedarf haben ausführen.

STM.8.1 UUID vom 29.05.26 ist gleich STM.4.1 UUID vom 01.07.26; cos-sim = 0.34

STM.4.1 Durchführung der Risikobetrachtung (normal-SdT) vom 01.07.26

Strukturmodellierung MUSS eine Risikobetrachtung bei durch die GS++-Methodik festgelegter Notwendigkeit ausführen.

STM.9.1 Verteilung der führenden Zuständigkeiten (normal-SdT)

Strukturmodellierung MUSS jeder Anforderung eine zuständige Person oder Rolle für den zugeordneten Prozess zuweisen.

STM.9.2 Weitere Parameter (normal-SdT)

Strukturmodellierung MUSS Parameter innerhalb einer Anforderung zur automatisierten Prüfung zuweisen.

STM.9.2 UUID vom 29.05.26 ist gleich STM.5.1 UUID vom 01.07.26; cos-sim = 0.27

STM.5.1 Setzen von Parametern (normal-SdT) vom 01.07.26

Strukturmodellierung MUSS bei Anforderungen mit Parametern konkrete Werte zuweisen.

📋 UMS.3.2 Priorisierung von Maßnahmen (normal-SdT)

Umsetzung MUSS eine Priorisierung der festgelegten Maßnahmen auf Basis der der Risikobewertung, Abhängigkeiten und Ressourcenverfügbarkeit festlegen.

UMS.3.2 UUID vom 29.05.26 ist gleich UMS.2.2 UUID vom 01.07.26; cos-sim = 1.0

UMS.2.2 Priorisierung von Maßnahmen (normal-SdT) vom 01.07.26

Umsetzung MUSS eine Priorisierung der festgelegten Maßnahmen auf Basis der der Risikobewertung, Abhängigkeiten und Ressourcenverfügbarkeit festlegen.

📋 UMS.4.2 Festlegung von Umsetzungsfristen (normal-SdT)

Umsetzung MUSS ein realistisches Zieldatum für die Umsetzung der bisher nicht umgesetzten Anforderungen festlegen.

UMS.4.2 UUID vom 29.05.26 ist gleich UMS.4.1 UUID vom 01.07.26; cos-sim = 1.0

UMS.4.1 Festlegung von Umsetzungsfristen (normal-SdT) vom 01.07.26

Umsetzung MUSS ein realistisches Zieldatum für die Umsetzung der bisher nicht umgesetzten Anforderungen festlegen.

📋 VRB.1.2 Änderungen im ISMS (normal-SdT)

Verbesserung MUSS ein Verfahren zum Umgang mit Änderungen im ISMS verankern.

📋 VRB.8.1 Behandlung von Compliance-Verstößen (normal-SdT)

Verbesserung SOLLTE ein Verfahren zur Behandlung von Verstößen unter Berücksichtigung der Betroffenenrechte verankern.

VRB.8.1 UUID vom 29.05.26 ist gleich VRB.7.1 UUID vom 01.07.26; cos-sim = 1.0

VRB.7.1 Behandlung von Compliance-Verstößen (normal-SdT) vom 01.07.26

Verbesserung SOLLTE ein Verfahren zur Behandlung von Verstößen unter Berücksichtigung der Betroffenenrechte verankern.

Neue Anforderungen

[Zurück zu Inhalte](#)

Anzahl neuer Anforderungen: 72

🌟 BER.3.23 Alternative Authentifizierung am IT-System (erhöht)

Berechtigung für IT-Systeme KANN ein ebenso vertrauenswürdiges, alternatives Verfahren zur Authentifizierung verankern.

🌟 BER.3.24 Alternative Authentifizierung an der Anwendung (erhöht)

Berechtigung für Anwendungen KANN ein ebenso vertrauenswürdiges, alternatives Verfahren zur Authentifizierung verankern.

BER.3.24 UUID vom 01.07.26 ist gleich KONF.11.3 UUID vom 29.05.26; cos-sim = 0.74

KONF.11.3 Alternative Authentifizierung (erhöht) vom 29.05.26

Konfiguration für Anwendungen KANN ein ebenso vertrauenswürdiges, alternatives Verfahren zur Authentifizierung aktivieren.

✦ **BER.3.25 Identitätsüberprüfung (normal-SdT)**

Berechtigung SOLLTE eine Identitätsüberprüfung vor dem Zurücksetzen von Passworten ausführen.

BER.3.25 UUID vom 01.07.26 ist gleich BER.4.1 UUID vom 29.05.26; cos-sim = 1.0

BER.4.1 Identitätsüberprüfung (normal-SdT) vom 29.05.26

Berechtigung SOLLTE eine Identitätsüberprüfung vor dem Zurücksetzen von Passworten ausführen.

✦ **BER.4.1.1 Rollenbasierte Berechtigung (normal-SdT)**

Berechtigung SOLLTE Berechtigungen rollenbasiert zuweisen.

BER.4.1.1 UUID vom 01.07.26 ist gleich BER.5.1.1 UUID vom 29.05.26; cos-sim = 1.0

BER.5.1.1 Rollenbasierte Berechtigung (normal-SdT) vom 29.05.26

Berechtigung SOLLTE Berechtigungen rollenbasiert zuweisen.

✦ **BER.4.1.2 JIT-/JEA-Berechtigungen (erhöht)**

Berechtigung KANN die Berechtigung zum Zeitpunkt des Zugriffs für {besonders kritische Ressourcen oder Zugänge} aktivieren.

BER.4.1.2 UUID vom 01.07.26 ist gleich BER.5.1.2 UUID vom 29.05.26; cos-sim = 1.0

BER.5.1.2 JIT-/JEA-Berechtigungen (erhöht) vom 29.05.26

Berechtigung KANN die Berechtigung zum Zeitpunkt des Zugriffs für {besonders kritische Ressourcen oder Zugänge} aktivieren.

✦ **BER.4.2 Begründung von Berechtigungen (normal-SdT)**

Berechtigung SOLLTE die Vergabe von Berechtigungen und Änderungen an Berechtigungen mit einer Begründung dokumentieren.

BER.4.2 UUID vom 01.07.26 ist gleich BER.5.2 UUID vom 29.05.26; cos-sim = 1.0

BER.5.2 Begründung von Berechtigungen (normal-SdT) vom 29.05.26

Berechtigung SOLLTE die Vergabe von Berechtigungen und Änderungen an Berechtigungen mit einer Begründung dokumentieren.

✦ **BER.4.3 Überprüfung von Berechtigungen (normal-SdT)**

Berechtigung SOLLTE vergebene Berechtigungen {regelmäßig} auf Erforderlichkeit überprüfen.

BER.4.3 UUID vom 01.07.26 ist gleich BER.5.3 UUID vom 29.05.26; cos-sim = 1.0

BER.5.3 Überprüfung von Berechtigungen (normal-SdT) vom 29.05.26

Berechtigung SOLLTE vergebene Berechtigungen {regelmäßig} auf Erforderlichkeit überprüfen.

✨ **BER.4.3.1 Überprüfung tatsächlicher Berechtigungen (normal-SdT)**

Berechtigung SOLLTE dokumentierte und tatsächlich vergebene Berechtigungen {regelmäßig} auf Übereinstimmung überprüfen.

BER.4.3.1 UUID vom 01.07.26 ist gleich BER.5.3.1 UUID vom 29.05.26; cos-sim = 1.0

BER.5.3.1 Überprüfung tatsächlicher Berechtigungen (normal-SdT) vom 29.05.26

Berechtigung SOLLTE dokumentierte und tatsächlich vergebene Berechtigungen {regelmäßig} auf Übereinstimmungüberprüfen.

✨ **BER.4.4 Kompromittierte Berechtigungsmittel (normal-SdT)**

Berechtigung SOLLTE kompromittierte Berechtigungsmittel deaktivieren.

BER.4.4 UUID vom 01.07.26 ist gleich BER.5.4 UUID vom 29.05.26; cos-sim = 1.0

BER.5.4 Kompromittierte Berechtigungsmittel (normal-SdT) vom 29.05.26

Berechtigung SOLLTE kompromittierte Berechtigungsmittel deaktivieren.

✨ **BER.4.5 Systemfunktionen ohne Authentifizierung (normal-SdT)**

Berechtigung für IT-Systeme SOLLTE Funktionen, auf die ohne vorherige Authentifizierung zugegriffen werden kann, dokumentieren.

BER.4.5 UUID vom 01.07.26 ist gleich BER.5.5 UUID vom 29.05.26; cos-sim = 1.0

BER.5.5 Systemfunktionen ohne Authentifizierung (normal-SdT) vom 29.05.26

Berechtigung für IT-Systeme SOLLTE Funktionen, auf die ohne vorherige Authentifizierung zugegriffen werden kann, dokumentieren.

✨ **BER.4.6 Anwendungsfunktionen ohne Authentifizierung (normal-SdT)**

Berechtigung für Anwendungen SOLLTE Funktionen, auf die ohne vorherige Authentifizierung zugegriffen werden kann, dokumentieren.

BER.4.6 UUID vom 01.07.26 ist gleich BER.5.6 UUID vom 29.05.26; cos-sim = 1.0

BER.5.6 Anwendungsfunktionen ohne Authentifizierung (normal-SdT) vom 29.05.26

Berechtigung für Anwendungen SOLLTE Funktionen, auf die ohne vorherige Authentifizierung zugegriffen werden kann, dokumentieren.

✨ **BER.4.7 IT-System-Zugangskonto (erhöht)**

Berechtigung für IT-Systeme KANN diese genau einem Zugangskonto zuweisen.

BER.4.7 UUID vom 01.07.26 ist gleich BER.5.7 UUID vom 29.05.26; cos-sim = 1.0

BER.5.7 IT-System-Zugangskonto (erhöht) vom 29.05.26

Berechtigung für IT-Systeme KANN diese genau einem Zugangskonto zuweisen.

✦ **BER.4.8 Entzug von Berechtigungen (normal-SdT)**

Berechtigung SOLLTE eine Vorgehensweise zum Entzug von Berechtigungen verankern.

BER.4.8 UUID vom 01.07.26 ist gleich BER.5.8 UUID vom 29.05.26; cos-sim = 1.0

BER.5.8 Entzug von Berechtigungen (normal-SdT) vom 29.05.26

Berechtigung SOLLTE eine Vorgehensweise zum Entzug von Berechtigungen verankern.

✦ **BER.5.9 Anlassbezogene Passwortwechsel (normal-SdT)**

Berechtigung SOLLTE einen Passwortwechsel ausschließlich anlassbezogen ausführen.

BER.5.9 UUID vom 01.07.26 ist gleich BER.6.9 UUID vom 29.05.26; cos-sim = 1.0

BER.6.9 Anlassbezogene Passwortwechsel (normal-SdT) vom 29.05.26

Berechtigung SOLLTE einen Passwortwechsel ausschließlich anlassbezogen ausführen.

✦ **BER.5.10 Monitoring von Zugangsdaten (normal-SdT)**

Berechtigung SOLLTE Zugangsdaten auf Kompromittierung durch {einen automatisierten Mechanismus} überwachen.

BER.5.10 UUID vom 01.07.26 ist gleich BER.6.10 UUID vom 29.05.26; cos-sim = 1.0

BER.6.10 Monitoring von Zugangsdaten (normal-SdT) vom 29.05.26

Berechtigung SOLLTE Zugangsdaten auf Kompromittierung durch {einen automatisierten Mechanismus} überwachen.

✦ **BER.6.11 Integrität (normal-SdT)**

Berechtigung SOLLTE die Verifikation der Integrität geheimer Schlüssel vor jeder Nutzung verankern.

BER.6.11 UUID vom 01.07.26 ist gleich BER.7.11 UUID vom 29.05.26; cos-sim = 1.0

BER.7.11 Integrität (normal-SdT) vom 29.05.26

Berechtigung SOLLTE die Verifikation der Integrität geheimer Schlüssel vor jeder Nutzung verankern.

✦ **BER.6.12 Authentizität (normal-SdT)**

Berechtigung SOLLTE die Verifikation der Authentizität öffentlicher Schlüssel vor jeder Nutzung verankern.

BER.6.12 UUID vom 01.07.26 ist gleich BER.7.12 UUID vom 29.05.26; cos-sim = 1.0

BER.7.12 Authentizität (normal-SdT) vom 29.05.26

Berechtigung SOLLTE die Verifikation der Authentizität öffentlicher Schlüssel vor jeder Nutzung verankern.

✦ **BER.6.13 Gültigkeit (normal-SdT)**

Berechtigung SOLLTE die Verifikation der Gültigkeit des Schlüssels vor jeder Nutzung verankern.

BER.6.13 UUID vom 01.07.26 ist gleich BER.7.13 UUID vom 29.05.26; cos-sim = 1.0

BER.7.13 Gültigkeit (normal-SdT) vom 29.05.26

Berechtigung SOLLTE die Verifikation der Gültigkeit des Schlüssels vor jeder Nutzung verankern.

✦ **BER.6.14 Schlüssel vor Ablauf prüfen (normal-SdT)**

Berechtigung SOLLTE Schlüssel auf das baldige Auslaufen der Nutzungszeit {regelmäßig} überprüfen.

BER.6.14 UUID vom 01.07.26 ist gleich BER.7.14 UUID vom 29.05.26; cos-sim = 1.0

BER.7.14 Schlüssel vor Ablauf prüfen (normal-SdT) vom 29.05.26

Berechtigung SOLLTE Schlüssel auf das baldige Auslaufen der Nutzungszeit {regelmäßig} überprüfen.

✦ **BER.6.15 Vorgehensweise nach Nutzung (normal-SdT)**

Berechtigung SOLLTE eine Vorgehensweise zur Außerbetriebnahme geheimer Schlüssel , sobald sie nicht mehr benötigt werden, verankern.

BER.6.15 UUID vom 01.07.26 ist gleich BER.7.15 UUID vom 29.05.26; cos-sim = 1.0

BER.7.15 Vorgehensweise nach Nutzung (normal-SdT) vom 29.05.26

Berechtigung SOLLTE eine Vorgehensweise zur Außerbetriebnahme geheimer Schlüssel , sobald sie nicht mehr benötigt werden, verankern.

✦ **BER.6.16 Vorgaben für die Schlüsselbeglaubigung (normal-SdT)**

Berechtigung SOLLTE Vorgaben für die Schlüsselbeglaubigung verankern.

BER.6.16 UUID vom 01.07.26 ist gleich BER.7.16 UUID vom 29.05.26; cos-sim = 1.0

BER.7.16 Vorgaben für die Schlüsselbeglaubigung (normal-SdT) vom 29.05.26

Berechtigung SOLLTE Vorgaben für die Schlüsselbeglaubigung verankern.

✦ **BER.6.16.1 Zertifizierungsstelle (normal-SdT)**

Berechtigung SOLLTE die Beglaubigung von Schlüsseln {einer zuständigen Person oder Rolle} zuweisen.

BER.6.16.1 UUID vom 01.07.26 ist gleich BER.7.16.1 UUID vom 29.05.26; cos-sim = 1.0

BER.7.16.1 Zertifizierungsstelle (normal-SdT) vom 29.05.26

Berechtigung SOLLTE die Beglaubigung von Schlüsseln {einer zuständigen Person oder Rolle} zuweisen.

✦ **BER.6.16.2 Beglaubigung (normal-SdT)**

Berechtigung SOLLTE den Schlüssel anhand der Vorgaben für die Schlüsselbeglaubigung bei Beantragung einer Beglaubigung testen.

BER.6.16.2 UUID vom 01.07.26 ist gleich BER.7.16.2 UUID vom 29.05.26; cos-sim = 1.0

BER.7.16.2 Beglaubigung (normal-SdT) vom 29.05.26

Berechtigung SOLLTE den Schlüssel anhand der Vorgaben für die Schlüsselbeglaubigung bei Beantragung einer Beglaubigung testen.

✦ **BER.6.16.3 Erneuerung (normal-SdT)**

Berechtigung SOLLTE den Schlüssel anhand der Vorgaben für die Schlüsselbeglaubigung bei Erneuerung einer Beglaubigung testen.

BER.6.16.3 UUID vom 01.07.26 ist gleich BER.7.16.3 UUID vom 29.05.26; cos-sim = 1.0

BER.7.16.3 Erneuerung (normal-SdT) vom 29.05.26

Berechtigung SOLLTE den Schlüssel anhand der Vorgaben für die Schlüsselbeglaubigung bei Erneuerung einer Beglaubigung testen.

✦ **BER.6.16.4 Revocation (normal-SdT)**

Berechtigung SOLLTE den Schlüssel anhand der Vorgaben für die Schlüsselbeglaubigung bei Revocation einer Beglaubigung testen.

BER.6.16.4 UUID vom 01.07.26 ist gleich BER.7.16.4 UUID vom 29.05.26; cos-sim = 1.0

BER.7.16.4 Revocation (normal-SdT) vom 29.05.26

Berechtigung SOLLTE den Schlüssel anhand der Vorgaben für die Schlüsselbeglaubigung bei Revocation einer Beglaubigung testen.

✦ **BER.6.16.5 Beglaubigungsstatus (normal-SdT)**

Berechtigung SOLLTE den Beglaubigungsstatus des Schlüssels im Verzeichnis öffentlicher Schlüssel dokumentieren.

BER.6.16.5 UUID vom 01.07.26 ist gleich BER.7.16.5 UUID vom 29.05.26; cos-sim = 1.0

BER.7.16.5 Beglaubigungsstatus (normal-SdT) vom 29.05.26

Berechtigung SOLLTE den Beglaubigungsstatus des Schlüssels im Verzeichnis öffentlicher Schlüssel dokumentieren.

✦ **BER.6.16.6 Revocationstatus (normal-SdT)**

Berechtigung SOLLTE den Revocationstatus des Schlüssels im Verzeichnis öffentlicher Schlüssel dokumentieren.

BER.6.16.6 UUID vom 01.07.26 ist gleich BER.7.16.6 UUID vom 29.05.26; cos-sim = 1.0

BER.7.16.6 Revocationstatus (normal-SdT) vom 29.05.26

Berechtigung SOLLTE den Revocationstatus des Schlüssels im Verzeichnis öffentlicher Schlüssel dokumentieren.

✦ GC.1.2 Freigabe des ISMS (normal-SdT)

Governance und Compliance MUSS alle festgelegten Verfahren für das ISMS durch die Institutionsleitung autorisieren.

GC.1.2 UUID vom 01.07.26 ist gleich GC.10.2 UUID vom 29.05.26; cos-sim = 0.88

GC.10.2 Freigabe von Vorgehensweisen (normal-SdT) vom 29.05.26

Governance und Compliance MUSS die Verfahren für das ISMS durch die Institutionsleitung autorisieren.

✦ GC.3.1.1 Gesetzliche Verpflichtungen (normal-SdT)

Governance und Compliance MUSS gesetzliche Verpflichtungen, welche die Verarbeitung von Informationen durch die Institution betreffen, analysieren.

GC.3.1.1 UUID vom 01.07.26 ist gleich GC.7.1.1 UUID vom 29.05.26; cos-sim = 0.8

GC.7.1.1 Gesetzliche Verpflichtungen (normal-SdT) vom 29.05.26

Governance und Compliance SOLLTE die Analyse der gesetzlichen Verpflichtungen, welche die Verarbeitung von Informationen durch die Institution betreffen, ausführen.

✦ GC.3.1.2 Anhörung zuständiger Stellen (normal-SdT)

Governance und Compliance SOLLTE für die Einhaltung gesetzlicher Verpflichtungen in der Informationsverarbeitung zuständige Stellen in der Institution anhören.

GC.3.1.2 UUID vom 01.07.26 ist gleich GC.7.1.2 UUID vom 29.05.26; cos-sim = 1.0

GC.7.1.2 Anhörung zuständiger Stellen (normal-SdT) vom 29.05.26

Governance und Compliance SOLLTE für die Einhaltung gesetzlicher Verpflichtungen in der Informationsverarbeitung zuständige Stellen in der Institution anhören.

✦ GC.3.1.3 Vertragliche Verpflichtungen (normal-SdT)

Governance und Compliance SOLLTE vertragliche Verpflichtungen, welche die Verarbeitung von Informationen durch die Institution betreffen, analysieren.

GC.3.1.3 UUID vom 01.07.26 ist gleich GC.7.1.3 UUID vom 29.05.26; cos-sim = 0.8

GC.7.1.3 Vertragliche Verpflichtungen (normal-SdT) vom 29.05.26

Governance und Compliance SOLLTE die Zusammenstellung vertraglicher Verpflichtungen, welche die Verarbeitung von Informationen durch die Institution betreffen, dokumentieren.

✦ GC.3.1.4 Prävention von Verstößen (normal-SdT)

Governance und Compliance SOLLTE Verfahren zur Prävention gegen Verstöße verankern.

GC.3.1.4 UUID vom 01.07.26 ist gleich GC.7.1.4 UUID vom 29.05.26; cos-sim = 1.0

GC.7.1.4 Prävention von Verstößen (normal-SdT) vom 29.05.26

Governance und Compliance SOLLTE Verfahren zur Prävention gegen Verstöße verankern.

✦ GC.4.2 Analyse der internen interessierten Parteien (normal-SdT)

Governance und Compliance MUSS alle internen interessierten Parteien sowie ihre Bedürfnisse und Erwartungen an das Informationssicherheitsmanagement der Institution analysieren.

GC.4.2 UUID vom 01.07.26 ist gleich GC.3.2 UUID vom 29.05.26; cos-sim = 0.8

GC.3.2 Analyse der internen interessierten Parteien (normal-SdT) vom 29.05.26

Governance und Compliance MUSS ein Verfahren zum Ermitteln aller internen interessierten Parteien und ihrer Bedürfnisse und Erwartungen an das Informationssicherheitsmanagement der Institution verankern.

✦ GC.5.1.4 Freigabe der Sicherheitsleitlinie (normal-SdT)

Governance und Compliance MUSS die festgelegte Sicherheitsleitlinie durch die Institutionsleitung autorisieren.

GC.5.1.4 UUID vom 01.07.26 ist gleich GC.6.1.4 UUID vom 29.05.26; cos-sim = 1.0

GC.6.1.4 Freigabe der Sicherheitsleitlinie (normal-SdT) vom 29.05.26

Governance und Compliance MUSS die festgelegte Sicherheitsleitlinie durch die Institutionsleitung autorisieren.

✦ GC.7.2 Geschäftsprozesse mit hohem Schutzbedarf (normal-SdT)

Governance und Compliance MUSS eine dedizierte Risikobetrachtung von Geschäftsprozessen oder Informationen mit hohem Schutzbedarf entsprechend der gewählten Methodik für das Informationssicherheitsrisikomanagement ausführen.

GC.7.2 UUID vom 01.07.26 ist gleich GC.5.1.3 UUID vom 29.05.26; cos-sim = 0.76

GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf (normal-SdT) vom 29.05.26

Governance und Compliance MUSS eine dedizierte Risikobetrachtung von Geschäftsprozessen oder Informationsarten mit hohem Schutzbedarf ausführen.

✦ GC.9.1.1.1 Informationssicherheitsbeauftragter (normal-SdT)

Governance und Compliance MUSS die Zuständigkeit für Informationssicherheit {einer unabhängigen Person} , welche unmittelbar der Institutionsleitung unterstellt ist, zuweisen.

GC.9.1.1.1 UUID vom 01.07.26 ist gleich GC.8.1.1.1 UUID vom 29.05.26; cos-sim = 0.83

GC.8.1.1.1 Informationssicherheitsbeauftragter (normal-SdT) vom 29.05.26

Governance und Compliance MUSS die Rolle des Informationssicherheitsbeauftragten {einer unabhängigen Person} , welche unmittelbar der Institutionsleitung unterstellt ist, zuweisen.

✦ GC.9.1.1.1.1 Ressourcen für den Informationssicherheitsbeauftragten (normal-SdT)

Governance und Compliance MUSS dem Informationssicherheitsbeauftragten hinreichende Ressourcen zuweisen.

GC.9.1.1.1.1 UUID vom 01.07.26 ist gleich GC.8.1.6 UUID vom 29.05.26; cos-sim = 1.0

*GC.8.1.6 Ressourcen für den Informationssicherheitsbeauftragten (normal-SdT) vom 29.05.26
Governance und Compliance MUSS dem Informationssicherheitsbeauftragten {hinreichende} Ressourcen zuweisen.*

🌟 **GC.9.1.1.1.2 Vorspracherecht (normal-SdT)**

Governance und Compliance MUSS das direkte Vorspracherecht des Informationssicherheitsbeauftragten bei der Institutionsleitung verankern.

GC.9.1.1.1.2 UUID vom 01.07.26 ist gleich GC.8.1.1.1.1 UUID vom 29.05.26; cos-sim = 0.94

*GC.8.1.1.1.1 Vorspracherecht des Informationssicherheitsbeauftragten (normal-SdT) vom 29.05.26
Governance und Compliance MUSS das direkte Vorspracherecht des ISB bei der Institutionsleitung verankern.*

🌟 **GC.9.1.1.2 Stellvertreterregelungen (normal-SdT)**

Governance und Compliance MUSS Stellvertreterregelungen für alle relevanten Rollen und Zuständigkeiten im ISMS zuweisen.

GC.9.1.1.2 UUID vom 01.07.26 ist gleich GC.8.1.2 UUID vom 29.05.26; cos-sim = 1.0

*GC.8.1.2 Stellvertreterregelungen (normal-SdT) vom 29.05.26
Governance und Compliance MUSS Stellvertreterregelungen für alle relevanten Rollen und Zuständigkeiten im ISMS zuweisen.*

🌟 **GC.9.1.1.3 Vermeidung von Interessenkonflikten (normal-SdT)**

Governance und Compliance MUSS Maßnahmen zur Vermeidung von Interessenkonflikten bei der Festlegung von Rollen und Zuständigkeiten des ISMS festlegen.

GC.9.1.1.3 UUID vom 01.07.26 ist gleich GC.8.1.3 UUID vom 29.05.26; cos-sim = 1.0

*GC.8.1.3 Vermeidung von Interessenkonflikten (normal-SdT) vom 29.05.26
Governance und Compliance MUSS Maßnahmen zur Vermeidung von Interessenkonflikten bei der Festlegung von Rollen und Zuständigkeiten des ISMS festlegen.*

🌟 **GC.9.1.1.4 Sicherstellung der Qualifikation (normal-SdT)**

Governance und Compliance MUSS für jeden Rollen- und Verantwortungsträger die erforderlichen Anforderungen und Fähigkeiten festlegen.

GC.9.1.1.4 UUID vom 01.07.26 ist gleich GC.8.1.5 UUID vom 29.05.26; cos-sim = 1.0

*GC.8.1.5 Sicherstellung der Qualifikation (normal-SdT) vom 29.05.26
Governance und Compliance MUSS für jeden Rollen- und Verantwortungsträger die erforderlichen Anforderungen und Fähigkeiten festlegen.*

🌟 **GC.10.1.1 Externer Austausch zur Informationssicherheit (normal-SdT)**

Governance und Compliance SOLLTE einen externen Austausch zur Informationssicherheit verankern.

GC.10.1.1 UUID vom 01.07.26 ist gleich GC.9.1.1 UUID vom 29.05.26; cos-sim = 0.86

GC.9.1.1 Externer Austausch zur Informationssicherheit (normal-SdT) vom 29.05.26

Governance und Compliance SOLLTE einen externen Austausch zur Informationssicherheit ausführen.

✦ **GC.10.1.2 Kommunikation im Projektmanagement (normal-SdT)**

Governance und Compliance MUSS bei sicherheitsrelevanten Projekten die Beteiligung {der relevanten Sicherheitsorgane} zu festgelegten Zeitpunkten im Projektverlauf verankern.

GC.10.1.2 UUID vom 01.07.26 ist gleich GC.9.1.2 UUID vom 29.05.26; cos-sim = 1.0

GC.9.1.2 Kommunikation im Projektmanagement (normal-SdT) vom 29.05.26

Governance und Compliance MUSS bei sicherheitsrelevanten Projekten die Beteiligung {der relevanten Sicherheitsorgane} zu festgelegten Zeitpunkten im Projektverlauf verankern.

✦ **GC.12.1 Methodik für das Risikomanagement (normal-SdT)**

Governance und Compliance MUSS eine einheitliche Methodik für das Informationssicherheitsrisikomanagement unter Berücksichtigungen von Kontext, Geschäftsprozessanalyse und interessierten Parteien verankern.

GC.12.1 UUID vom 01.07.26 ist gleich GC.11.1 UUID vom 29.05.26; cos-sim = 0.56

GC.11.1 Methodik für das Risikomanagement (normal-SdT) vom 29.05.26

Governance und Compliance MUSS eine einheitliche Methodik für das Informationssicherheitsrisikomanagement auf Basis des Kontextes der Institution und der Anforderungen interessierter Parteien sowie der daraus hergeleiteten Risikoziele verankern.

✦ **KONF.11.7.1 Einschränkung von Zonentransfers (normal-SdT)**

Konfiguration für DNS-Server SOLLTE Zonentransfers einschränken.

KONF.11.7.1 UUID vom 01.07.26 ist gleich KONF.11.8.1 UUID vom 29.05.26; cos-sim = 1.0

KONF.11.8.1 Einschränkung von Zonentransfers (normal-SdT) vom 29.05.26

Konfiguration für DNS-Server SOLLTE Zonentransfers einschränken.

✦ **KONF.11.7.2 Einschränkung von TK-Verbindungen (normal-SdT)**

Konfiguration für TK-Anwendungen SOLLTE unerwünschte TK-Verbindungen einschränken.

KONF.11.7.2 UUID vom 01.07.26 ist gleich KONF.11.8.2 UUID vom 29.05.26; cos-sim = 1.0

KONF.11.8.2 Einschränkung von TK-Verbindungen (normal-SdT) vom 29.05.26

Konfiguration für TK-Anwendungen SOLLTE unerwünschte TK-Verbindungen einschränken.

✦ **KONF.11.7.2.1 Einschränkung der TK-Gegenstellen (normal-SdT)**

Konfiguration für TK-Anwendungen SOLLTE Verbindungen mit externen Gegenstellen einschränken.

KONF.11.7.2.1 UUID vom 01.07.26 ist gleich KONF.11.8.2.1 UUID vom 29.05.26; cos-sim = 1.0

KONF.11.8.2.1 Einschränkung der TK-Gegenstellen (normal-SdT) vom 29.05.26

Konfiguration für TK-Anwendungen SOLLTE Verbindungen mit externen Gegenstellen einschränken.

✦ **PERF.1.2 Evaluation des Umsetzungsplans (normal-SdT)**

Monitoring-Evaluation MUSS die {regelmäßige} Überprüfung und Fortschreibung des Umsetzungsplans in Bezug auf Fortschritt, Fristeinhaltung und inhaltlicher Korrektheit verankern.

PERF.1.2 UUID vom 01.07.26 ist gleich PERF.1.1.2 UUID vom 29.05.26; cos-sim = 0.42

PERF.1.1.2 Auswertung des Umsetzungsplans (normal-SdT) vom 29.05.26

Monitoring-Evaluation SOLLTE den Umsetzungsplan in Bezug auf den Fortschritt, die Einhaltung von Fristen und der inhaltlichen Korrektheit {regelmäßig} überprüfen.

✦ **PERF.1.3 Aktualität der Anforderungen (normal-SdT)**

Monitoring-Evaluation MUSS die Aktualität der Anforderungen {regelmäßig} überprüfen.

PERF.1.3 UUID vom 01.07.26 ist gleich PERF.7.1 UUID vom 29.05.26; cos-sim = 1.0

PERF.7.1 Aktualität der Anforderungen (normal-SdT) vom 29.05.26

Monitoring-Evaluation MUSS die Aktualität der Anforderungen {regelmäßig}überprüfen.

✦ **PERF.3.2 Dokumentation von Auditergebnissen (normal-SdT)**

Monitoring-Evaluation MUSS ein Verfahren zur Erstellung aussagekräftiger Auditberichte verankern.

PERF.3.2 UUID vom 01.07.26 ist gleich PERF.4.1 UUID vom 29.05.26; cos-sim = 1.0

PERF.4.1 Dokumentation von Auditergebnissen (normal-SdT) vom 29.05.26

Monitoring-Evaluation MUSS ein Verfahren zur Erstellung aussagekräftiger Auditberichte verankern.

✦ **PERF.3.2.1 Einheitliches Bewertungsschema (normal-SdT)**

Monitoring-Evaluation SOLLTE für Feststellungen in Audits ein einheitliches Bewertungsschema festlegen.

PERF.3.2.1 UUID vom 01.07.26 ist gleich PERF.4.1.1 UUID vom 29.05.26; cos-sim = 1.0

PERF.4.1.1 Einheitliches Bewertungsschema (normal-SdT) vom 29.05.26

Monitoring-Evaluation SOLLTE für Feststellungen in Audits ein einheitliches Bewertungsschema festlegen.

✦ **PERF.3.2.2 Kommunikation an Stakeholder (normal-SdT)**

Monitoring-Evaluation MUSS alle relevanten Stakeholder über die Auditergebnisse informieren.

PERF.3.2.2 UUID vom 01.07.26 ist gleich PERF.4.1.2 UUID vom 29.05.26; cos-sim = 0.67

PERF.4.1.2 Kommunikation an Stakeholder (normal-SdT) vom 29.05.26

Monitoring-Evaluation MUSS eine angemessene Kommunikation an alle relevanten Stakeholder ausführen.

🌟 **PERF.4.1.3 Erfolge und Probleme (normal-SdT)**

Monitoring-Evaluation SOLLTE bisherige Erfolge und Probleme (z. B. Sicherheitsvorfälle) beim Informationssicherheitsprozess als Ergebnis der Überprüfung in einem Managementbericht dokumentieren.

PERF.4.1.3 UUID vom 01.07.26 ist gleich PERF.5.1.3 UUID vom 29.05.26; cos-sim = 0.82

PERF.5.1.3 Erfolge und Probleme (normal-SdT) vom 29.05.26

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der bisherige Erfolge und Probleme (z. B. Sicherheitsvorfälle) beim Informationssicherheitsprozess berücksichtigt, dokumentieren.

🌟 **PERF.4.1.4 Interne Überprüfungen und Audits (normal-SdT)**

Monitoring-Evaluation SOLLTE Auditberichte als Ergebnis der Überprüfung in einem Managementbericht dokumentieren.

PERF.4.1.4 UUID vom 01.07.26 ist gleich PERF.5.1.4 UUID vom 29.05.26; cos-sim = 0.67

PERF.5.1.4 Interne Überprüfungen und Audits (normal-SdT) vom 29.05.26

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der Ergebnisse interner Überprüfungen und Audits enthält, dokumentieren.

🌟 **PERF.4.1.5 Eignungsprüfung bisheriger Sicherheitsmaßnahmen (normal-SdT)**

Monitoring-Evaluation SOLLTE eine Evaluation der Eignung umgesetzter Sicherheitsmaßnahmen zur Erreichung der Sicherheitsziele oder ob Maßnahmen geändert oder ergänzt werden müssen als Ergebnis der Überprüfung in einem Managementbericht dokumentieren.

PERF.4.1.5 UUID vom 01.07.26 ist gleich PERF.5.1.5 UUID vom 29.05.26; cos-sim = 0.69

PERF.5.1.5 Eignungsprüfung bisheriger Sicherheitsmaßnahmen (normal-SdT) vom 29.05.26

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der eine Bewertung enthält, ob sich die Sicherheitsmaßnahmen zur Erreichung der Sicherheitsziele als geeignet erwiesen haben oder ob Maßnahmen geändert oder ergänzt werden müssen, dokumentieren.

🌟 **PERF.4.1.6 Rückmeldung von Stakeholdern (normal-SdT)**

Monitoring-Evaluation SOLLTE die Bewertung von Rückmeldungen von Kunden, Geschäftspartnern, Mitarbeitern oder der Öffentlichkeit zu Sicherheitsaspekten als Ergebnis der Überprüfung in einem Managementbericht dokumentieren.

PERF.4.1.6 UUID vom 01.07.26 ist gleich PERF.5.1.6 UUID vom 29.05.26; cos-sim = 0.83

PERF.5.1.6 Rückmeldung von Stakeholdern (normal-SdT) vom 29.05.26

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der Rückmeldungen von Kunden, Geschäftspartnern, Mitarbeitern oder der Öffentlichkeit zu Sicherheitsaspekten bei der Bewertung berücksichtigt, dokumentieren.

🌟 **PERF.4.1.7 Status des Realisierungsplans (normal-SdT)**

Monitoring-Evaluation SOLLTE die erfolgreiche Umsetzung von Maßnahmen und des damit verringerten Risikos (Status des Umsetzungsplans) als Ergebnis der Überprüfung in einem Managementbericht dokumentieren.

PERF.4.1.7 UUID vom 01.07.26 ist gleich PERF.5.1.7 UUID vom 29.05.26; cos-sim = 0.38

PERF.5.1.7 Status des Realisierungsplans (normal-SdT) vom 29.05.26

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der Berichte über die Reduzierung bestehender Umsetzungsdefizite und der damit verbundenen Risiken (Status des Realisierungsplans) dokumentieren.

🌟 **PERF.4.1.8 Verbesserungen (normal-SdT)**

Monitoring-Evaluation SOLLTE die aufgrund der Überprüfung abgeleitete Verbesserungen des ISMS als Ergebnis der Überprüfung in einem Managementbericht dokumentieren.

PERF.4.1.8 UUID vom 01.07.26 ist gleich PERF.5.1.8 UUID vom 29.05.26; cos-sim = 0.5

PERF.5.1.8 Verbesserungen (normal-SdT) vom 29.05.26

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der die Ergebnisse der Bewertung in Form von Verbesserungen in das ISMS einfließen lässt, dokumentieren.

🌟 **PERF.4.1.9 Maßnahmenvorschläge (normal-SdT)**

Monitoring-Evaluation MUSS priorisierte Maßnahmenvorschläge mit realistischen Abschätzungen zum erwarteten Umsetzungsaufwand als Ergebnis der Überprüfung in einem Managementbericht dokumentieren.

PERF.4.1.9 UUID vom 01.07.26 ist gleich PERF.5.1.9 UUID vom 29.05.26; cos-sim = 0.78

PERF.5.1.9 Maßnahmenvorschläge (normal-SdT) vom 29.05.26

Monitoring-Evaluation MUSS die Ergebnisse dieser Überprüfungen in einem Managementbericht, der priorisierte Maßnahmenvorschläge mit realistischen Abschätzungen zum erwarteten Umsetzungsaufwand enthält, dokumentieren.

🌟 **PERF.4.2 Bericht an die Institutionsleitung (normal-SdT)**

Monitoring-Evaluation MUSS die Institutionsleitung über den Stand des Managementsystems {regelmäßig} anhand des Managementberichtes informieren.

PERF.4.2 UUID vom 01.07.26 ist gleich PERF.5.2 UUID vom 29.05.26; cos-sim = 1.0

PERF.5.2 Bericht an die Institutionsleitung (normal-SdT) vom 29.05.26

Monitoring-Evaluation MUSS die Institutionsleitung über den Stand des Managementsystems {regelmäßig} anhand des Managementberichtes informieren.

🌟 **STM.2.1.1 ISMS-Anforderungen (normal-SdT)**

Strukturmodellierung MUSS alle Anforderungen der ISMS-Praktiken auf den vorliegenden Informationsverbund modellieren.

STM.2.1.1 UUID vom 01.07.26 ist gleich STM.3.1 UUID vom 29.05.26; cos-sim = 0.76

STM.3.1 ISMS-Anforderungen des Informationsverbundes (normal-SdT) vom 29.05.26
Strukturmodellierung MUSS alle Anforderungen der ISMS-Praktiken modelliert auf den vorliegenden Informationsverbund platzieren.

🌟 **STM.2.1.2 Erfassung relevanter Assets (normal-SdT)**

Strukturmodellierung MUSS alle relevanten Assets für die betrachteten Geschäftsprozesse festlegen.

STM.2.1.2 UUID vom 01.07.26 ist gleich STM.4.1 UUID vom 29.05.26; cos-sim = 0.85

STM.4.1 Erfassung relevanter Assets (normal-SdT) vom 29.05.26
Strukturmodellierung MUSS alle relevanten Assets für die betrachteten Geschäftsprozesse modelliert auf den vorliegenden Informationsverbund festlegen.

🌟 **STM.2.1.3 Mapping der Assets auf Zielobjektkategorien (normal-SdT)**

Strukturmodellierung MUSS allen relevanten Assets eine oder mehrere Zielobjektkategorien zuweisen.

STM.2.1.3 UUID vom 01.07.26 ist gleich STM.4.3 UUID vom 29.05.26; cos-sim = 0.86

STM.4.3 Mapping des Assets auf die Zielobjektkategorien (normal-SdT) vom 29.05.26
Strukturmodellierung MUSS allen relevanten Assets passende Zielobjektkategorien zuweisen.

🌟 **STM.2.1.4 Modellierung der Anforderungen mit Zielobjektkategorie (normal-SdT)**

Strukturmodellierung MUSS die den Zielobjektkategorien zugehörigen Anforderungen auf die zugewiesenen Assets modellieren.

STM.2.1.4 UUID vom 01.07.26 ist gleich STM.5.1 UUID vom 29.05.26; cos-sim = 0.56

STM.5.1 Modellierung der Anforderungen mit Zielobjekt (normal-SdT) vom 29.05.26
Strukturmodellierung MUSS die Modellierung der Anforderung aus den Zielobjektkategorien auf die zugeordneten Assets ausführen.

🌟 **STM.2.1.4.1 Vererbung von Zielobjektkategorien (normal-SdT)**

Strukturmodellierung MUSS die in der Hierarchie übergeordneten Zielobjektkategorien ebenfalls dem jeweiligen Asset die in der Zielobjekthierarchie übergeordnet sind zuweisen.

STM.2.1.4.1 UUID vom 01.07.26 ist gleich STM.5.2 UUID vom 29.05.26; cos-sim = 0.45

STM.5.2 Vererbung von Zielobjektkategorien (normal-SdT) vom 29.05.26
Strukturmodellierung MUSS die Ergänzung der zuvor zugeordneten Zielobjektkategorien um diejenigen Kategorien die in der Zielobjekthierarchie übergeordnet sind ausführen.

🌟 **STM.2.1.4.2 Konsolidierung und Redundanzprüfung (normal-SdT)**

Strukturmodellierung MUSS eine Konsolidierung und Redundanzprüfung des Anforderungspakets ausführen.

STM.2.1.4.2 UUID vom 01.07.26 ist gleich STM.5.3 UUID vom 29.05.26; cos-sim = 1.0

STM.5.3 Konsolidierung und Redundanzprüfung (normal-SdT) vom 29.05.26

Strukturmodellierung MUSS eine Konsolidierung und Redundanzprüfung des Anforderungspakets ausführen.

✨ **STM.2.1.5 Modellierung der Anforderungen ohne Zielobjektkategorie (normal-SdT)**

Strukturmodellierung MUSS alle weiteren Anforderungen denen keine Zielobjektkategorie zugeordnet ist modellieren.

STM.2.1.5 UUID vom 01.07.26 ist gleich STM.5.4 UUID vom 29.05.26; cos-sim = 0.88

STM.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie (normal-SdT) vom 29.05.26

Strukturmodellierung MUSS die Modellierung aller weiteren Anforderungen denen kein Zielobjektkategorie zugeordnet ist ausführen.

✨ **STM.2.1.6 Aufgrund anforderungsloser Assets (normal-SdT)**

Strukturmodellierung MUSS für Assets, für die es noch keine passenden GS++-Anforderungen gibt, zusätzliche Anforderungen dem Anforderungspaket zuweisen.

STM.2.1.6 UUID vom 01.07.26 ist gleich STM.6.1 UUID vom 29.05.26; cos-sim = 0.57

STM.6.1 Auf Grund anforderungsloser Assets (normal-SdT) vom 29.05.26

Strukturmodellierung MUSS die Ergänzung des Anforderungspakets um Anforderungen für die es keine passenden Anforderungen gibt ausführen.

✨ **STM.2.1.7 Aufgrund externer Verpflichtungen (normal-SdT)**

Strukturmodellierung MUSS für das individuelle Compliance-Umfeld der Institution zusätzliche Anforderungen dem Anforderungspaket zuweisen.

STM.2.1.7 UUID vom 01.07.26 ist gleich STM.6.2 UUID vom 29.05.26; cos-sim = 0.5

STM.6.2 Auf Grund externer Verpflichtungen (normal-SdT) vom 29.05.26

Strukturmodellierung MUSS die Ergänzung des Anforderungspakets um Anforderungen für Assets die sich aus dem individuellen Compliance-Umfeld der Institution ergeben ausführen.

✨ **UMS.1.2 Bewertung des Restrisikos (normal-SdT)**

Umsetzung SOLLTE das bestehende Restrisiko durch die nicht umgesetzten Anforderungen festlegen.

UMS.1.2 UUID vom 01.07.26 ist gleich UMS.2.1 UUID vom 29.05.26; cos-sim = 1.0

UMS.2.1 Bewertung des Restrisikos (normal-SdT) vom 29.05.26

Umsetzung SOLLTE das bestehende Restrisiko durch die nicht umgesetzten Anforderungen festlegen.

✨ **UMS.2.2 Priorisierung von Maßnahmen (normal-SdT)**

Umsetzung MUSS eine Priorisierung der festgelegten Maßnahmen auf Basis der der Risikobewertung, Abhängigkeiten und Ressourcenverfügbarkeit festlegen.

UMS.2.2 UUID vom 01.07.26 ist gleich UMS.3.2 UUID vom 29.05.26; cos-sim = 1.0

UMS.3.2 Priorisierung von Maßnahmen (normal-SdT) vom 29.05.26

Umsetzung MUSS eine Priorisierung der festgelegten Maßnahmen auf Basis der der Risikobewertung, Abhängigkeiten und Ressourcenverfügbarkeit festlegen.

🌟 VRB.6.2 Bewertung der erreichten Verbesserung (normal-SdT)

Verbesserung SOLLTE ein Verfahren zur Bewertung der erreichten Verbesserung unter Berücksichtigung der damit verbundenen Vor- und Nachteile verankern.

VRB.6.2 UUID vom 01.07.26 ist gleich VRB.7.1 UUID vom 29.05.26; cos-sim = 0.88

VRB.7.1 Bewertung der erreichten Verbesserung (normal-SdT) vom 29.05.26

Verbesserung SOLLTE ein Verfahren zur Bewertung der erreichten Verbesserung unter Berücksichtigung der damit verbundenen Risiken verankern.

Veraenderte Anforderungsattribute

[Zurück zu Inhalt](#)

Anzahl geänderter Anforderungsattribute: 661

Anforderung	Geänderte Attribute
BER.3.10	Ergebnis, Parameter, Text
BER.3.15	Ergebnis, Hinweis, Text
BER.4.1	Aufwand, Dokumentation, Ergebnis, Handlungswort, Hinweis, Präzisierung, Tags, Text, Thema, Titel, UUID, Verbesserung
BER.5.1	Aufwand, Dokumentation, Ergebnis, Handlungswort, Hinweis, Tags, Text, Thema, Titel, UUID, Verbesserung, Zielobjekte
BER.5.2	Aufwand, Dokumentation, Ergebnis, Handlungswort, Hinweis, Präzisierung, Tags, Text, Thema, Titel, UUID
BER.5.3	Dokumentation, Ergebnis, Handlungswort, Hinweis, Parameter, Präzisierung, Text, Thema, Titel, UUID, Verbesserung
BER.5.4	Aufwand, Ergebnis, Handlungswort, Hinweis, Tags, Text, Thema, Titel, UUID, Zielobjekte
BER.5.5	Abhängigkeit, Aufwand, Dokumentation, Ergebnis, Handlungswort, Hinweis, Präzisierung, Tags, Text, Thema, Titel, UUID, Verwandte, Zielobjekte
BER.5.6	Aufwand, Dokumentation, Ergebnis, Handlungswort, Hinweis, Tags, Text, Thema, Titel, UUID, Zielobjekte
BER.5.7	Aufwand, Dokumentation, Ergebnis, Handlungswort, Hinweis, Modalverb, Sicherheitsniveau, Tags, Text, Thema, Titel, UUID, Zielobjekte
BER.5.8	Abhängigkeit, Ergebnis, Hinweis, Präzisierung, Tags, Text, Thema, Titel, UUID, Verwandte
BER.6.1	Ergebnis, Handlungswort, Hinweis, Parameter, Präzisierung, Tags, Text, Thema, Titel, UUID, Zielobjekte

Anforderung	Geänderte Attribute
BER.6.2	Aufwand, Dokumentation, Ergebnis, Handlungswort, Hinweis, Parameter, Präzisierung, Tags, Text, Thema, Titel, UUID
BER.6.3	Dokumentation, Ergebnis, Handlungswort, Hinweis, Präzisierung, Tags, Text, Thema, Titel, UUID
BER.6.4	Aufwand, Ergebnis, Handlungswort, Hinweis, Präzisierung, Tags, Text, Thema, Titel, UUID, Zielobjekte
BER.6.5	Abhängigkeit, Aufwand, Ergebnis, Handlungswort, Hinweis, Parameter, Präzisierung, Tags, Text, Thema, Titel, UUID, Verwandte
BER.6.6	Aufwand, Dokumentation, Ergebnis, Handlungswort, Hinweis, Präzisierung, Tags, Text, Thema, Titel, UUID, Zielobjekte
BER.6.7	Aufwand, Dokumentation, Ergebnis, Handlungswort, Hinweis, Modalverb, Parameter, Präzisierung, Sicherheitsniveau, Tags, Text, Thema, Titel, UUID, Zielobjekte
BER.6.8	Aufwand, Ergebnis, Hinweis, Präzisierung, Tags, Text, Thema, Titel, UUID
BER.6.9	Aufwand, Ergebnis, Handlungswort, Hinweis, Präzisierung, Tags, Text, Thema, Titel, UUID
BER.6.10	Aufwand, Dokumentation, Ergebnis, Handlungswort, Hinweis, Parameter, Präzisierung, Tags, Text, Thema, Titel, UUID
BES.2.1.2	Modalverb, Sicherheitsniveau, Text
BES.2.5	Titel
DET.4.11.2	Aufwand
DET.4.12	Aufwand
DET.4.12.1	Modalverb, Text
DET.5.6	Hinweis
DET.5.7	Hinweis, Parameter, Präzisierung
DET.6.1.1	Aufwand
DET.6.2.2	Aufwand, Hinweis
GC.1.1	Dokumentation
GC.2.1	Ergebnis, Handlungswort, Hinweis, Text, Thema
GC.2.2	Ergebnis, Handlungswort, Hinweis, Text, Thema
GC.3.1	Dokumentation, Ergebnis, Hinweis, Präzisierung, Tags, Text, Thema, Titel, UUID, Verbesserung, Verwandte
GC.4.1	Abhängigkeit, Ergebnis, Handlungswort, Hinweis, Präzisierung, Text, Thema, Titel, UUID, Verwandte

Anforderung	Geänderte Attribute
GC.5.1	Abhängigkeit, Dokumentation, Ergebnis, Handlungswort, Hinweis, Präzisierung, Text, Thema, Titel, UUID, Verbesserung
GC.5.1.1	Aufwand, Dokumentation, Ergebnis, Hinweis, Präzisierung, Text, Thema, Titel, UUID, Verwandte
GC.5.1.2	Abhängigkeit, Dokumentation, Ergebnis, Handlungswort, Hinweis, Präzisierung, Tags, Text, Thema, Titel, UUID
GC.5.1.3	Abhängigkeit, Dokumentation, Ergebnis, Handlungswort, Hinweis, Text, Thema, Titel, UUID
GC.6.1	Abhängigkeit, Dokumentation, Ergebnis, Hinweis, Präzisierung, Text, Thema, Titel, UUID, Verbesserung
GC.7.1	Dokumentation, Ergebnis, Hinweis, Präzisierung, Tags, Text, Thema, Titel, UUID, Verbesserung, Verwandte
GC.7.1.1	Aufwand, Dokumentation, Ergebnis, Handlungswort, Hinweis, Modalverb, Präzisierung, Tags, Text, Thema, Titel, UUID, Verwandte
GC.7.1.2	Abhängigkeit, Aufwand, Dokumentation, Ergebnis, Handlungswort, Hinweis, Modalverb, Präzisierung, Tags, Text, Thema, Titel, UUID
GC.8.1	Thema, Verbesserung, Verwandte
GC.9.1	Dokumentation, Ergebnis, Handlungswort, Hinweis, Präzisierung, Text, Thema, Titel, UUID, Verbesserung
GC.9.1.1	Aufwand, Dokumentation, Ergebnis, Handlungswort, Hinweis, Modalverb, Parameter, Präzisierung, Text, Thema, Titel, UUID, Verbesserung
GC.10.1	Dokumentation, Ergebnis, Handlungswort, Hinweis, Präzisierung, Text, Thema, Titel, UUID, Verbesserung, Verwandte
GC.11.1	Dokumentation, Ergebnis, Hinweis, Präzisierung, Text, Thema, Titel, UUID, Verwandte
GEB.3.3	Verwandte
KONF.11.3	Aufwand, Ergebnis, Handlungswort, Hinweis, Modalverb, Parameter, Präzisierung, Sicherheitsniveau, Tags, Text, Titel, UUID, Zielobjekte
KONF.11.4	Aufwand, Ergebnis, Handlungswort, Hinweis, Parameter, Präzisierung, Tags, Text, Titel, UUID, Zielobjekte
KONF.11.5	Aufwand, Ergebnis, Handlungswort, Hinweis, Parameter, Präzisierung, Tags, Text, Titel, UUID, Zielobjekte
KONF.11.6	Aufwand, Ergebnis, Handlungswort, Hinweis, Modalverb, Sicherheitsniveau, Text, Titel, UUID, Zielobjekte
KONF.11.7	Aufwand, Ergebnis, Handlungswort, Hinweis, Modalverb, Präzisierung, Sicherheitsniveau, Text, Titel, UUID, Verbesserung

Anforderung	Geänderte Attribute
KONF.11.8	Aufwand, Ergebnis, Handlungswort, Hinweis, Modalverb, Präzisierung, Sicherheitsniveau, Tags, Text, Titel, UUID, Verbesserung
KONF.12.1	Aufwand
KONF.13.2	Aufwand
KONF.13.2.1	Aufwand
KONF.13.2.2	Aufwand
PERF.1.1	Verbesserung
PERF.2.1	Hinweis, Thema, Verwandte
PERF.3.1	Thema
PERF.3.1.1	Thema
PERF.3.1.2	Thema
PERF.3.1.3	Thema
PERF.3.1.4	Thema
PERF.4.1	Dokumentation, Ergebnis, Handlungswort, Hinweis, Parameter, Präzisierung, Text, Thema, Titel, UUID, Verbesserung, Verwandte
PERF.4.1.1	Aufwand, Dokumentation, Ergebnis, Handlungswort, Hinweis, Präzisierung, Text, Thema, Titel, UUID, Verwandte
PERF.4.1.2	Aufwand, Dokumentation, Ergebnis, Handlungswort, Hinweis, Modalverb, Präzisierung, Text, Thema, Titel, UUID, Verwandte
PERF.5.1	Dokumentation, Ergebnis, Handlungswort, Hinweis, Parameter, Präzisierung, Text, Thema, Titel, UUID, Verbesserung
PERS.6.1.1	Verwandte
SENS.4.1	Abhängigkeit
SENS.4.1.3	Abhängigkeit
STM.1.1	Abhängigkeit, Hinweis, Thema
STM.1.2	Hinweis, Thema
STM.2.1	Dokumentation, Ergebnis, Handlungswort, Hinweis, Präzisierung, Text, Thema, Verbesserung
STM.3.1	Aufwand, Ergebnis, Handlungswort, Hinweis, Modalverb, Präzisierung, Text, Thema, Titel, UUID, Verwandte
STM.4.1	Ergebnis, Handlungswort, Hinweis, Präzisierung, Text, Thema, Titel, UUID, Verwandte

Anforderung	Geänderte Attribute
STM.5.1	Abhängigkeit, Ergebnis, Handlungswort, Hinweis, Präzisierung, Text, Thema, Titel, UUID, Verwandte
UMS.1.1	Ergebnis, Parameter, Präzisierung, Text, Thema
UMS.2.1	Aufwand, Dokumentation, Ergebnis, Hinweis, Modalverb, Präzisierung, Text, Thema, Titel, UUID
UMS.3.1	Ergebnis, Handlungswort, Hinweis, Präzisierung, Text, Thema, Titel, UUID, Verwandte
UMS.4.1	Ergebnis, Handlungswort, Hinweis, Präzisierung, Text, Thema, Titel, UUID, Verwandte
UMS.5.1	Hinweis, Parameter, Präzisierung, Text, Thema, Verwandte
UMS.5.2	Thema
UMS.6.1	Abhängigkeit, Thema
UMS.6.2	Abhängigkeit, Thema
UMS.7.1	Thema, Verwandte
VRB.1.1	Hinweis
VRB.2.1	Verwandte
VRB.2.2	Aufwand, Ergebnis, Hinweis, Modalverb, Parameter, Präzisierung, Text
VRB.3.1	Aufwand, Handlungswort, Hinweis, Modalverb, Präzisierung, Text, Thema
VRB.4.1	Hinweis
VRB.4.2	Hinweis, Präzisierung, Text
VRB.5.1	Verwandte
VRB.6.1	Ergebnis, Handlungswort, Hinweis, Text, Titel
VRB.7.1	Dokumentation, Ergebnis, Hinweis, Präzisierung, Text, Thema, Titel, UUID, Verwandte

BER.3.10 Anmeldeversuchsgrenze an der Anwendung (normal-SdT)

Attribut	29.05.26	01.07.26
Ergebnis	weitere Anmeldeversuche nach Erreichen von einem maximalen Schwellwert an fehlgeschlagenen Versuchen	weitere Anmeldeversuche nach Erreichen von {{einem maximalen Schwellwert an}} fehlgeschlagenen Versuchen
Parameter		{'ber.3.10-prm1': 'einem maximalen Schwellwert an'}
Text	Berechtigung für Anwendungen SOLLTE weitere Anmeldeversuche nach Erreichen von einem maximalen Schwellwert an	Berechtigung für Anwendungen SOLLTE weitere Anmeldeversuche nach Erreichen von {{ insert: param, ber.3.10-prm1 }}

Attribut	29.05.26	01.07.26
	fehlgeschlagenen Versuchen vorübergehend blockieren.	fehlgeschlagenen Versuchen vorübergehend blockieren.

BER.3.15 Keine Gruppenkonten (normal-SdT)

Attribut	29.05.26	01.07.26
Ergebnis	Gruppenkonten	Gruppenkonten im Regelbetrieb
Hinweis	Werden [- Zugangskonten von mehr als -] einer Person [- genutzt , so kann später nur noch schwer ermittelt -] werden, [- wer -] eine [- bestimmte Tätigkeit mit dem Konto ausgeführt hat . -]	[+ Ein Gruppenkonto (englisch shared account) bezeichnet hier ein Zugangskonto , das von mehreren natürlichen Personen gemeinsam genutzt wird und daher keiner einzelnen natürlichen Person eindeutig zugeordnet +] werden [+ kann . Vom Regelbetrieb erfasst ist die gewöhnliche , wiederkehrende Nutzung im Tagesgeschäft , nicht jedoch ein eng begrenzter Ausnahmefall mit gesonderter Begründung und Absicherung , sowie nachvollziehbarer Zuordnung der Nutzung zu +] einer [+ konkreten +] Person [+ . Der Ausschluss von Gruppenkonten hat das Ziel die Nachvollziehbarkeit von Zugriffen und Änderungen zu verbessern und eine eindeutige Verantwortlichkeit für die Nutzung von Berechtigungen sicherzustellen . Die Verwendung von Gruppenkonten im Regelbetrieb könnten hingegen die Aufklärung von Sicherheitsvorfällen erschweren , die missbräuchliche Nutzung von Zugriffsrechten begünstigen oder nach dem Ausscheiden einzelner Nutzer unbemerkte Zugriffsmöglichkeiten bestehen lassen . Für technisch unvermeidbare Sonderfälle können stattdessen speziell gekennzeichnete Funktions - oder Dienstkonten (service accounts) verwendet +] werden. [+ Im Unterschied zu Gruppenkonten sind Service Accounts nicht zur gemeinsamen interaktiven Nutzung durch mehrere Mitarbeiter gedacht . Sie können beispielsweise einen Datenbankdienst mit einer Anwendung verbinden , automatisierte Datensicherungen durchführen oder den Datenaustausch zwischen zwei Systemen ermöglichen . Um klar von Gruppenkonten abgegrenzt zu sein benötigt ein Dienstkonto +] eine [+ klar nachvollziehbare Zweckbindung , die Sperrung interaktiver Anmeldungen , sowie eine regelmäßige Erneuerung von Authentisierungsmerkmalen . +]
Text	Berechtigung SOLLTE Gruppenkonten untersagen.	Berechtigung SOLLTE Gruppenkonten im Regelbetrieb untersagen.

BER.4.1 Prinzip der geringsten Berechtigungen (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	3	1
Dokumentation	IT-Betriebskonzept	Inventar Berechtigungen
Ergebnis	eine Identitätsüberprüfung	die Vergabe von Berechtigungen nach dem Prinzip der geringsten Berechtigungen
Handlungswort	ausführen	einschränken
Hinweis	Das [- unberechtigte Zurücksetzen -] von [- Zugangsdaten ist -] eine [- bekannte Angriffsmethode . -] Eine [- eindeutige Identifizierung des Inhabers des Zugangs z . B . anhand eines Personalausweises oder OTP ist eine zwingende Voraussetzung bevor eine Zurücksetzung erfolgen kann . -]	Das [+ Prinzip der geringsten Berechtigungen , im Englischen als Principle of Least Privilege (PoLP) bekannt , besagt , dass Nutzende , Prozesse oder Systeme nur die minimal notwendigen Zugriffsrechte erhalten dürfen , um die ihnen jeweils zugewiesenen Aufgaben zu erfüllen . Dies dient primär der Minimierung der Angriffsfläche und der Begrenzung potenzieller Schäden . Sollte beispielsweise ein Zugangskonto durch Phishing kompromittiert werden , könnte ein Angreifer ohne dieses Prinzip weitreichenden Zugriff auf kritische Daten oder Systeme erlangen und diese manipulieren , exfiltrieren oder verschlüsseln . Die konsequente Anwendung dieses Grundsatzes kann die Ausbreitung [+] von [+] Schadsoftware nach einem ersten Eindringen erheblich erschweren und sicherstellen , dass Mitarbeitende nur jene Informationen einsehen , die für ihre Tätigkeit unmittelbar relevant sind . Hierdurch wird auch das Risiko von Datendiebstahl durch Innentäter reduziert . Es empfiehlt sich als Ergänzung hier auch das "Need to know " - Prinzip zu betrachten , da sich beide Prinzipien ergänzen . Während das "Least Privilege " - Prinzip auf Systemrechte , Rollen und Berechtigungen fokussiert , liegt der Fokus des "Need to know " - Prinzips mehr auf Informationen und Datenzugriff . Zur sinnvollen Umsetzung kann die Institution ein rollenbasiertes Berechtigungskonzept (Role - Based Access Control , RBAC) etablieren , bei dem Berechtigungen nicht an einzelne Personen , sondern an vordefinierte Rollen (z . B . "Finanzbuchhaltung " oder "Netzwerkadministrator ") gebunden werden . Für die Einführung in [+] eine [+] bestehende Umgebung kann ein gestuftes Vorgehen gewählt werden : (1) Zunächst wird ein Überwachungsmodus (" Audit - Only ") aktiviert , der protokolliert , welche Zugriffe durch [+] eine [+] strengere Richtlinie verweigert würden , ohne sie tatsächlich zu blockieren . (2) Anschließend werden diese Protokolle analysiert , um legitime , für den

Attribut	29.05.26	01.07.26
		Geschäftsbetrieb notwendige Zugriffe zu identifizieren und diese gezielt in die jeweiligen Rollen und Berechtigungsgruppen aufzunehmen . (3) Erst wenn keine legitimen Zugriffe mehr in den Protokollen als "verweigert " auftauchen , wird die Richtlinie scharf geschaltet und blockiert aktiv alle nicht explizit erlaubten Zugriffe . Alle relevanten Anforderungen zur Vergabe von Berechtigungen können mit den Handlungsworten "authentifizieren " , "autorisieren " und "einschränken " gefunden werden . +]
Präzisierung	vor dem Zurücksetzen von Passworten	
Tags	Password Policy	Security by Default, Privilegierte Rechte
Text	Berechtigung SOLLTE eine Identitätsüberprüfung vor dem Zurücksetzen von Passworten ausführen.	Berechtigung SOLLTE die Vergabe von Berechtigungen nach dem Prinzip der geringsten Berechtigungen einschränken.
Thema	BER.4 Authentifizierung	BER.4 Berechtigungsmanagement
Titel	Identitätsüberprüfung	Prinzip der geringsten Berechtigungen
UUID	fb946aab-b392-49b1-bb88-44902c331955 (gleich BER.3.25 UUID vom 01.07.26)	0e1f4190-44ad-48f0-9504-781aef585ba0 (gleich BER.5.1 UUID vom 29.05.26)
Verbesserung		BER.4.1.1, BER.4.1.2

BER.5.1 Passwortmanager (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	1	2
Dokumentation	Inventar Berechtigungen	IT-Betriebskonzept
Ergebnis	die Vergabe von Berechtigungen nach dem Prinzip der geringsten Berechtigungen	einen Passwortmanager
Handlungswort	einschränken	installieren
Hinweis	[- Das Prinzip -] der [- geringsten Berechtigungen -], [- im Englischen als Principle of Least Privilege -] ([- PoLP -]) [- bekannt , besagt , dass Nutzende , Prozesse oder Systeme nur die minimal notwendigen Zugriffsrechte	Der [+ Einsatz eines Passwortmanagers +], [+ der von der Institution den

Attribut	29.05.26	01.07.26
	erhalten dürfen , um die ihnen jeweils zugewiesenen Aufgaben zu erfüllen . Dies dient primär der Minimierung der Angriffsfläche -] und der [- Begrenzung potenzieller Schäden -]. [- Sollte beispielsweise ein Zugangskonto durch Phishing kompromittiert werden -], [- könnte ein Angreifer ohne dieses Prinzip weitreichenden Zugriff auf kritische Daten oder Systeme erlangen und diese manipulieren , exfiltrieren oder verschlüsseln . Die konsequente Anwendung dieses Grundsatzes kann die Ausbreitung von Schadsoftware nach einem ersten Eindringen erheblich erschweren und sicherstellen , dass Mitarbeitende nur jene Informationen einsehen , die für ihre Tätigkeit unmittelbar relevant sind . Hierdurch wird auch das Risiko von Datendiebstahl durch Innentäter reduziert . Es empfiehlt sich als Ergänzung hier auch das "Need to know " - Prinzip zu betrachten , da sich beide Prinzipien ergänzen . Während das "Least Privilege " - Prinzip auf Systemrechte , Rollen und Berechtigungen fokussiert , liegt der Fokus des "Need to know " - Prinzips mehr auf Informationen und Datenzugriff . Zur sinnvollen Umsetzung kann die Institution ein rollenbasiertes Berechtigungskonzept (Role - Based Access Control , RBAC) etablieren , bei dem Berechtigungen nicht an einzelne Personen , sondern an vordefinierte Rollen (z . B . "Finanzbuchhaltung " oder "Netzwerkadministrator ") gebunden werden . Für die Einführung in eine bestehende Umgebung kann ein gestuftes Vorgehen gewählt werden : (1) Zunächst wird ein Überwachungsmodus (" Audit - Only ") aktiviert , der protokolliert , welche Zugriffe durch eine strengere Richtlinie verweigert würden , ohne sie tatsächlich zu blockieren . (2) Anschließend werden diese Protokolle analysiert , um legitime , für den Geschäftsbetrieb notwendige Zugriffe zu identifizieren und diese gezielt in die jeweiligen Rollen und Berechtigungsgruppen aufzunehmen . (3) Erst wenn keine legitimen Zugriffe mehr in den Protokollen als "verweigert " auftauchen , wird die Richtlinie scharf geschaltet und blockiert aktiv alle nicht explizit erlaubten Zugriffe . Alle relevanten Anforderungen zur Vergabe von Berechtigungen können mit den Handlungsworten "authentifizieren " , "autorisieren " und "einschränken " gefunden werden . -]	Nutzenden zur Verfügung gestellt wird +], [+ erleichtert die Generierung von sicheren Passwörtern und deren sicherer Verwahrung +], [+ indem eine verschlüsselte Datenbank genutzt wird +] und der [+ Zugang zu dem Passwortmanager mit einem Masterpasswort oder Multi +]- [+ Faktor Authentisierung geschützt ist +].

Attribut	29.05.26	01.07.26
Tags	Security by Default, Privilegierte Rechte	Password Policy
Text	Berechtigung SOLLTE die Vergabe von Berechtigungen nach dem Prinzip der geringsten Berechtigungen einschränken.	Berechtigung für Nutzende SOLLTE einen Passwortmanager installieren.
Thema	BER.5 Berechtigungsmanagement	BER.5 Passwortgebrauch
Titel	Prinzip der geringsten Berechtigungen	Passwortmanager
UUID	0e1f4190-44ad-48f0-9504-781aef585ba0 (gleich BER.4.1 UUID vom 01.07.26)	c1cfa733-340c-497d-a3b6-8480d78e1278 (gleich BER.6.1 UUID vom 29.05.26)
Verbesserung	BER.5.1.1, BER.5.1.2	
Zielobjekte		Nutzende

BER.5.2 Vorkonfigurierte Authentisierungsmittel (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	3	1
Dokumentation	Inventar Berechtigungen	IT-Betriebskonzept
Ergebnis	die Vergabe von Berechtigungen und Änderungen an Berechtigungen	vorkonfigurierte Authentisierungsmittel
Handlungswort	dokumentieren	deaktivieren
Hinweis	[- Zweck ist die Nachvollziehbarkeit der Vergabe von Berechtigungen -]. [- Die Dokumentation kann z -]. [- B -]. [- mit einem Identity -] [- Access - Management -] oder [- Personalmanagementsystem automatisiert -] werden.	[+ Herstellerseitige Standardkonten und Default +]- [+ Passwörter stellen ein beliebtes Eingangstor für Angreifer dar +]. [+ Wenn vorhanden können auch andere Zugangsmittel wie Hardware +]- [+ Zugangstoken +], [+ Zertifikate +] oder [+ physische Zugangskontrollsysteme als Authentisierungsmittel verstanden +] werden.
Präzisierung	mit einer Begründung	
Tags		Advanced Persistent Threats (APT)
Text	Berechtigung SOLLTE die Vergabe von Berechtigungen und Änderungen an	Berechtigung SOLLTE vorkonfigurierte Authentisierungsmittel deaktivieren.

Attribut	29.05.26	01.07.26
	Berechtigungen mit einer Begründung dokumentieren.	
Thema	BER.5 Berechtigungsmanagement	BER.5 Passwortgebrauch
Titel	Begründung von Berechtigungen	Vorkonfigurierte Authentisierungsmittel
UUID	d1151b4b-8e26-48fe-a4fe-8c6f14d3bdce (gleicht BER.4.2 UUID vom 01.07.26)	7e0edf55-22d6-42d8-973f-d3f8635a0913 (gleicht BER.6.2 UUID vom 29.05.26)

BER.5.3 Deaktivierung einfacher Biometrie (normal-SdT)

Attribut	29.05.26	01.07.26
Dokumentation	Prüfplan	IT-Betriebskonzept
Ergebnis	vergebene Berechtigungen	die Authentifizierung nur anhand von Biometrie
Handlungswort	überprüfen	deaktivieren
Hinweis	[- Erforderlichkeit bedeutet in diesem Kontext , dass eine vergebene Berechtigung -] nur [- dann als gerechtfertigt gilt , wenn sie für die aktuelle Aufgabenwahrnehmung , Rolle oder Funktion einer Person tatsächlich benötigt -] wird [- . Dabei kann zwischen fachlicher Notwendigkeit -] (z. B. [- Zugriff auf eine bestimmte Anwendung -], um [- Kernaufgaben erfüllen -] zu [- können -]) [- und zeitlicher Relevanz -] (z. B. [- Projektzugriff -], [- der nur für die Dauer des Projekts sinnvoll ist -]) [- unterschieden werden -]. [- Als mögliche Werte für den Parameter regelmäßig bieten sich an : (1) quartalsweise , (2) halbjährlich , (3) jährlich – je nach Kritikalität der Systeme und Sensibilität der Daten -]. Die [- regelmäßige Überprüfung der Erforderlichkeit kann verhindern -], [- dass sich unbemerkt überhöhte Rechte -] ([- „ Privilege Creep “) ansammeln , die Angreifer im Falle einer Kompromittierung zusätzlichen Spielraum eröffnen könnten . Ohne solche Kontrollen könnte ein ehemaliger Projektmitarbeiter weiterhin Zugang zu sensiblen Daten haben oder ein interner Angreifer auf nicht benötigte Administrationsrechte stoßen . Umgekehrt kann die Überprüfung sicherstellen , dass Berechtigungen stets am aktuellen	[+ Wenn die Authentifizierung +] nur [+ biometrisch vorgenommen +] wird (z. B. [+ anhand von Fingerabdrücken oder Abbildern des Gesichtes) , dann könnten Angreifer Fälschungen oder gestohlene Fingerabdrücke missbrauchen +], um [+ sich Zugang +] zu [+ verschaffen +]. [+ Werden biometrische Verfahren dagegen mit weiteren Authentisierungsmittel +] (z. B. [+ einer PIN +]) [+ kombiniert +], [+ können sie den Zugriffsschutz verbessern +]. [+ Ein häufig vorkommendes Beispiel sind Mobilgeräte wie Smartphones +], die [+ durch Fingerabdruck den Zugriff auf Daten oder Funktionen wie das mobile Bezahlen gestatten +] - [+ obwohl auf dem Gerät selbst häufig noch Fingerabdrücke erkennbar sind +].

Attribut	29.05.26	01.07.26
	Aufgabenprofil ausgerichtet bleiben und so Schaden durch Missbrauch oder Fehlhandlungen eingedämmt werden kann . Zur Umsetzung kann eine Institution rollenbasierte Zugriffskonzepte einsetzen , die regelmäßig mit den Ist - Berechtigungen der Nutzer abgeglichen werden („ Access Reviews “) . Dies kann durch automatisierte Reports aus Verzeichnisdiensten , Datenbanken oder Fachanwendungen erfolgen , die Verantwortlichen zur Bestätigung oder Korrektur vorgelegt werden . Hilfreich kann auch ein Vier - Augen - Prinzip sein , bei dem Vorgesetzte die Notwendigkeit von Berechtigungen bestätigen . Darüber hinaus kann es nützlich sein , temporäre Projekt - oder Sonderrechte mit Ablaufdatum zu vergeben , sodass diese automatisch entzogen werden , wenn sie nicht mehr bestätigt werden . -]	
Parameter	{ 'ber.5.3-prm1': 'regelmäßig' }	
Präzisierung	{{regelmäßig}} auf Erforderlichkeit	
Text	Berechtigung SOLLTE vergebene Berechtigungen {{ insert: param, ber.5.3-prm1 }} auf Erforderlichkeit überprüfen.	Berechtigung SOLLTE die Authentifizierung nur anhand von Biometrie deaktivieren.
Thema	BER.5 Berechtigungsmanagement	BER.5 Passwortgebrauch
Titel	Überprüfung von Berechtigungen	Deaktivierung einfacher Biometrie
UUID	4123f246-95b2-4785-9714-17a5e68462c5 (gleicht BER.4.3 UUID vom 01.07.26)	4483f020-da27-44af-ae23-edf7d676d72f (gleicht BER.6.3 UUID vom 29.05.26)
Verbesserung	BER.5.3.1	

BER.5.4 Mehr-Faktor-Authentisierung am Perimeter (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	1	3
Ergebnis	kompromittierte Berechtigungsmittel	Phishing-resistente Mehr-Faktor-Authentisierung

Attribut	29.05.26	01.07.26
Handlungswort	deaktivieren	aktivieren
Hinweis	[- Ein Berechtigungsmittel gilt als kompromittiert -], [- wenn Anzeichen bestehen -], dass [- Unbefugte es nutzen -] oder [- Zugriff darauf gehabt haben könnten . Beispiele sind Passwörter , die -] durch [- Datenlecks öffentlich geworden sind , oder biometrische Merkmale (z . B . Fingerabdrücke) , die Unbefugten vorliegen . In solchen Fällen ist das Berechtigungsmittel zu sperren oder zu entziehen , etwa durch den Einsatz von Sperrlisten . Bei biometrischen Merkmalen besteht zusätzlich ein enger Bezug zu datenschutzrechtlichen Anforderungen , da diese Daten nicht einfach ausgetauscht -] werden können.	[+ Phishing +]- [+ resistente Mehr - Faktor - Authentisierung bezeichnet Verfahren zur Anmeldung , bei denen mindestens zwei unterschiedliche Faktoren genutzt werden und bei denen die Authentisierung zusätzlich gegen typische Angriffe wie Credential Phishing , Adversary - in - the - Middle - Angriffe oder die Wiederverwendung abgefangener Sitzungsdaten abgesichert ist . Phishing - resistente Verfahren basieren typischerweise auf kryptographischen Nachweisen zwischen Endgerät und Zielsystem und verhindern dadurch +], dass [+ einmal abgefragte Zugangsdaten +] oder [+ Einmalcodes +] durch [+ täuschend echte Anmeldeseiten weiterverwendet +] werden können, [+ beispielsweise FIDO2 Paskeys . Hintergrund ist , dass aus externen Netzen wie dem Internet erreichbare Anwendungen (insbesondere die VPN - Einwahl oder Cloud - Anwendungen) ein beliebtes Ziel für Angreifer sind . Klassische Passwörter oder einfache Einmalcodes könnten durch Social Engineering , gefälschte Login - Portale oder Man - in - the - Browser - Angriffe ausgespäht werden . +]
Tags		MFA, Credential Stuffing, Brute-Force-Attacke
Text	Berechtigung SOLLTE kompromittierte Berechtigungsmittel deaktivieren.	Berechtigung für Anwendungen von Externe Netzanschlüssen SOLLTE Phishing-resistente Mehr-Faktor-Authentisierung aktivieren.
Thema	BER.5 Berechtigungsmanagement	BER.5 Passwortgebrauch
Titel	Kompromittierte Berechtigungsmittel	Mehr-Faktor-Authentisierung am Perimeter
UUID	7dbede94-beea-430f-b058-3ff2f9f6b90c (gleicht BER.4.4 UUID vom 01.07.26)	2b9ddd3e-5233-46f5-abca-1793b89e2809 (gleicht BER.6.4 UUID vom 29.05.26)
Zielobjekte		Anwendungen, Externe Netzanschlüsse

BER.5.5 Mehr-Faktor-Authentisierung für weitreichende Berechtigungen (normal-SdT)

Attribut	29.05.26	01.07.26
Abhängigkeit		#BER.3.5
Aufwand	4	2
Dokumentation	Systemdokumentation	IT-Betriebskonzept
Ergebnis	Funktionen, auf die ohne vorherige Authentifizierung zugegriffen werden kann,	Mehr-Faktor-Authentisierung
Handlungswort	dokumentieren	aktivieren
Hinweis	[- Funktionen ohne -] Authentifizierung [- sind alle Zugriffsmöglichkeiten auf Schnittstellen oder Daten des Systems -], [- für die keine Authentifizierung erforderlich ist . Hierzu gehören -] z. B. [- Sprachassistenten -], [- offene Webserver -] [- Ports -] oder [- das Einblenden von Inhalten aus Apps auf dem Sperrbildschirm -], [- wodurch persönliche Nachrichten oder Logintoken für Unbefugte zugänglich -] sein [- könnten -]. [- Solche Funktionen sind häufige Einfallstore für Angriffe auf das System oder für Datenleaks . Daher ist es sinnvoll eine Übersicht dieser Funktionen zu führen , selbst wenn die Funktionen benötigt werden . -]	[+ Eine Mehr - Faktor - +] Authentifizierung [+ bei Zugängen mit weitreichenden Berechtigungen +], z. B. [+ Administrationskonten +], [+ die Zugriff auf wichtige Server wie den Verzeichnisdienst +], [+ das MDM , EDR +] oder [+ DNS haben +], [+ erschwert den unberechtigten Zugang zu diesen Zugängen . Auch der Zugriff auch besonders sensible Daten kann eine weitreichende Berechtigung +] sein.
Präzisierung		für weitreichende Berechtigungen
Tags		MFA, Living off the land, Privilege Escalation, Credential Stuffing, Brute-Force-Attacke
Text	Berechtigung für IT-Systeme SOLLTE Funktionen, auf die ohne vorherige Authentifizierung zugegriffen werden kann, dokumentieren.	Berechtigung SOLLTE Mehr-Faktor-Authentisierung für weitreichende Berechtigungen aktivieren.
Thema	BER.5 Berechtigungsmanagement	BER.5 Passwortgebrauch
Titel	Systemfunktionen ohne Authentifizierung	Mehr-Faktor-Authentisierung für weitreichende Berechtigungen
UUID	bf5b5f6a-f525-45fc-b5a5-62379b3e6b2f (gleich BER.4.5 UUID vom 01.07.26)	55b70084-f446-42af-908b-0f514a72f380 (gleich BER.6.5 UUID vom 29.05.26)

Attribut	29.05.26	01.07.26
Verwandte		#BER.5.4
Zielobjekte	IT-Systeme	

BER.5.6 Blockieren von Passwort Recycling (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	4	3
Dokumentation	Anwendungsdokumentation	Konfigurationshistorie
Ergebnis	Funktionen, auf die ohne vorherige Authentifizierung zugegriffen werden kann,	die Wiederverwendung von Passwörtern
Handlungswort	dokumentieren	blockieren
Hinweis	Hierzu [- gehören z . B . der Zugriff auf öffentliche Inhalte oder Funktionen -] zum [- Zurücksetzen des Passwortes , wodurch persönliche Daten oder Logintoken für Unbefugte zugänglich sein könnten . Allerdings -] kann [- es auch unauthentifizierte Funktionen geben , die für Betrieb oder Informationssicherheit benötigt werden , z . B . Meldeformulare für Sicherheitsvorfälle oder öffentliche Webseiteninhalte . -]	[+ Die Wiederverwendung von Passwörtern („ password reuse “) ist die Nutzung identischer oder bereits früher verwendeter Passwörter für verschiedene Konten , Systeme oder aufeinanderfolgende Authentifizierungsvorgänge . Die Blockierung der Passwortwiederverwendung bedeutet hier , dass das Berechtigungsmanagementsystem („ access management system “) technisch verhindert , dass ein neues Passwort mit einem zuvor verwendeten identisch ist oder einer vordefinierten Anzahl früherer Passwörter entspricht . Dies könnte nicht nur bei Wiederverwendung einer Person problematisch sein , sondern auch bei einer systemübergreifenden Fehlkonfiguration : Ein typisches Szenario wäre , dass in einer Institution mehrere Arbeitsplatzrechner mit identischen lokalen Administratorpasswörtern konfiguriert sind („ local admin password reuse “) . Wird ein einzelner Rechner durch Schadsoftware oder physischen Zugriff kompromittiert , könnte ein Angreifer dieses Passwort anschließend nutzen , um sich mit denselben Anmeldeinformationen lateral auf weitere Systeme auszubreiten . Die Wiederverwendung des lokalen Administratorpassworts könnte somit eine vollständige Kompromittierung der internen IT - Infrastruktur ermöglichen . Diese Anforderung

Attribut	29.05.26	01.07.26
		adressiert den Schutz vor solchen Angriffen , die sich aus der Wiederverwendung kompromittierter Anmeldeinformationen ergeben könnten , etwa durch Credential - Stuffing oder Brute - Force - Angriffe auf bekannte Passwortmuster . Blockieren kann das Risiko verringern , dass ein Angreifer durch bekannte Passwörter unbefugten Zugang zu Konten erhält . +] Hierzu [+ können +] zum [+ einen eine lokale Passworthistorie oder zum anderen elektronische Passwortmanager genutzt werden , die unabhängige sichere Passwörter generieren , wo die Wahrscheinlichkeit einer Passwortwiederholung ausgeschlossen werden +] kann [+ . +]
Tags		Credential Stuffing, Privilege Escalation, Password Policy
Text	Berechtigung für Anwendungen SOLLTE Funktionen, auf die ohne vorherige Authentifizierung zugegriffen werden kann, dokumentieren.	Berechtigung für Nutzende SOLLTE die Wiederverwendung von Passwörtern blockieren.
Thema	BER.5 Berechtigungsmanagement	BER.5 Passwortgebrauch
Titel	Anwendungsfunktionen ohne Authentifizierung	Blockieren von Passwort Recycling
UUID	383f3a5e-d627-46aa-960f-4e8c5c9c9592 (gleicht BER.4.6 UUID vom 01.07.26)	d7c76736-0c1d-4693-92d5-894a8b740204 (gleicht BER.6.6 UUID vom 29.05.26)
Zielobjekte	Anwendungen	Nutzende

BER.5.7 Trivialpasswörter (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	5	2
Dokumentation	Inventar Berechtigungen	Konfigurationshistorie
Ergebnis	diese genau einem Zugangskonto	die Verwendung von Trivialpassworten

Attribut	29.05.26	01.07.26
Handlungswort	zuweisen	blockieren
Hinweis	Wenn ein [- besonders schützenswertes IT -] [- System nur von einer Person -] oder [- Identität genutzt wird -], [- empfiehlt es sich dieses mit genau einem zugehörigen Zugangskonto zu verknüpfen . Dadurch wird ausgeschlossen -], dass [- weitere Konten unnötig Zugriff erhalten -]. [- Bei Revisionen ist auf diese Weise eindeutig nachvollziehbar -], [- welche Identität Zugriff auf das System hatte -]. [- Das Vorgehen ist auch auf virtualisierte IT -] [- Systeme übertragbar . Ein Beispiel ist eine spezielle Administrationskonsole , die ausschließlich einem dedizierten Admin - Konto zugeordnet ist . -]	[+ Trivialpasswörter sind leicht zu erratende oder zu diesem Zugangskonto bereits öffentlich bekannte Passwörter (erkennbar durch Nutzung sog . Leak Check Datenbanken) . Leicht zu erraten sind Passwörter , +] wenn [+ sie mit gängigen Wörterbuchangriffen (dictionary attacks) bzw . systematischem Ausprobieren (brute force) in kurzer Zeit zu kompromittieren sind . Dazu zählen etwa einfache Folgen wie „ 123456 “ , „ Passwort “ oder „ qwerty “ sowie häufig vorkommende , in Leaks dokumentierte Standardkombinationen . Der Zweck der Anforderung liegt darin , das Risiko unautorisierter Zugriffe zu reduzieren : +] Ein [+ Angreifer könnte mit automatisierten Tools in Sekunden oder Minuten triviale Passwörter durchprobieren +], [+ was zu einem unbefugten Zugriff auf Benutzerkonten , Systemressourcen +] oder [+ sensible Daten führen könnte +]. [+ Die Blockierung solcher Passwörter kann dagegen sicherstellen +], dass [+ nur schwer vorhersehbare Kennwörter verwendet werden +], [+ wodurch ein entscheidender Schutz gegen automatisierte Angriffsverfahren erreicht werden kann +]. [+ Zudem können Passwortmanager beim Generieren nicht +]- [+ trivialer Passwörter unterstützen +].
Modalverb	KANN	SOLLTE
Sicherheitsniveau	erhöht	normal-SdT
Tags		Credential Stuffing, Password Policy
Text	Berechtigung für IT-Systeme KANN diese genau einem Zugangskonto zuweisen.	Berechtigung für Nutzende SOLLTE die Verwendung von Trivialpassworten blockieren.
Thema	BER.5 Berechtigungsmanagement	BER.5 Passwortgebrauch
Titel	IT-System-Zugangskonto	Trivialpasswörter

Attribut	29.05.26	01.07.26
UUID	7057a1f6-0804-49ac-9d7f-289ecc71fa33 (gleich BER.4.7 UUID vom 01.07.26)	f0722999-f8c4-4c75-810b-94d7563dd698 (gleich BER.6.7 UUID vom 29.05.26)
Zielobjekte	IT-Systeme	Nutzende

BER.5.8 Kriterien für die Qualität von Passwörtern (normal-SdT)

Attribut	29.05.26	01.07.26
Abhängigkeit	#PERS.6.1	
Ergebnis	eine Vorgehensweise zum Entzug von Berechtigungen	Kriterien für die Qualität von Passwörtern
Hinweis	[- Innerhalb -] der [- Institution ist ein Prozess etabliert -], [- mit dem Berechtigungen system -] und [- anwendungsübergreifend entzogen sowie -] Zugänge [- deaktiviert -] oder [- gelöscht werden , sobald diese nicht mehr benötigt werden . Dadurch wird sichergestellt , dass bei Personalwechseln oder Aufgabenänderungen keine Berechtigungen für einzelne Systeme -] oder Anwendungen [- bestehen bleiben -]. [- Der Entzug von Berechtigungen bei Kündigungen , Versetzungen oder Änderungen von Zuständigkeiten ist , soweit möglich , als automatisierter Ablauf umgesetzt . -]	[+ Kriterien für die Qualität von Passwörtern können z . B . eine minimale Entropie , Passwortlänge oder Verwendung verschiedener Symbole sein . Die Lebensdauer meint die erwartete Nutzungsdauer des Passwortes . Die erforderliche Qualität hängt von den Angriffsmöglichkeiten ab , z . B . Anzahl +] der [+ Zugangskonten +], [+ verwendetes kryptografisches Verfahren (vgl . BSI TR - 02102 +)] und [+ begleitenden Sicherheitsmaßnahmen wie maximale Passwortversuche oder Mehr - Faktor - Authentifizierung . Für +] Zugänge [+ ohne begleitende Maßnahmen ist eine Passwortlänge nicht unter 14 Zeichen empfehlenswert . Die Kriterien können einmalig festgelegt werden +] oder [+ zwischen Zugängen +] oder Anwendungen [+ differenzieren +].
Präzisierung		anhand von Lebensdauer und Angriffsmöglichkeiten
Tags		Privilege Escalation, Credential Stuffing, Brute-Force-Attacke, Password Policy, Cryptography
Text	Berechtigung SOLLTE eine Vorgehensweise zum Entzug von Berechtigungen verankern.	Berechtigung SOLLTE Kriterien für die Qualität von Passwörtern anhand von Lebensdauer und Angriffsmöglichkeiten verankern.

Attribut	29.05.26	01.07.26
Thema	BER.5 Berechtigungsmanagement	BER.5 Passwortgebrauch
Titel	Entzug von Berechtigungen	Kriterien für die Qualität von Passwörtern
UUID	12ab3443-67a1-4ecd-9177-d9547f62d27e (gleich BER.4.8 UUID vom 01.07.26)	af5ba77a-8d77-4a4f-8842-23ba9dedb829 (gleich BER.6.8 UUID vom 29.05.26)
Verwandte	#PERS.6.1.1	

BER.6.1 Etablierte Algorithmen bei der Schlüsselerzeugung (normal-SdT)

Attribut	29.05.26	01.07.26
Ergebnis	einen Passwortmanager	die ausschließliche Verwendung etablierter kryptografischer Algorithmen
Handlungswort	installieren	verankern
Hinweis	Der [- Einsatz eines Passwortmanagers -], [- der -] von [- der Institution den Nutzenden -] zur [- Verfügung gestellt wird -], [- erleichtert die Generierung von sicheren Passwörtern und deren sicherer Verwahrung , indem eine verschlüsselte Datenbank genutzt wird und der Zugang zu dem Passwortmanager mit einem Masterpasswort oder Multi - Faktor Authentisierung geschützt ist . -]	[+ Etablierte kryptografische Algorithmen sind mathematisch fundierte Verschlüsselungsverfahren und Protokolle , die in +] der [+ aktuellen Praxis nicht mit vertretbarem Aufwand gebrochen werden können +]. [+ Sie basieren auf mathematisch schwer lösbaren Problemen , bieten Resistenz gegen bekannte kryptanalytische Angriffe , unterstützen ausreichend große Schlüssellängen und wurden +] von [+ Experten gründlich geprüft und analysiert . Aktuelle etablierte Algorithmen sind in BSI TR - 02102 zu finden . Für weitere Details +] zur [+ Implementierung siehe Detailspezifikation kryptografischer Abläufe und Mechanismen des BSI +].
Parameter		{'ber.6.1-prm1': 'einem anerkannten Standard'}
Präzisierung		bei der Schlüsselerzeugung nach {{einem anerkannten Standard}}
Tags	Password Policy	Cryptography
Text	Berechtigung für Nutzende SOLLTE einen Passwortmanager installieren.	Berechtigung SOLLTE die ausschließliche Verwendung etablierter kryptografischer Algorithmen bei der Schlüsselerzeugung nach {{insert: param, ber.6.1-prm1 }} verankern.
Thema	BER.6 Passwortgebrauch	BER.6 Schlüsselmanagement
Titel	Passwortmanager	Etablierte Algorithmen bei der Schlüsselerzeugung

Attribut	29.05.26	01.07.26
UUID	c1cfa733-340c-497d-a3b6-8480d78e1278 (gleich BER.5.1 UUID vom 01.07.26)	d9e08db0-484e-4cce-89de-2f29f1a52e4e (gleich BER.7.1 UUID vom 29.05.26)

Zielobjekte Nutzende

BER.6.2 Schlüssellänge (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	1	2
Dokumentation	IT-Betriebskonzept	Verzeichnis öffentlicher Schlüssel
Ergebnis	vorkonfigurierte Authentisierungsmittel	die Schlüssellängen
Handlungswort	deaktivieren	zuweisen
Hinweis	[- Herstellerseitige Standardkonten und Default -] [- Passwörter stellen ein beliebtes Eingangstor -] für [- Angreifer dar -]. [- Wenn vorhanden können auch andere Zugangsmittel wie Hardware -] [- Zugangstoken , Zertifikate oder physische Zugangskontrollsysteme als Authentisierungsmittel verstanden werden . -] [+ Für die Sicherheit von Schlüsseln wie Passwörter oder PINs ist die Länge von Bedeutung +]. Für [+ Details siehe BSI TR +]- [+ 02102 +].	
Parameter		{'ber.6.2-prm1': 'einem anerkannten Standard'}
Präzisierung		nach {{einem anerkannten Standard}} bei der Schlüsselerzeugung
Tags	Advanced Persistent Threats (APT)	Cryptography
Text	Berechtigung SOLLTE vorkonfigurierte Authentisierungsmittel deaktivieren.	Berechtigung SOLLTE die Schlüssellängen nach {{ insert: param, ber.6.2-prm1 }} bei der Schlüsselerzeugung zuweisen.
Thema	BER.6 Passwortgebrauch	BER.6 Schlüsselmanagement
Titel	Vorkonfigurierte Authentisierungsmittel	Schlüssellänge
UUID	7e0edf55-22d6-42d8-973f-d3f8635a0913 (gleich BER.5.2 UUID vom 01.07.26)	39301f7d-20ca-49c0-97e5-a8b048877e68 (gleich BER.7.2 UUID vom 29.05.26)

BER.6.3 Verzeichnis öffentlicher Schlüssel (normal-SdT)

Attribut	29.05.26	01.07.26
Dokumentation	IT-Betriebskonzept	Verzeichnis öffentlicher Schlüssel
Ergebnis	die Authentifizierung nur anhand von Biometrie	zu jedem öffentlichen Schlüssel die dazugehörige Identität, das Ablaufdatum, den Nutzungszweck, die Schlüsselart und den Algorithmus
Handlungswort	deaktivieren	dokumentieren
Hinweis	[- Wenn -] die [- Authentifizierung nur biometrisch vorgenommen wird (z . B . anhand von Fingerabdrücken oder Abbildern des Gesichtes) , dann könnten Angreifer Fälschungen oder gestohlene Fingerabdrücke missbrauchen , um sich Zugang zu verschaffen . Werden biometrische Verfahren dagegen mit weiteren Authentisierungsmittel (z . B . einer PIN) kombiniert , können sie den Zugriffsschutz verbessern . Ein häufig vorkommendes Beispiel sind Mobilgeräte wie Smartphones -], die [- durch Fingerabdruck den Zugriff auf Daten -] oder [- Funktionen wie das mobile Bezahlen gestatten -]- [- obwohl auf dem Gerät selbst häufig noch Fingerabdrücke erkennbar sind -].	[+ Im Verzeichnis öffentlicher Schlüssel werden +] die [+ öffentlichen Schlüssel +], die [+ von der Institution erzeugt +] oder [+ eingesetzt werden +], [+ aufgelistet +]. [+ Hiermit werden kryptografische Schlüssel systematisch erfasst und dokumentiert . Zweckmäßig ist es , die Angaben direkt im Schlüssel abzuspeichern . +]
Präzisierung		bei der Schlüsselbeglaubigung
Tags		Cryptography
Text	Berechtigung SOLLTE die Authentifizierung nur anhand von Biometrie deaktivieren.	Berechtigung SOLLTE zu jedem öffentlichen Schlüssel die dazugehörige Identität, das Ablaufdatum, den Nutzungszweck, die Schlüsselart und den Algorithmus bei der Schlüsselbeglaubigung dokumentieren.
Thema	BER.6 Passwortgebrauch	BER.6 Schlüsselmanagement
Titel	Deaktivierung einfacher Biometrie	Verzeichnis öffentlicher Schlüssel
UUID	4483f020-da27-44af-ae23-edf7d676d72f (gleich BER.5.3 UUID vom 01.07.26)	1434b374-7b49-427e-a015-82bffd0d5ea

Attribut	29.05.26	01.07.26
		(gleicht BER.7.3 UUID vom 29.05.26)
BER.6.4 Erzeugung auf sicheren IT-Systemen (normal-SdT)		
Attribut	29.05.26	01.07.26
Aufwand	3	2
Ergebnis	Phishing-resistente Mehr-Faktor-Authentisierung	die Verwendung eines IT-Systems, welches mindestens dasselbe Schutzniveau bietet, für das der Schlüssel eingesetzt werden soll,
Handlungswort	aktivieren	verankern
Hinweis	[- Phishing - resistente Mehr - Faktor - Authentisierung bezeichnet Verfahren zur Anmeldung , bei denen mindestens zwei unterschiedliche Faktoren genutzt werden und bei denen die Authentisierung zusätzlich gegen typische Angriffe wie Credential Phishing , Adversary - in - the - Middle - Angriffe oder die Wiederverwendung abgefangener Sitzungsdaten abgesichert ist . Phishing - resistente Verfahren basieren typischerweise -] auf [- kryptographischen Nachweisen zwischen Endgerät und Zielsystem und verhindern dadurch -], dass [- einmal abgefragte Zugangsdaten oder Einmalcodes durch täuschend echte Anmeldeseiten weiterverwendet werden können -], [- beispielsweise FIDO2 Passkeys -]. [- Hintergrund ist , dass aus externen Netzen wie dem Internet erreichbare Anwendungen (insbesondere die VPN - Einwahl oder Cloud - Anwendungen) ein beliebtes Ziel für Angreifer sind . Klassische Passwörter oder einfache Einmalcodes könnten durch Social Engineering , gefälschte Login - Portale oder Man - in - the - Browser - Angriffe ausgespäht werden . -] [+ Wird ein Schlüssel +] auf [+ einem System erzeugt +], dass [+ einen geringeren Schutz bietet als auf dem späteren Einsatzsystem +], [+ dann könnte der Schlüssel bereits kompromittiert sein +].	
Präzisierung	bei der Schlüsselerzeugung	
Tags	MFA, Credential Stuffing, Brute-Force-Attacke	Cryptography
Text	Berechtigung für Anwendungen von Externe Netzanschlüssen SOLLTE Phishing-resistente Mehr-	Berechtigung SOLLTE die Verwendung eines IT-

Attribut	29.05.26	01.07.26
	Faktor-Authentisierung aktivieren.	Systems, welches mindestens dasselbe Schutzniveau bietet, für das der Schlüssel eingesetzt werden soll, bei der Schlüsselerzeugung verankern.
Thema	BER.6 Passwortgebrauch	BER.6 Schlüsselmanagement
Titel	Mehr-Faktor-Authentisierung am Perimeter	Erzeugung auf sicheren IT-Systemen
UUID	2b9ddd3e-5233-46f5-abca-1793b89e2809 (gleicht BER.5.4 UUID vom 01.07.26)	f99e7db6-714a-4fd8-94dd-e27cce24f0a7 (gleicht BER.7.4 UUID vom 29.05.26)
Zielobjekte	Anwendungen, Externe Netzanschlüsse	

BER.6.5 Kriterien für die Qualität von Zufallszahlen (normal-SdT)

Attribut	29.05.26	01.07.26
Abhängigkeit	#BER.3.5	
Aufwand	2	3
Ergebnis	Mehr-Faktor-Authentisierung	{{Kriterien}} für die Qualität von Zufallszahlen
Handlungswort	aktivieren	verankern
Hinweis	[- Eine Mehr -] [- Faktor -] [- Authentifizierung bei Zugängen mit weitreichenden Berechtigungen -], z. B. [- Administrationskonten -], die [- Zugriff -] auf [- wichtige Server wie den Verzeichnisdienst -], [- das MDM , EDR oder DNS haben , erschwert den unberechtigten Zugang zu diesen Zugängen . Auch der Zugriff auch besonders sensible Daten kann eine weitreichende Berechtigung sein . -]	[+ Wenn bei der Schlüsselerzeugung ein ungeeigneter Zufallszahlengenerator verwendet wird +], [+ könnte ein Angreifer Schlüssel errechnen +]. [+ Daher sind Kriterien für Zufallszahlengeneratoren zu wählen +], z. B. [+ Verwendung etablierter +], [+ durch unabhängige Dritte geprüfter Zufallszahlengeneratoren . Für Details siehe BSI TR - 02102 - 1 . Wichtig ist dabei auch , dass +] die [+ verwendete Zufallsquelle tatsächlich eine nicht vorhersagbare Zahlenerzeugung erreicht . Insbesondere virtualisierte Systeme könnten ungeeignet sein zur Schlüsselerzeugung , da ihre Zufallszahlenquellen nicht direkt +] auf [+ Hardwarefunktionen zurückgreifen +].

Attribut	29.05.26	01.07.26
Parameter		{'ber.6.5-prm1': 'Kriterien'}
Präzisierung	für weitreichende Berechtigungen	bei der Schlüsselerzeugung
Tags	MFA, Living off the land, Privilege Escalation, Credential Stuffing, Brute-Force-Attacke	Cryptography
Text	Berechtigung SOLLTE Mehr-Faktor-Authentisierung für weitreichende Berechtigungen aktivieren.	Berechtigung SOLLTE {{ insert: param, ber.6.5-prm1 }} für die Qualität von Zufallszahlen bei der Schlüsselerzeugung verankern.
Thema	BER.6 Passwortgebrauch	BER.6 Schlüsselmanagement
Titel	Mehr-Faktor-Authentisierung für weitreichende Berechtigungen	Kriterien für die Qualität von Zufallszahlen
UUID	55b70084-f446-42af-908b-0f514a72f380 (gleicht BER.5.5 UUID vom 01.07.26)	426ad852-4455-43a4-b4ff-795ee2caa47b (gleicht BER.7.5 UUID vom 29.05.26)
Verwandte	#BER.6.4	

BER.6.6 Etablierte Algorithmen beim Transport (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	3	2
Dokumentation	Konfigurationshistorie	IT-Betriebskonzept
Ergebnis	die Wiederverwendung von Passwörtern	die ausschließliche Verwendung etablierter kryptografischer Algorithmen
Handlungswort	blockieren	verankern
Hinweis	[- Die Wiederverwendung von Passwörtern -] ([- „password reuse “ -]) [- ist die Nutzung identischer oder bereits früher verwendeter Passwörter für verschiedene Konten -], [- Systeme oder aufeinanderfolgende Authentifizierungsvorgänge . Die Blockierung der Passwortwiederverwendung bedeutet hier , dass das Berechtigungsmanagementsystem („access management system “) technisch verhindert , dass ein neues Passwort mit einem zuvor verwendeten identisch ist oder einer vordefinierten Anzahl früherer Passwörter entspricht . Dies könnte nicht nur bei Wiederverwendung einer Person problematisch sein ,	[+ Aktuelle etablierte Algorithmen sind in BSI TR +] - [+ 02102 zu finden +]. [+ Der Transport kann mit Public Key Cryptography Standards +] ([+ PKCS +]), [+ z +]. [+ B +]. [+ PKCS # 12 Dateiformat erfolgen . Für +] weitere [+ Details zur

Attribut	29.05.26	01.07.26
	sondern auch bei einer systemübergreifenden Fehlkonfiguration : Ein typisches Szenario wäre , dass in einer Institution mehrere Arbeitsplatzrechner mit identischen lokalen Administratorpasswörtern konfiguriert sind („ local admin password reuse “ -]). [- Wird ein einzelner Rechner durch Schadsoftware oder physischen Zugriff kompromittiert -], [- könnte ein Angreifer dieses Passwort anschließend nutzen -], [- um sich mit denselben Anmeldeinformationen lateral auf -] weitere [- Systeme auszubreiten -]. [- Die Wiederverwendung des lokalen Administratorpassworts könnte somit eine vollständige Kompromittierung der internen IT - Infrastruktur ermöglichen . Diese Anforderung adressiert den Schutz vor solchen Angriffen , die sich aus der Wiederverwendung kompromittierter Anmeldeinformationen ergeben könnten , etwa durch Credential - Stuffing oder Brute - Force - Angriffe auf bekannte Passwortmuster . Blockieren kann das Risiko verringern , dass ein Angreifer durch bekannte Passwörter unbefugten Zugang zu Konten erhält . Hierzu können zum einen eine lokale Passworthistorie oder zum anderen elektronische Passwortmanager genutzt werden , die unabhängige sichere Passwörter generieren , wo die Wahrscheinlichkeit einer Passwortwiederholung ausgeschlossen werden kann . -]	Implementierung siehe Detailspezifikation kryptografischer Abläufe und Mechanismen des BSI +].
Präzisierung		beim Transport geheimer Schlüssel
Tags	Credential Stuffing, Privilege Escalation, Password Policy	Cryptography
Text	Berechtigung für Nutzende SOLLTE die Wiederverwendung von Passwörtern blockieren.	Berechtigung SOLLTE die ausschließliche Verwendung etablierter kryptografischer Algorithmen beim Transport geheimer Schlüssel verankern.
Thema	BER.6 Passwortgebrauch	BER.6 Schlüsselmanagement
Titel	Blockieren von Passwort Recycling	Etablierte Algorithmen beim Transport

Attribut	29.05.26	01.07.26
UUID	d7c76736-0c1d-4693-92d5-894a8b740204 (gleicht BER.5.6 UUID vom 01.07.26)	88e6ce16-583d-40b4-a0cc-8a31bbb8c62c (gleicht BER.7.6 UUID vom 29.05.26)

Zielobjekte Nutzende

BER.6.7 Kein Transport privater Schlüssel (erhöht)

Attribut	29.05.26	01.07.26
Aufwand	2	5
Dokumentation	Konfigurationshistorie	IT-Betriebskonzept
Ergebnis	die Verwendung von Trivialpasswörtern	den Export privater Schlüssel
Handlungswort	blockieren	autorisieren

Hinweis	[- Trivialpasswörter sind leicht -] zu [- erratende oder zu diesem Zugangskonto bereits öffentlich bekannte Passwörter -] ([- erkennbar durch Nutzung sog . Leak Check Datenbanken) . Leicht zu erraten sind Passwörter , wenn -] sie [- mit gängigen Wörterbuchangriffen (dictionary attacks) bzw . systematischem Ausprobieren (brute force) in kurzer Zeit zu kompromittieren sind . Dazu zählen etwa einfache Folgen wie „ 123456 “ , „ Passwort “ oder „ qwerty “ sowie häufig vorkommende , in Leaks dokumentierte Standardkombinationen . Der Zweck der Anforderung liegt darin , das Risiko unautorisierter Zugriffe zu reduzieren : Ein Angreifer könnte mit automatisierten Tools in Sekunden oder Minuten triviale Passwörter durchprobieren , was zu einem unbefugten Zugriff auf Benutzerkonten , Systemressourcen oder sensible Daten führen könnte . Die Blockierung solcher Passwörter kann dagegen sicherstellen , dass nur schwer vorhersehbare Kennwörter verwendet -] werden, [- wodurch ein entscheidender Schutz gegen automatisierte Angriffsverfahren erreicht -] werden [- kann -]. [- Zudem können Passwortmanager beim Generieren nicht -] [- trivialer Passwörter unterstützen -].	[+ Im Allgemeinen ist es sinnvoll , private Schlüssel nur dort +] zu [+ erzeugen +], [+ wo +] sie [+ auch genutzt +] werden. [+ Andernfalls könnten sie durch den Export kompromittiert +] werden. [+ Hiervon sind allerdings zahlreiche Ausnahmen denkbar +], [+ z +]. [+ B . zur Schlüsselerzeugung auf besonders abgesicherten Systemen , zum Transport auf Redundanzsysteme oder zur Datensicherung . Daher ist eine Abwägung sinnvoll , ob der Export zu genehmigen ist . +]
---------	--	---

Modalverb	SOLLTE	KANN
-----------	--------	------

Attribut	29.05.26	01.07.26
Parameter		{'ber.6.7-prm1': 'eine zuständige Person oder Rolle'}
Präzisierung		durch {{eine zuständige Person oder Rolle}}
Sicherheitsniveau	normal-SdT	erhöht
Tags	Credential Stuffing, Password Policy	Cryptography
Text	Berechtigung für Nutzende SOLLTE die Verwendung von Trivialpasswörtern blockieren.	Berechtigung KANN den Export privater Schlüssel durch {{insert: param, ber.6.7-prm1 }} autorisieren.
Thema	BER.6 Passwortgebrauch	BER.6 Schlüsselmanagement
Titel	Trivialpasswörter	Kein Transport privater Schlüssel
UUID	f0722999-f8c4-4c75-810b-94d7563dd698 (gleich BER.5.7 UUID vom 01.07.26)	c28426cd-d01c-427d-bade-141936177c55 (gleich BER.7.7 UUID vom 29.05.26)
Zielobjekte	Nutzende	

BER.6.8 Etablierte Algorithmen bei der Schlüsselnutzung (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	3	2
Ergebnis	Kriterien für die Qualität von Passwörtern	die ausschließliche Verwendung etablierter Algorithmen
Hinweis	[- Kriterien für die Qualität von Passwörtern können z . B . eine minimale Entropie , Passwortlänge oder Verwendung verschiedener Symbole sein . Die Lebensdauer meint die erwartete Nutzungsdauer des Passwortes . Die erforderliche Qualität hängt von den Angriffsmöglichkeiten ab , z . B . Anzahl der Zugangskonten , verwendetes kryptografisches Verfahren (vgl . -] BSI TR- 02102 [-) und begleitenden Sicherheitsmaßnahmen wie maximale Passwortversuche oder Mehr - Faktor - Authentifizierung -]. Für [- Zugänge ohne begleitende Maßnahmen ist eine Passwortlänge nicht unter 14 Zeichen empfehlenswert -]. [- Die Kriterien können	[+ Aktuelle etablierte Algorithmen sind in +] BSI TR- 02102 [+ zu finden +]. Für [+ weitere Details zur Implementierung siehe Detailspezifikation kryptografischer Abläufe und Mechanismen des BSI +].

Attribut	29.05.26	01.07.26
	einmalig festgelegt werden oder zwischen Zugängen oder Anwendungen differenzieren . -]	
Präzisierung	anhand von Lebensdauer und Angriffsmöglichkeiten	bei der Schlüsselnutzung
Tags	Privilege Escalation, Credential Stuffing, Brute-Force-Attacke, Password Policy, Cryptography	Cryptography
Text	Berechtigung SOLLTE Kriterien für die Qualität von Passwörtern anhand von Lebensdauer und Angriffsmöglichkeiten verankern.	Berechtigung SOLLTE die ausschließliche Verwendung etablierter Algorithmen bei der Schlüsselnutzung verankern.
Thema	BER.6 Passwortgebrauch	BER.6 Schlüsselmanagement
Titel	Kriterien für die Qualität von Passwörtern	Etablierte Algorithmen bei der Schlüsselnutzung
UUID	af5ba77a-8d77-4a4f-8842-23ba9dedb829 (gleich BER.5.8 UUID vom 01.07.26)	efea2ba5-e5b5-4344-9341-b87340dab114 (gleich BER.7.8 UUID vom 29.05.26)

BER.6.9 Zweckbindung (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	1	2
Ergebnis	einen Passwortwechsel	Verstöße gegen die Zweckbindung
Handlungswort	ausführen	untersagen
Hinweis	[- Ein ausschließlich anlassbezogener Passwortwechsel -] bedeutet, dass [- Passwörter nur genau dann geändert -] werden [- , wenn ein begründeter Sicherheitsanlass vorliegt – beispielsweise ein Verdacht auf Kompromittierung des Endgerätes oder Zugangs , neue einschlägige Einträge in öffentlichen Leak - Datenbanken -] , die [- Weitergabe an Unbefugte durch einen Phishing -] [- Vorfall , oder technische Indikatoren für einen möglichen Missbrauch des Zugangs zu Systemen oder Anwendungen . Dieser Ansatz unterscheidet sich vom früher häufig praktizierten , periodischen Passwortwechsel , der ohne konkreten Anlass in festen Intervallen erzwungen wurde . Ein solcher erzwungener Rhythmus könnte die	[+ Zweckbindung +] bedeutet, dass [+ der Schlüssel ausschließlich zu dem im Verzeichnis öffentlichen Schlüssel festgelegten Nutzungszweck verwendet +] werden [+ darf +] . Die [+ Zweckbindung gilt insbesondere auch für den privaten Schlüssel +] .

Attribut	29.05.26	01.07.26
	Passwortsicherheit sogar verringern , weil Nutzende dann dazu neigen , schwächere , nur leicht veränderte Passwörter („ sommer5 “) zu wählen oder Zugangsdaten in verschiedenen Zugängen wiederzuverwenden . Zweck dieser Regelung ist es , die tatsächliche Sicherheit von Zugangskonten zu erhöhen und unnötige Belastungen der Nutzenden zu vermeiden . -]	
Präzisierung	ausschließlich anlassbezogen	bei der Schlüsselnutzung
Tags	Password Policy	Cryptography
Text	Berechtigung SOLLTE einen Passwortwechsel ausschließlich anlassbezogen ausführen.	Berechtigung SOLLTE Verstöße gegen die Zweckbindung bei der Schlüsselnutzung untersagen.
Thema	BER.6 Passwortgebrauch	BER.6 Schlüsselmanagement
Titel	Anlassbezogene Passwortwechsel	Zweckbindung
UUID	4de1c314-e6b3-4b70-bc73-54cdfca7ae9 (gleicht BER.5.9 UUID vom 01.07.26)	c5ed06a9-b144-43a9-b269-ff914304036a (gleicht BER.7.9 UUID vom 29.05.26)

BER.6.10 Abgelaufene Schlüssel (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	3	1
Dokumentation	Detektions-Konzept	IT-Betriebskonzept
Ergebnis	Zugangsdaten auf Kompromittierung	die Nutzung des Schlüssels zur Verschlüsselung oder Signierung
Handlungswort	überwachen	untersagen
Hinweis	[- Eine Kompromittierung meint hier , dass Zugangsdaten wie Benutzername und Passwort (englisch : credentials) von Unbefugten eingesehen , abgefangen -] oder [- manipuliert wurden , sodass ein Missbrauch für unautorisierte Zugriffe möglich wird . Dies könnte etwa durch Leaks in Datenbanken , durch Phishing - Angriffe oder durch das Abfangen unverschlüsselter Übertragungen	[+ Schlüssel dürfen nach Ablauf der Nutzungszeit nur noch zur Entschlüsselung +] oder [+ Signaturprüfung alter +] Daten [+ verwendet +] werden. [+ Bei automatisierter

Attribut	29.05.26	01.07.26
	entstehen . Ein automatisierter Mechanismus bezeichnet hierbei eine technische Lösung , die ohne manuelles Zutun kontinuierlich prüft , ob bekannte Indikatoren einer Kompromittierung vorliegen (englisch : credential monitoring system) . Geeignete Mechanismen können etwa Credential - Leak - Monitoring - Dienste , Data Breach Checker oder Darknet - Scanning - Tools sein . Der Zweck dieser Vorgabe liegt darin , dass ein frühzeitiges Erkennen von kompromittierten Zugangsdaten helfen kann , unautorisierte Logins und den Missbrauch sensibler Systeme zu verhindern ; ohne eine solche Überwachung könnte ein Angreifer über lange Zeit unentdeckt mit gestohlenen -] Daten [- arbeiten und kritische Schäden verursachen . Ergeben sich hierbei Anzeichen auf eine Kompromittierung oder einen Leak der Zugangsdaten , so kann als Reaktion ein Wechsel der Zugangsdaten über einen nicht kompromittierten Kommunikationskanal veranlasst oder schlicht das betroffene Zugangskonto gesperrt -] werden.	Schlüsselnutzung ist der Schlüssel zu deaktivieren , bei manueller Schlüsselnutzung ist den Nutzenden weitere Verwendung des Schlüssels zu verbieten . +]
Parameter	{'ber.6.10-prm1': 'einen automatisierten Mechanismus'}	
Präzisierung	durch {{einen automatisierten Mechanismus}}	nach Ablauf der Nutzungszeit
Tags	Credential Stuffing, Password Policy	Cryptography
Text	Berechtigung SOLLTE Zugangsdaten auf Kompromittierung durch {{ insert: param, ber.6.10-prm1 }} überwachen.	Berechtigung SOLLTE die Nutzung des Schlüssels zur Verschlüsselung oder Signierung nach Ablauf der Nutzungszeit untersagen.
Thema	BER.6 Passwortgebrauch	BER.6 Schlüsselmanagement
Titel	Monitoring von Zugangsdaten	Abgelaufene Schlüssel
UUID	4785649d-561d-4757-9421-4d0db14ee4df (gleich BER.5.10 UUID vom 01.07.26)	f9429a00-a0c2-434c-89d5-cb768d87a192 (gleich BER.7.10 UUID vom 29.05.26)

BES.2.1.2 Geschäftsprozessprofile (normal-SdT)

Attribut	29.05.26	01.07.26
Modalverb	KANN	SOLLTE
Sicherheitsniveau	erhöht	normal-SdT
Text	Beschaffungsmanagement für Outsourcing KANN Geschäftsprozessprofile für (Teil-)Prozesse, die ausgelagert werden, mit Funktion, verarbeiteten Informationen, einzuhaltenden rechtlichen und organisatorischen Rahmenbedingungen, prozessualen Schnittstellen, Abhängigkeiten zwischen Prozessen, sowie ihren Schutzbedarfen und Kritikalitäten dokumentieren.	Beschaffungsmanagement für Outsourcing SOLLTE Geschäftsprozessprofile für (Teil-)Prozesse, die ausgelagert werden, mit Funktion, verarbeiteten Informationen, einzuhaltenden rechtlichen und organisatorischen Rahmenbedingungen, prozessualen Schnittstellen, Abhängigkeiten zwischen Prozessen, sowie ihren Schutzbedarfen und Kritikalitäten dokumentieren.

BES.2.5 Anhörung Administrierender (normal-SdT)

Attribut	29.05.26	01.07.26
Titel	Anhörung Administrierender	Anhörung Administrierender

DET.4.11.2 Netzwerk-Honeypots (erhöht)

Attribut	29.05.26	01.07.26
Aufwand	3	5

DET.4.12 Monitoring der Netzverfügbarkeit (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	5	3

DET.4.12.1 Auslastung des Netzes (erhöht)

Attribut	29.05.26	01.07.26
Modalverb	KANN	SOLLTE
Text	Detektion für Netze KANN die Auslastung des Netzes anhand von {{ insert: param, det.4.12.1-prm1 }} überwachen.	Detektion für Netze SOLLTE die Auslastung des Netzes anhand von {{ insert: param, det.4.12.1-prm1 }} überwachen.

DET.5.6 Threat Hunting (erhöht)

Attribut	29.05.26	01.07.26
Hinweis	Threat Hunting bezeichnet eine proaktive Suche nach Anzeichen für Sicherheitsvorfälle durch Analyseexperten, da fortschrittliche Angriffe durch automatisierte Systeme zur Angriffserkennung häufig nicht detektiert werden können. Im Unterschied zum Penetrationstest steht dabei nicht das Aufsuchen von Schwachstellen, sondern das Finden bereits erfolgreicher Angriffe oder Bedrohungen in den eigenen Systemen und Anwendungen im Vordergrund.	Threat Hunting bezeichnet eine proaktive Suche nach Anzeichen für Sicherheitsvorfälle durch Analyseexperten, da fortschrittliche Angriffe durch automatisierte Systeme zur Angriffserkennung häufig nicht detektiert werden können. Im Unterschied zum Penetrationstest steht dabei nicht das Aufsuchen von Schwachstellen, sondern das Finden bereits erfolgreicher Angriffe oder Bedrohungen in den eigenen Systemen und Anwendungen im Vordergrund. [+ In einem ersten Schritt werden Hypothesen , wo und wie sich Angreifer in Infrastrukturen eingeschlichen haben könnten , aufgestellt . Dabei kann man sich etwa auf den Kontext des Informationsverbunden und existierende Bedrohungsmodellierungen stützen . Anschließend werden einschlägige Zielobjekte ausgewählt und auf Anzeichen für verdächtige Aktivitäten untersucht , etwa IT - Systeme , die direkt aus dem Internet erreichbar sind , Jumphosts oder zentrale Hostsysteme . Die Ergebnisse der Überprüfung fließen dann in die regelmäßige Auswahl und Verbesserung von Schutzmaßnahmen mit ein . +]

DET.5.7 Analyse verdeckter Kanäle (erhöht)

Attribut	29.05.26	01.07.26
Hinweis	Ein verdeckter Kanal (Covert Channel) ist ein heimlicher Kommunikationskanal, mit dem Angreifer legitime Verbindungen ausnutzen, um verdeckt Daten zu übertragen. [- Viele dieser -] verdeckten Kanäle können durch darauf spezialisierte Erkennungswerkzeuge (sog. Warden) erkannt werden. Aufgrund der Vielzahl denkbarer verdeckter Kommunikationswege können solche Kanäle jedoch kaum vollständig verhindert werden. Ergänzende Maßnahmen wie Traffic Normalization können sie [- jedoch -] ausbremsen oder unerkant eliminieren. [-	Ein verdeckter Kanal (Covert Channel) ist ein heimlicher Kommunikationskanal, mit dem Angreifer legitime Verbindungen ausnutzen, um verdeckt Daten zu übertragen. [+ Die Analyse verdeckter Kanäle ist insbesondere dann sinnvoll , wenn die Gefahr eines unbefugten Informationsflusses über Sicherheitsdomänen hinweg besteht , beispielsweise bei Anwendungen an externen Netzanschlüssen oder bei IT - Systemen , auf denen Daten mit hoher Sicherheitseinstufung neben anderen Daten verarbeitet werden . Relevant sind dabei sowohl Speicherkanäle (Storage Channel) als auch Zeitkanäle (Timing Channel) . Um potenzielle verdeckte Kanäle zu identifizieren bietet es sich an , auf Bedrohungsmodellierungen (Threat Modelling) oder die Sicherheitsarchitektur der betrachteten IT - Produkte zurückzugreifen . Entwickler oder erfahrene Penetrationstester sind am besten in der Lage , potenzielle Schwachstellen in IT - Systemen zu identifizieren , die zu +] verdeckten [+ Kanälen

Attribut	29.05.26	01.07.26
	Relevant sind dabei sowohl Speicherkanäle (Storage Channel) als auch Zeitkanäle (Timing Channel) . -]	führen könnten . Einige verdeckte +] Kanäle können durch darauf spezialisierte Erkennungswerkzeuge (sog. Warden) erkannt werden. Aufgrund der Vielzahl denkbarer verdeckter Kommunikationswege können solche Kanäle jedoch kaum vollständig verhindert werden. [+ Daher ist es zweckmäßig , sich bei der Analyse auf diejenigen potenziellen verdeckte Kanäle zu konzentrieren , die eine bestimmte Bandbreitenschwelle überschreiten . Hierbei bietet sich ein gegenseitiger Abgleich mit existierenden Bedrohungsmodellierungen oder Risikoanalysen an . Auch +] ergänzende Maßnahmen wie Traffic Normalization können [+ sinnvoll sein - dadurch kann verdeckte Kommunikation zwar nicht erkannt werden , jedoch kann man +] sie [+ so +] ausbremsen oder unerkannt eliminieren.
Parameter	{'det.5.7-prm1': 'regelmäßig'}	{'det.5.7-prm1': 'bei Sicherheitsvorfällen mit verdeckten Kanälen und regelmäßig'}
Präzisierung	{{regelmäßig}}	{{bei Sicherheitsvorfällen mit verdeckten Kanälen und regelmäßig}}

DET.6.1.1 Automatisierte Feststellung (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	4	3

DET.6.2.2 Datenträgerschleuse (erhöht)

Attribut	29.05.26	01.07.26
Aufwand	3	5
Hinweis	Eine Datenträgerschleuse ist ein vom restlichen Netz der Institution getrenntes System zur Erkennung von Schadprogrammen.	Eine Datenträgerschleuse ist ein vom restlichen Netz der Institution getrenntes [+ IT - +] System [+ , das speziell +] zur Erkennung von Schadprogrammen [+ dient +] . [+ Der Begriff Datenträger umfasst hierbei insbesondere USB - Speichergeräte , externe Festplatten , Speicherkarten sowie optische Datenträger . Der Einsatz einer Datenträgerschleuse kann das Risiko reduzieren , dass Schadsoftware , manipulierte Dateien oder unzulässig übertragene Informationen über mobile Speichermedien in Systeme eingebracht oder aus ihnen heraus transportiert werden . Ohne entsprechende Kontrollmechanismen könnte beispielsweise Malware über USB - Datenträger eingeschleust

Attribut	29.05.26	01.07.26
		oder eine unbemerkte Datenabgabe über Wechselspeicher erfolgen ; eine Datenträgerschleuse kann solche Vorgänge sichtbar machen und zusätzliche Prüfungen ermöglichen . +]

GC.1.1 Errichtung und Aufrechterhaltung eines ISMS (normal-SdT)

Attribut	29.05.26	01.07.26
Dokumentation		ISMS-Regelwerk

GC.2.1 Festlegung des externen Kontextes der Institution (normal-SdT)

Attribut	29.05.26	01.07.26
Ergebnis	ein Verfahren zur Sammlung, Integration und Priorisierung aller für das Informationssicherheitsmanagement relevanten externen Rahmenbedingungen	alle für das Informationssicherheitsmanagement relevanten externen Rahmenbedingungen
Handlungswort	verankern	analysieren
Hinweis	[- Analysieren und dokumentieren Sie systematisch -] alle externen Faktoren, die einen Einfluss auf die Informationssicherheitsziele und- strategie der Institution haben. Dazu zählen insbesondere Faktoren, die von außen auf die Institution einwirken wie z. B. gesellschaftliche und kulturelle Faktoren, die die Erwartungen an die Institution prägen; rechtliche und regulatorische Rahmenbedingungen auf nationaler und internationaler Ebene; technologische Entwicklungen und deren Auswirkungen auf die Informationssicherheit; wirtschaftliche Bedingungen im relevanten Marktumfeld und ökologische und physische Umweltbedingungen am Standort der Institution.	Alle externen Faktoren, die einen Einfluss auf die Informationssicherheitsziele und- strategie der Institution haben [+ , werden systematisch analysiert und dokumentiert +] . Dazu zählen insbesondere Faktoren, die von außen auf die Institution einwirken wie z. B. gesellschaftliche und kulturelle Faktoren, die die Erwartungen an die Institution prägen; rechtliche und regulatorische Rahmenbedingungen auf nationaler und internationaler Ebene; technologische Entwicklungen und deren Auswirkungen auf die Informationssicherheit; wirtschaftliche Bedingungen im relevanten Marktumfeld und ökologische und physische Umweltbedingungen am Standort der Institution.
Text	Governance und Compliance MUSS ein Verfahren zur Sammlung, Integration und Priorisierung aller für das Informationssicherheitsmanagement relevanten externen Rahmenbedingungen verankern.	Governance und Compliance MUSS alle für das Informationssicherheitsmanagement relevanten externen Rahmenbedingungen analysieren.

Attribut	29.05.26	01.07.26
Thema	GC.2 Festlegung des Kontextes der Institution	GC.2 Institutionskontext

GC.2.2 Festlegung des internen Kontextes der Institution (normal-SdT)

Attribut	29.05.26	01.07.26
Ergebnis	ein Verfahren zur Sammlung, Integration und Priorisierung aller für das Informationssicherheitsmanagement relevanten internen Rahmenbedingungen	alle für das Informationssicherheitsmanagement relevanten internen Rahmenbedingungen
Handlungswort	verankern	analysieren
Hinweis	[- Analysieren und dokumentieren Sie systematisch -] alle internen Faktoren, die einen Einfluss auf die Informationssicherheitsziele und- strategie der Institution haben. Dazu zählen institutionseigene Faktoren wie z. B. vorhandene Institutionsstrategien, Werte und Institutionsziele; die Institutionsstruktur mit Hierarchien, Abteilungen und Zuständigkeitsbereichen; die in Ihrer Institution etablierte Prozesse und Arbeitsabläufe; vorhandene IT- Infrastruktur und Informationssysteme und die Institutionskultur und Einstellungen zur Sicherheit.	Alle internen Faktoren, die einen Einfluss auf die Informationssicherheitsziele und- strategie der Institution haben [+ , werden systematisch analysiert und dokumentiert +] . Dazu zählen institutionseigene Faktoren wie z. B. vorhandene Institutionsstrategien, Werte und Institutionsziele; die Institutionsstruktur mit Hierarchien, Abteilungen und Zuständigkeitsbereichen; die in Ihrer Institution etablierte Prozesse und Arbeitsabläufe; vorhandene IT- Infrastruktur und Informationssysteme und die Institutionskultur und Einstellungen zur Sicherheit.
Text	Governance und Compliance MUSS ein Verfahren zur Sammlung, Integration und Priorisierung aller für das Informationssicherheitsmanagement relevanten internen Rahmenbedingungen verankern.	Governance und Compliance MUSS alle für das Informationssicherheitsmanagement relevanten internen Rahmenbedingungen analysieren.
Thema	GC.2 Festlegung des Kontextes der Institution	GC.2 Institutionskontext

GC.3.1 Verfahren und Regelungen (normal-SdT)

Attribut	29.05.26	01.07.26
Dokumentation		Compliance-Verpflichtungen
Ergebnis	ein Verfahren zum Ermitteln aller externen interessierten Parteien und	ein Verfahren zur systematischen Erfassung und Verwaltung von Compliance-

Attribut	29.05.26	01.07.26
	ihrer Bedürfnisse und Erwartungen an das Informationssicherheitsmanagement der Institution	Verpflichtungen
Hinweis	Alle [- relevanten externen interessierten Parteien sind ermittelt -]. Die [- externen interessierten Parteien umfassen beispielsweise : Gesetzgeber , Aufsichtsbehörden , Kunden , Dienstleister , Gesellschaft / Öffentlichkeit -]. Die [- Relevanz -] und [- Priorität der identifizierten Anforderungen sind zu bewerten -] und [- auf Grundlage dessen ist festzulegen -], [- welche dieser Anforderungen als verbindliche Verpflichtungen in das ISMS aufgenommen werden . -]	[+ Die systematische Erfassung der informationssicherheitsrelevanten Compliance - Anforderungen ist Grundlage für eine wirksame Umsetzung . Das Compliance Management stellt sicher , dass +] alle [+ gesetzlichen , regulatorischen und vertraglichen Verpflichtungen im Bereich der Informationssicherheit eingehalten werden . Aufgrund der hohen Komplexität des modernen Rechts ist für die Rechtspflege eine eigene Rechtsabteilung oder die Beauftragung von Mitgliedern der rechtsberatenden Berufe zweckmäßig +]. Die [+ bei der Festlegung des Verfahrens im Einzelnen zu berücksichtigenden Inhalte ergeben sich aus den Anforderungen dieser Praktik +]. Die [+ systematische Erfassung +] und [+ Verwaltung von Compliance - Verpflichtungen für Informationssicherheit bilden die Grundlage für deren wirksame Umsetzung +] und [+ kontinuierliche Überwachung +].
Präzisierung		unter Einbezug der jeweiligen Priorität für das ISMS
Tags		Compliance Management
Text	Governance und Compliance MUSS ein Verfahren zum Ermitteln aller externen interessierten Parteien und ihrer Bedürfnisse und Erwartungen an das Informationssicherheitsmanagement der Institution verankern.	Governance und Compliance MUSS ein Verfahren zur systematischen Erfassung und Verwaltung von Compliance-Verpflichtungen unter Einbezug der jeweiligen Priorität für das ISMS verankern.
Thema	GC.3 Analyse der interessierten Parteien	GC.3 Compliance-Management
Titel	Analyse der externen interessierten Parteien	Verfahren und Regelungen

Attribut	29.05.26	01.07.26
UUID	834c85a0-f793-4d6a-8eba-5f26f38979cd (gleicht GC.4.1 UUID vom 01.07.26)	de07bcb3-2a0b-44d4-bd3f-eca08ce44992 (gleicht GC.7.1 UUID vom 29.05.26)
Verbesserung		GC.3.1.1, GC.3.1.2, GC.3.1.3, GC.3.1.4
Verwandte	#GC.3.2	#PERF.2.1, #UMS.7.1

GC.4.1 Analyse der externen interessierten Parteien (normal-SdT)

Attribut	29.05.26	01.07.26
Abhängigkeit	#GC.3.2, #GC.3.1, #GC.2.2, #GC.2.1	
Ergebnis	den nachvollziehbar abgegrenzten Geltungsbereich	alle externen interessierten Parteien sowie ihre Bedürfnisse und Erwartungen
Handlungswort	festlegen	analysieren
Hinweis	[- Definieren -] und [- dokumentieren Sie den Geltungsbereich Ihres ISMS . Dieser legt den formalen -] und [- organisatorischen Umfang (Scope) fest , in dem das ISMS angewendet -] wird [- . Legen Sie fest -], welche [- Institutionsbereiche , Geschäftsprozesse und Tätigkeiten formell zum Geltungsbereich gehören und grenzen Sie infrastrukturell ab , welche Standorte und Systeme innerhalb des Geltungsbereichs liegen ; welche externen Partner oder Dienstleister -] in das ISMS [- einzubeziehen sind und welche Bereiche bewusst nicht Bestandteil des Geltungsbereichs sind -].	[+ Alle relevanten externen interessierten Parteien werden ermittelt . Die externen interessierten Parteien umfassen beispielsweise : Gesetzgeber , Aufsichtsbehörden , Kunden , Dienstleister , Gesellschaft / Öffentlichkeit . Die Relevanz +] und [+ Priorität der identifizierten Anforderungen werden bewertet +] und [+ auf Grundlage dessen +] wird [+ festgelegt +], welche [+ dieser Anforderungen als verbindliche Verpflichtungen +] in das ISMS [+ aufgenommen werden +].
Präzisierung	nach Freigabe der Institutionsleitung	an das Informationssicherheitsmanagement der Institution
Text	Governance und Compliance MUSS den nachvollziehbar abgegrenzten Geltungsbereich nach Freigabe der Institutionsleitung festlegen.	Governance und Compliance MUSS alle externen interessierten Parteien sowie ihre Bedürfnisse und Erwartungen an das

Attribut	29.05.26	01.07.26
		Informationssicherheitsmanagement der Institution analysieren.
Thema	GC.4 Festlegung des Geltungsbereichs	GC.4 Stakeholder
Titel	Festlegung des Geltungsbereichs	Analyse der externen interessierten Parteien
UUID	ebff4c7b-77b1-4d08-bc57-37d3ca16242c (gleich GC.6.1 UUID vom 01.07.26)	834c85a0-f793-4d6a-8eba-5f26f38979cd (gleich GC.3.1 UUID vom 29.05.26)
Verwandte		#GC.4.2

GC.5.1 Festlegung von Zielen für die Informationssicherheit (normal-SdT)

Attribut	29.05.26	01.07.26
Abhängigkeit		#GC.4.2, #GC.4.1, #GC.2.2, #GC.2.1
Dokumentation		Informationssicherheitsstrategie
Ergebnis	ein Verfahren für die Festlegung von Geschäftsprozessen und die Einstufung des Schutzbedarfs	konkrete und messbare Ziele für die Informationssicherheit
Handlungswort	verankern	festlegen
Hinweis	Die [- Informationssicherheitseinstufung dient -] der [- systematischen Identifikation des Schutzbedarfs von Geschäftsprozessen -] und [- verarbeiteten Informationen -]. [- Hierbei wird zwischen dem Schutzbedarf „normal“ und „hoch“ unterschieden -]. Der [- prozessorientierte Ansatz stellt -] die [- Verbindung zwischen Geschäftsprozessen und Informationen in -] den [- Vordergrund -].	Die [+ Ziele sollten Bezug zu den Geschäftszielen +] der [+ Institution aufweisen +] und [+ müssen messbar und konkret sein +], [+ z. B. : 98 +]% der [+ aktiven Endgeräte im Netzwerk der Institution verfügen über eine aktuelle Antivirensoftware, deren Signaturdatenbank nicht älter als 24 Stunden ist . +] Die [+ Ziele sollten die Anforderungen der interessierten Parteien sowie +] den [+ Kontext berücksichtigen +].
Präzisierung	dieser Geschäftsprozesse und den hierbei verarbeiteten Informationen	auf Basis der identifizierten Rahmenbedingungen
Text	Governance und Compliance MUSS ein Verfahren für die Festlegung von Geschäftsprozessen und die Einstufung des Schutzbedarfs dieser Geschäftsprozesse und den hierbei verarbeiteten Informationen verankern.	Governance und Compliance MUSS konkrete und messbare Ziele für die Informationssicherheit auf Basis der identifizierten Rahmenbedingungen festlegen.

Attribut	29.05.26	01.07.26
Thema	GC.5 Prozess der Informationssicherheitseinstufung	GC.5 Informationssicherheitsleitlinie
Titel	Vorgehen bei der Informationssicherheitseinstufung	Festlegung von Zielen für die Informationssicherheit
UUID	bdbc4d9b-c0d7-4f5a-8e07-ba12b4049625 (gleich GC.7.1 UUID vom 01.07.26)	551fec73-dce4-4f34-b41d-555142b09cf7 (gleich GC.6.1 UUID vom 29.05.26)
Verbesserung	GC.5.1.1, GC.5.1.2, GC.5.1.3	GC.5.1.1, GC.5.1.2, GC.5.1.3, GC.5.1.4

GC.5.1.1 Festlegung einer Sicherheitsstrategie (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	0	3
Dokumentation	Geschäftsprozesse	Informationssicherheitsstrategie
Ergebnis	die Geschäftsprozesse	eine grundlegende Strategie zur Erreichung der Ziele für die Informationssicherheit
Hinweis	[- Hierbei kann oft auf bestehende Prozesslandkarten -] und [- Managementsysteme zurückgegriffen werden -]. [- Besteht noch keine Prozessübersicht in der Institution , so können die technischen und organisatorischen Praktiken als Ausgangsvorschlag für relevante Hilfsprozesse herangezogen werden (siehe Prozessschritt 2 - Anforderungsanalyse) -]	[+ Die Sicherheitsstrategie legt fest , wie die Organisation die Ziele erreichen möchte +] und [+ fokussiert insbesondere den übergeordneten Ansatz und die Prinzipien +].
Präzisierung	die für den Geltungsbereich relevant sind	gemeinsam mit der Institutionsleitung
Text	Governance und Compliance MUSS die Geschäftsprozesse die für den Geltungsbereich relevant sind festlegen.	Governance und Compliance MUSS eine grundlegende Strategie zur Erreichung der Ziele für die Informationssicherheit gemeinsam mit der Institutionsleitung festlegen.
Thema	GC.5 Prozess der Informationssicherheitseinstufung	GC.5 Informationssicherheitsleitlinie
Titel	Festlegung der Geschäftsprozesse	Festlegung einer Sicherheitsstrategie

Attribut	29.05.26	01.07.26
UUID	b75cea5b-dc1e-4b96-b34a-5053242dabc1 (gleich GC.7.1.1 UUID vom 01.07.26)	a13fb400-1756-4708-b212-502d284c4308 (gleich GC.6.1.1 UUID vom 29.05.26)
Verwandte	#GC.4.1	

GC.5.1.2 Verpflichtung der Institutionsleitung (normal-SdT)

Attribut	29.05.26	01.07.26
Abhängigkeit	#GC.5.1.1	
Dokumentation	Schutzbedarfsfeststellung	Leitungsentscheidung
Ergebnis	eine Einstufung des Schutzbedarfs der relevanten Geschäftsprozesse und Informationsarten	die Verpflichtung der Institutionsleitung
Handlungswort	festlegen	zuweisen
Hinweis	[- Das Ergebnis -] der [- Schutzbedarfsfeststellung ist eine Übersicht des Schutzbedarfs -] der [- zu verarbeitenden Informationen , sowie der Relevanz der Geschäftsprozesse -]. Die [- Einstufung erfolgt dabei in den Stufen „ normal “ oder „ hoch “ -]. Die [- Einstufung richtet sich nach -] der [- Bedeutung -] des [- Geschäftsprozess für -] die [- Geschäftsziele oder den gesetzlichen Auftrag -] der [- Institution -]. [- Priorität für die weitere Abarbeitung hat zunächst der wichtigste Geschäftsprozess , d . h . derjenige Geschäftsprozess , dessen Informationsschutz für den Fortbestand der Institution von essentieller Bedeutung ist . Die Entscheidung darüber , welcher Geschäftsprozess am wichtigsten ist , obliegt der Institutionsleitung . Droht bei einer Verletzung der Vertraulichkeit , Integrität oder Verfügbarkeit von Informationen in diesem Geschäftsprozess ein existenzbedrohender finanzieller oder existenzbedrohender	[+ Die Verpflichtung +] der [+ Institutionsleitung beinhaltet die Übernahme +] der [+ Gesamtverantwortung +], die [+ Bestätigung und Überwachung der Informationssicherheitsziele bezüglich der Organisationsziele und die Förderung des ISMS +]. Die [+ Förderung des ISMS erfolgt durch Beteiligung (z . B . Führungsentscheidungen) , Bestätigung +] der [+ Informationssicherheitsorganisation , Unterstützung der Integration +] des [+ ISMS , Bereitstellung von Ressourcen (z . B . finanzielle , personelle , technische , infrastrukturelle) und +] die [+ Unterstützung +] der [+ kontinuierlichen Verbesserung +].

Attribut	29.05.26	01.07.26
	Reputationsschaden , so ist der Schutzbedarf des Prozesses als hoch einzustufen . Das gleiche gilt , wenn innerhalb eines Geschäftsprozesses Informationen verarbeitet werden , die als besonders vertraulich eingestuft werden . -]	
Präzisierung	unter Berücksichtigung der Geschäftsziele und in Absprache mit der Institutionsleitung	
Tags		Führungsverantwortung
Text	Governance und Compliance MUSS eine Einstufung des Schutzbedarfs der relevanten Geschäftsprozesse und Informationsarten unter Berücksichtigung der Geschäftsziele und in Absprache mit der Institutionsleitung festlegen.	Governance und Compliance MUSS die Verpflichtung der Institutionsleitung zuweisen.
Thema	GC.5 Prozess der Informationssicherheitseinstufung	GC.5 Informationssicherheitsleitlinie
Titel	Festlegung des Schutzbedarfs	Verpflichtung der Institutionsleitung
UUID	7a951196-bf44-463f-91b6-8cf140c97e4c (gleich GC.7.1.2 UUID vom 01.07.26)	8b3ae6fa-4bd0-4d81-babe-7792c63b9989 (gleich GC.6.1.2 UUID vom 29.05.26)

GC.5.1.3 Erstellung einer Sicherheitsleitlinie (normal-SdT)

Attribut	29.05.26	01.07.26
Abhängigkeit	#GC.5.1.2	
Dokumentation	Risikobewertung	Informationssicherheitsleitlinie
Ergebnis	eine dedizierte Risikobetrachtung von Geschäftsprozessen oder Informationsarten mit hohem Schutzbedarf	eine für die Institution passende Sicherheitsleitlinie
Handlungswort	ausführen	festlegen
Hinweis	[- In einem separaten Dokument -] zur [- Risikobetrachtung werden verbindliche Vorgaben an die Risikomethodik vorgeschrieben -].	[+ Die Sicherheitsleitlinie dient als zentrale Weisung und als Orientierung für alle sicherheitsrelevanten Entscheidungen und Aktivitäten und fördert ein gemeinsames Verständnis der Bedeutung und Ausrichtung der Informationssicherheit . Die Leitlinie für

Attribut	29.05.26	01.07.26
		Informationssicherheit enthält insbesondere die Gesamtverantwortung und Verpflichtung der Institutionsleitung , Informationssicherheitsziele , eine Informationssicherheitsstrategie , die Benennung der Rollen und Zuständigkeiten sowie die Verpflichtung +] zur [+ kontinuierlichen Verbesserung +].
Text	Governance und Compliance MUSS eine dedizierte Risikobetrachtung von Geschäftsprozessen oder Informationsarten mit hohem Schutzbedarf ausführen.	Governance und Compliance MUSS eine für die Institution passende Sicherheitsleitlinie festlegen.
Thema	GC.5 Prozess der Informationssicherheitseinstufung	GC.5 Informationssicherheitsleitlinie
Titel	Geschäftsprozesse mit hohem Schutzbedarf	Erstellung einer Sicherheitsleitlinie
UUID	c86010f0-6e07-429a-a203-529ebdc6c99a (gleich GC.7.2 UUID vom 01.07.26)	af7b68e3-ac36-4876-a1ea-80d38407f1c1 (gleich GC.6.1.3 UUID vom 29.05.26)

GC.6.1 Festlegung des Geltungsbereichs (normal-SdT)

Attribut	29.05.26	01.07.26
Abhängigkeit		#GC.4.2, #GC.4.1, #GC.2.2, #GC.2.1
Dokumentation	Informationssicherheitsstrategie	
Ergebnis	konkrete und messbare Ziele für die Informationssicherheit	den nachvollziehbar abgegrenzten Geltungsbereich
Hinweis	[- Die Ziele sollten Bezug zu -] den [- Geschäftszielen der Institution aufweisen -] und [- müssen messbar -] und [- konkret sein -], [- z -]. [- B -]. [- : 98 % der aktiven Endgeräte im Netzwerk der Institution verfügen über eine aktuelle Antivirensoftware , deren Signaturdatenbank nicht älter als 24 Stunden ist . Die Ziele sollten die Anforderungen der interessierten Parteien sowie den Kontext berücksichtigen . -]	[+ Der Geltungsbereich legt +] den [+ formalen +] und [+ organisatorischen Umfang (Scope) fest , in dem das ISMS angewendet wird . Es wird festgelegt , welche Institutionsbereiche +] und [+ Tätigkeiten formell zum Geltungsbereich gehören und infrastrukturell abgegrenzt +], [+ welche Standorte und Systeme innerhalb des Geltungsbereichs liegen +]; [+ welche externen Partner oder Dienstleister in das

Attribut	29.05.26	01.07.26
		ISMS einzubeziehen sind und welche Bereiche bewusst nicht Bestandteil des Geltungsbereichs sind +].
Präzisierung	auf Basis der identifizierten Rahmenbedingungen	nach Freigabe der Institutionsleitung
Text	Governance und Compliance MUSS konkrete und messbare Ziele für die Informationssicherheit auf Basis der identifizierten Rahmenbedingungen festlegen.	Governance und Compliance MUSS den nachvollziehbar abgegrenzten Geltungsbereich nach Freigabe der Institutionsleitung festlegen.
Thema	GC.6 Entwicklung einer Sicherheitsleitlinie	GC.6 Geltungsbereich
Titel	Festlegung von Zielen für die Informationssicherheit	Festlegung des Geltungsbereichs
UUID	551fec73-dce4-4f34-b41d-555142b09cf7 (gleicht GC.5.1 UUID vom 01.07.26)	ebff4c7b-77b1-4d08-bc57-37d3ca16242c (gleicht GC.4.1 UUID vom 29.05.26)
Verbesserung	GC.6.1.1, GC.6.1.2, GC.6.1.3, GC.6.1.4	

GC.7.1 Vorgehen bei der Informationssicherheitseinstufung (normal-SdT)

Attribut	29.05.26	01.07.26
Dokumentation	Compliance-Verpflichtungen	
Ergebnis	ein Verfahren zur Sammlung, Integration und Priorisierung aller für das Informationssicherheitsmanagement relevanten Rahmenbedingungen	ein Verfahren für die Festlegung von Geschäftsprozessen und die Einstufung des Schutzbedarfs
Hinweis	[- Das Compliance Management -] stellt [- sicher , dass alle gesetzlichen , regulatorischen -] und [- vertraglichen Verpflichtungen im Bereich der Informationssicherheit eingehalten werden . Identifizieren , überwachen und bewerten Sie Verpflichtungen , um rechtliche Konsequenzen , finanzielle Verluste oder Reputationsschäden zu vermeiden . Aufgrund der hohen Komplexität des modernen Rechts ist für die Rechtspflege eine eigene Rechtsabteilung oder die Beauftragung von Mitgliedern der rechtsberatenden	[+ Die Informationssicherheitseinstufung dient der systematischen Identifikation des Schutzbedarfs von Geschäftsprozessen und verarbeiteten Informationen . Hierbei wird zwischen dem Schutzbedarf „ normal “ und „ hoch “ unterschieden . Der prozessorientierte Ansatz +] stellt [+ die Verbindung zwischen Geschäftsprozessen +] und [+ Informationen in den Vordergrund +] . Die [+ konkrete Ausgestaltung dieses

Attribut	29.05.26	01.07.26
	Berufe zweckmäßig -]. Die [- bei -] der [- Festlegung des Verfahrens im Einzelnen zu berücksichtigenden Inhalte ergeben sich aus den Anforderungen dieser Praktik -].	Verfahrens obliegt +] der [+ Instution +] ([+ - sleitung) . +]
Präzisierung		dieser Geschäftsprozesse oder den hierbei verarbeiteten Informationen
Tags	Compliance Management	
Text	Governance und Compliance MUSS ein Verfahren zur Sammlung, Integration und Priorisierung aller für das Informationssicherheitsmanagement relevanten Rahmenbedingungen verankern.	Governance und Compliance MUSS ein Verfahren für die Festlegung von Geschäftsprozessen und die Einstufung des Schutzbedarfs dieser Geschäftsprozesse oder den hierbei verarbeiteten Informationen verankern.
Thema	GC.7 Implementierung des Compliance-Managements	GC.7 Infomationssicherheitseinstufung
Titel	Verfahren und Regelungen	Vorgehen bei der Infomationssicherheitseinstufung
UUID	de07bcb3-2a0b-44d4-bd3f-eca08ce44992 (gleich GC.3.1 UUID vom 01.07.26)	bdbc4d9b-c0d7-4f5a-8e07-ba12b4049625 (gleich GC.5.1 UUID vom 29.05.26)
Verbesserung	GC.7.1.1, GC.7.1.2, GC.7.1.3, GC.7.1.4	GC.7.1.1, GC.7.1.2
Verwandte	#PERF.2.1	

GC.7.1.1 Festlegung der Geschäftsprozesse (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	3	0
Dokumentation	Compliance-Verpflichtungen	Geschäftsprozesse
Ergebnis	die Analyse der gesetzlichen Verpflichtungen, welche die Verarbeitung von Informationen durch die Institution betreffen,	die Geschäftsprozesse oder Informationen
Handlungswort	ausführen	festlegen
Hinweis	[- Gesetzliche Verpflichtungen -], [- welche -] die [- Verarbeitung von Informationen durch die Institution betreffen -], [- sind dokumentiert -]. [-	[+ Hierbei kann oft auf bestehende Prozesslandkarten und Managementsysteme zurückgegriffen werden +]. [+ Besteht noch keine

Attribut	29.05.26	01.07.26
	Gesetzliche Verpflichtungen meint alle Pflichten -], [- die sich unmittelbar aus dem Recht ergeben -], [- inklusive des Verfassungsrechts , Europarechts und Verordnungen . Relevante gesetzliche Verpflichtungen können sich je nach Institution z . B . aus Grundrechten , Cyber Resilience Act , Data Act , Data Markets Act , NIS , DSGVO , BDSG , TKG , TDDDG oder GeschGehG ergeben . Beachten Sie dabei auch Verpflichtungen , die sich mittelbar auswirken wie die Arbeitsstättenverordnung oder allgemeine Regelungen zur Fürsorgepflicht . -]	Prozessübersicht in der Institution , so können +] die [+ technischen und organisatorischen Praktiken als Ausgangsvorschlag für relevante Prozesse herangezogen werden +] ([+ siehe Prozessschritt 2 +]- [+ Anforderungsanalyse +]).
Modalverb	SOLLTE	MUSS
Präzisierung		die für den Geltungsbereich relevant sind
Tags	Compliance Management, Inventories	
Text	Governance und Compliance SOLLTE die Analyse der gesetzlichen Verpflichtungen, welche die Verarbeitung von Informationen durch die Institution betreffen, ausführen.	Governance und Compliance MUSS die Geschäftsprozesse oder Informationen die für den Geltungsbereich relevant sind festlegen.
Thema	GC.7 Implementierung des Compliance-Managements	GC.7 Informationssicherheitseinstufung
Titel	Gesetzliche Verpflichtungen	Festlegung der Geschäftsprozesse
UUID	02747a0f-cd38-4815-9eec-351ae89dbdfe (gleicht GC.3.1.1 UUID vom 01.07.26)	b75cea5b-dc1e-4b96-b34a-5053242dabc1 (gleicht GC.5.1.1 UUID vom 29.05.26)
Verwandte		#GC.6.1

GC.7.1.2 Festlegung des Schutzbedarfs (normal-SdT)

Attribut	29.05.26	01.07.26
Abhängigkeit		#GC.7.1.1
Aufwand	3	0
Dokumentation	Compliance-Verpflichtungen	Schutzbedarfsfeststellung
Ergebnis	für die Einhaltung gesetzlicher Verpflichtungen in der Informationsverarbeitung	eine Einstufung des Schutzbedarfs der relevanten Geschäftsprozesse oder Informationen

Attribut	29.05.26	01.07.26
	zuständige Stellen in der Institution	
Handlungswort	anhören	festlegen
Hinweis	Für die [- Einhaltung gesetzlicher Verpflichtungen in der Informationsverarbeitung zuständige Stellen in -] der Institution [- wurden -] bei der [- Dokumentation -] der [- Compliance -] [- Verpflichtungen angehört -]. [- Hierunter können z -]. [- B -]. [- Rechtsabteilung -], [- Datenschutzbeauftragte , Brandschutzbeauftragte oder Fachverantwortliche bei branchenspezifischen Vorschriften fallen . -]	[+ Das Ergebnis der Schutzbedarfsfeststellung ist eine Übersicht des Schutzbedarfs der zu verarbeitenden Informationen , sowie der Relevanz der Geschäftsprozesse . Die Einstufung erfolgt dabei in den Stufen „ normal “ oder „ hoch “ . Die Einstufung richtet sich nach der Bedeutung des Geschäftsprozess +] für die [+ Geschäftsziele oder den gesetzlichen Auftrag +] der Institution [+ . Priorität für die weitere Abarbeitung hat zunächst der wichtigste Geschäftsprozess , d . h . derjenige Geschäftsprozess , dessen Informationsschutz für den Fortbestand der Institution von essentieller Bedeutung ist . Die Entscheidung darüber , welcher Geschäftsprozess am wichtigsten ist , obliegt der Institutionsleitung . Droht +] bei [+ einer Verletzung +] der [+ Vertraulichkeit , Integrität oder Verfügbarkeit von Informationen in diesem Geschäftsprozess ein existenzbedrohender finanzieller oder existenzbedrohender Reputationsschaden oder sind folgenschwere Auswirkungen einer Verletzung +] der [+ Sicherheitsziele auf die Geschäftsziele oder bestehende Verpflichtungen zu befürchten +], [+ so ist der Schutzbedarf des Prozesses als hoch einzustufen +]. [+ Das gleiche gilt +], [+ wenn innerhalb eines Geschäftsprozesses Informationen verarbeitet werden +], [+ die als besonders vertraulich eingestuft werden +].
Modalverb	SOLLTE	MUSS
Präzisierung		unter Berücksichtigung der Geschäftsziele und in Absprache mit der Institutionsleitung
Tags	Compliance Management	
Text	Governance und Compliance SOLLTE für die Einhaltung gesetzlicher Verpflichtungen in der Informationsverarbeitung	Governance und Compliance MUSS eine Einstufung des Schutzbedarfs der relevanten Geschäftsprozesse oder Informationen unter Berücksichtigung der Geschäftsziele und in Absprache mit der Institutionsleitung festlegen.

Attribut	29.05.26	01.07.26
	zuständige Stellen in der Institution anhören.	
Thema	GC.7 Implementierung des Compliance-Managements	GC.7 Informationssicherheitseinstufung
Titel	Anhörung zuständiger Stellen	Festlegung des Schutzbedarfs
UUID	3d677306-5748-405a-b5f3-cdc2939e7d14 (gleich GC.3.1.2 UUID vom 01.07.26)	7a951196-bf44-463f-91b6-8cf140c97e4c (gleich GC.5.1.2 UUID vom 29.05.26)

GC.8.1 Verfahren zur Ressourcenplanung (normal-SdT)

Attribut	29.05.26	01.07.26
Thema	GC.8 Sicherheitsorganisation und Rollen	GC.8 Ressourcen
Verbesserung	GC.8.1.1, GC.8.1.1.1, GC.8.1.1.1.1, GC.8.1.2, GC.8.1.3, GC.8.1.4, GC.8.1.5, GC.8.1.6	
Verwandte	#GC.6.1.2	#GC.5.1.2

GC.9.1 Festlegung einer Sicherheitsorganisation (normal-SdT)

Attribut	29.05.26	01.07.26
Dokumentation	Übersicht der Kommunikationspartner	Sicherheitsorganisation
Ergebnis	ein Verfahren zum Kommunikationsmanagement	die Sicherheitsorganisation für das ISMS
Handlungswort	verankern	festlegen
Hinweis	[- Für -] die [- relevante Kommunikation im Rahmen -] eines ISMS [- sind die Eckpunkte (wer , wann , mit wem , wie) festgelegt . Dies beinhaltet ebenfalls die Identifikation der relevanten Behörden und der relevanten Kontakte -] sowie die [- Festlegung von Zuständigkeiten für -] die [- Kommunikation -].	

[+ Ziel der Sicherheitsorganisation ist es , +] die [+ relevanten Bereiche +] eines ISMS sowie die [+ relevanten Schnittstellen zu anderen Bereichen (z . B . Datenschutz , physische Sicherheit , Geheimschutz oder Arbeitsschutz) vollständig und wirksam in der Institution zu verankern . +] Die [+ Sicherheitsorganisation sollte in einem Organigramm oder einer ähnlichen Darstellung zu dokumentiert und abgebildet werden +].

Attribut	29.05.26	01.07.26
Präzisierung	hinsichtlich der internen und externen Kommunikation	unter Einbezug von Rollen, Zuständigkeiten sowie Gremien
Text	Governance und Compliance MUSS ein Verfahren zum Kommunikationsmanagement hinsichtlich der internen und externen Kommunikation verankern.	Governance und Compliance MUSS die Sicherheitsorganisation für das ISMS unter Einbezug von Rollen, Zuständigkeiten sowie Gremien festlegen.
Thema	GC.9 Dokumentation und Kommunikation	GC.9 Sicherheitsorganisation
Titel	Festlegung eines Verfahrens zum Kommunikationsmanagement	Festlegung einer Sicherheitsorganisation
UUID	b7947004-8b4e-4b64-b73f-df1e790bed19 (gleicht GC.10.1 UUID vom 01.07.26)	56907e29-773a-4339-8166-785b68f9c065 (gleicht GC.8.1.4 UUID vom 29.05.26)
Verbesserung	GC.9.1.1, GC.9.1.2, GC.9.1.3	GC.9.1.1, GC.9.1.1.1, GC.9.1.1.1.1, GC.9.1.1.1.2, GC.9.1.1.2, GC.9.1.1.3, GC.9.1.1.4

GC.9.1.1 Festlegung von Rollen und Zuständigkeiten (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	4	0
Dokumentation		Tätigkeits- & Rollenbeschreibung
Ergebnis	einen externen Austausch zur Informationssicherheit	die {{Rollen und Zuständigkeiten}} im Rahmen des ISMS
Handlungswort	ausführen	zuweisen
Hinweis	[- Um auch andere Perspektiven wahrzunehmen -] und [- Eindrücke zu erhalten -] , [- findet ein externer Austausch statt -] . [- Hierzu können beispielsweise Branchenverbände -] , [- Fachforen oder andere Einrichtungen genutzt werden -] .	[+ Im Rahmen des ISMS werden die Rollen hinsichtlich der Aufgaben , der dafür notwendigen Qualifikation +] und [+ der notwendigen Befugnisse festgelegt +] . [+ Eine zentrale Rolle wäre beispielsweise der +] "[+ Informationssicherheitsbeauftragte +]" ([+ ISB] . +])
Modalverb	SOLLTE	MUSS
Parameter		{'gc.9.1.1-prm1': 'Rollen und Zuständigkeiten'}
Präzisierung		inklusive ihrer Kompetenzen bzw. Befugnisse

Attribut	29.05.26	01.07.26
Text	Governance und Compliance SOLLTE einen externen Austausch zur Informationssicherheit ausführen.	Governance und Compliance MUSS die {{ insert: param, gc.9.1.1-prm1 }} im Rahmen des ISMS inklusive ihrer Kompetenzen bzw. Befugnisse zuweisen.
Thema	GC.9 Dokumentation und Kommunikation	GC.9 Sicherheitsorganisation
Titel	Externer Austausch zur Informationssicherheit	Festlegung von Rollen und Zuständigkeiten
UUID	4fb02efc-1b80-497d-af10-77433319be96 (gleich GC.10.1.1 UUID vom 01.07.26)	5cc59bb1-af0d-457f-a548-03373447fec7 (gleich GC.8.1.1 UUID vom 29.05.26)
Verbesserung		GC.9.1.1.1, GC.9.1.1.1.1, GC.9.1.1.1.2, GC.9.1.1.2, GC.9.1.1.3, GC.9.1.1.4

GC.10.1 Festlegung eines Verfahrens zum Kommunikationsmanagement (normal-SdT)

Attribut	29.05.26	01.07.26
Dokumentation	ISMS-Regelwerk	Übersicht der Kommunikationspartner
Ergebnis	die Verfahren des ISMS sowie die Zuständigkeiten	ein Verfahren zum Kommunikationsmanagement
Handlungswort	festlegen	verankern
Hinweis	Der [- Umfang der Dokumentation der Verfahren ist der Größe und Komplexität der Institution angemessen -]. [- Die Verfahren beinhalten insbesondere die Risikobetrachtung , die Etablierung von Änderungen im ISMS , die Dokumentenlenkung , die Leistungsbewertung und Auditierung , kontinuierliche Verbesserung sowie reaktive Verfahren (Sicherheitsvorfallbehandlung , Notfallmanagement -)]. [- In kleineren Institutionen kann dies beispielsweise in einem Dokument erfolgen -]. [- In größeren Institutionen kann die Etablierung von Prozessen hierfür erforderlich sein . -]	[+ Für die relevante Kommunikation im Rahmen eines ISMS werden die Eckpunkte (wer , wann , mit wem , wie) festgelegt . Dies beinhaltet ebenfalls die Identifikation +] der [+ relevanten +] ([+ Aufsichts +]-) [+ Behörden und der relevanten Kontakte sowie die Festlegung von Zuständigkeiten für die Kommunikation +].
Präzisierung		hinsichtlich der internen und externen Kommunikation

Attribut	29.05.26	01.07.26
Text	Governance und Compliance MUSS die Verfahren des ISMS sowie die Zuständigkeiten festlegen.	Governance und Compliance MUSS ein Verfahren zum Kommunikationsmanagement hinsichtlich der internen und externen Kommunikation verankern.
Thema	GC.10 Festlegung und Freigabe der Vorgehensweise	GC.10 Kommunikation
Titel	Festlegung von Vorgehensweisen	Festlegung eines Verfahrens zum Kommunikationsmanagement
UUID	4b2b03f6-103d-4435-9edc-27cd961e2361	b7947004-8b4e-4b64-b73f-df1e790bed19 (gleich GC.9.1 UUID vom 29.05.26)
Verbesserung		GC.10.1.1, GC.10.1.2
Verwandte	#GC.11.1	

GC.11.1 Dokumentenlenkung (normal-SdT)

Attribut	29.05.26	01.07.26
Dokumentation	Risikobewertung	Richtlinie zur Lenkung von Dokumenten und Aufzeichnungen
Ergebnis	eine einheitliche Methodik für das Informationssicherheitsrisikomanagement	ein Verfahren zur Lenkung der Dokumente im Rahmen des ISMS
Hinweis	Das [- Risikomanagement -] stellt sicher, [- dass Risiken systematisch identifiziert -] , [- eingeschätzt -] , [- bewertet -] und [- behandelt werden -] . [- Die Festlegung einheitlicher Kriterien für -] , [- Risikoeinschätzung , Risikobewertung und Risikobehandlung , sowie die Rolle des Risikoeigentümers sorgen für Transparenz und Verbindlichkeit . Die Risikomanagementmethodik kann frei gewählt werden . In einem separaten Dokument zur Risikobetrachtung werden verbindliche Vorgaben an die Risikomethodik vorgeschrieben . Die Vorgaben sind entsprechend gängiger Risikomanagement - Prozesse strukturiert . -]	[+ Ziel eines Verfahrens zur Dokumentenlenkung ist die Sicherstellung der Nachvollziehbarkeit von Dokumenten . +] Das [+ Verfahren +] stellt [+ hierbei die Nachvollziehbarkeit über den gesamten Lebenszyklus des Dokuments +] sicher. [+ Dies beinhaltet die Erstellung bzw +] . [+ Übernahme +] ([+ z . B . aus "Alt - Dokumenten " oder externen Dokumenten) der Dokumente mit Titel , Autor , Dokumenteneigentümer , Sicherheitsklassifikation , Erstelldatum sowie einheitlicher Formate . Des Weiteren

Attribut	29.05.26	01.07.26
		beinhaltet dies die Steuerung mit einem Änderungsmanagement (Versionierung) , einer einheitlichen Veröffentlichung , einer angemessen geschützten Ablage +] und [+ ggf +]. [+ auch Archivierung sowie einer Rücknahme +].
Präzisierung	auf Basis des Kontextes der Institution und der Anforderungen interessierter Parteien sowie der daraus hergeleiteten Risikoziele	über ihren kompletten Lebenszyklus hinweg
Text	Governance und Compliance MUSS eine einheitliche Methodik für das Informationssicherheitsrisikomanagement auf Basis des Kontextes der Institution und der Anforderungen interessierter Parteien sowie der daraus hergeleiteten Risikoziele verankern.	Governance und Compliance MUSS ein Verfahren zur Lenkung der Dokumente im Rahmen des ISMS über ihren kompletten Lebenszyklus hinweg verankern.
Thema	GC.11 Initiierung des Risikomanagements	GC.11 Dokumentenlenkung
Titel	Methodik für das Risikomanagement	Dokumentenlenkung
UUID	0567f921-f474-4060-9a64-11e5148ebe09 (gleicht GC.12.1 UUID vom 01.07.26)	9cc14941-253d-4bfa-89f6-8902370cc509 (gleicht GC.9.1.3 UUID vom 29.05.26)
Verwandte	#GC.10.1	

GEB.3.3 Authentifizierung vor Zutritt (normal-SdT)

Attribut	29.05.26	01.07.26
Verwandte	#BER.6.4, #DET.3.1.1	#BER.5.4, #DET.3.1.1

KONF.11.3 Veröffentlichung von Domain-Infomationen (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	5	3
Ergebnis	ein ebenso vertrauenswürdigen, alternatives Verfahren zur Authentifizierung	die Veröffentlichung von Domain-Infomationen
Handlungswort	aktivieren	einschränken
Hinweis	Wenn [- Nutzende ihren Primärzugang -] (z. B. [- Passwort -], [- Smartphone mit	[+ Angreifer nutzen häufig DNS um das Netz zu erkunden (DNS -

Attribut	29.05.26	01.07.26
	Authentifizierungs -] [- App -]) [- nicht mehr haben -], [- wird eine alternative Möglichkeit zur Authentifizierung benötigt -]. [- Damit dieser Alternativzugang den Schutz der Primärmethode nicht aushebelt , ist eine vergleichbare Zuverlässigkeit der Authentifizierung erforderlich . Lösungsmöglichkeiten je nach Schutzbedarf sind z . B -]. ([- 1) ein Einmalpasswort , dass an die hinterlegte E - Mailadresse versendet wird , (2) die persönliche Vorstellung mit Ausweis , (3) die Verifikation über bestehende Sitzungen , (4) Rückfallantworten wie Sicherheitsfragen oder PUK . -]	Reconnaissance) . Veröffentlichen Sie Domain - Informationen nur , +] wenn [+ diese zu einem Dienst gehören +], [+ der zur externen Nutzung gedacht ist . Nur intern benötigte DNS - Einträge dagegen bleiben intern . Kriterien können +] z. B. [+ Domains oder Subdomain sein +] ([+ intern +]. [+ domain +]. [+ com vs www +]. [+ domain +]. [+ com +]).
Modalverb	KANN	SOLLTE
Parameter		{'konf.11.3-prm1': 'Kriterien'}
Präzisierung		anhand von {{Kriterien}}
Sicherheitsniveau	erhöht	normal-SdT
Tags	Produktbeschreibung	Produktbeschreibung, Data Leak, Recon
Text	Konfiguration für Anwendungen KANN ein ebenso vertrauenswürdiges, alternatives Verfahren zur Authentifizierung aktivieren.	Konfiguration für DNS-Server SOLLTE die Veröffentlichung von Domain-Infomationen anhand von {{ insert: param, konf.11.3-prm1 }} einschränken.
Titel	Alternative Authentifizierung	Veröffentlichung von Domain-Infomationen
UUID	7d8e0d79-751c-4afe-bbe5-124004f01577 (gleicht BER.3.24 UUID vom 01.07.26)	24d7bd4d-9ae9-4871-b6da-4c5186351b46 (gleicht KONF.11.4 UUID vom 29.05.26)
Zielobjekte	Anwendungen	DNS-Server

KONF.11.4 Erraten von Zugriffslinks (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	3	4

Attribut	29.05.26	01.07.26
Ergebnis	die Veröffentlichung von Domain-Infomationen	das Durchprobieren von Zugriffslinks
Handlungswort	einschränken	blockieren
Hinweis	Angreifer [- nutzen häufig DNS um das Netz zu erkunden (DNS - Reconnaissance) . Veröffentlichen Sie Domain - Informationen nur , wenn - diese zu [- einem Dienst gehören -], [- der zur externen Nutzung gedacht ist . Nur intern benötigte DNS - Einträge dagegen bleiben intern . Kriterien können - z. B. [- Domains -] oder [- Subdomain sein -] ([- intern -]. [- domain -]. [- com vs www -]. [- domain -]. [- com -]).	[+ Ermöglichen Links den Zugriff auf vertrauliche Daten ohne Authentifizierung , so könnten +] Angreifer [+ versuchen +] diese zu [+ finden +], z. B. [+ mit Durchprobieren von Meeting - Links +] oder [+ Ressourcen +]- [+ URLs +]. [+ Mögliche Maßnahmen sind Nicht +]- [+ Sequentielle IDs mit hoher Entropie +], [+ Rate Limiting von Anfragen oder CAPTCHA +]. [+ Hierbei bietet sich eine Kombination von Maßnahmen an +], [+ die Anzahl erwarteter Zugriffe +], [+ Verfügbarkeits - und Usability - Kriterien ebenso beachtet wie das Risikoprofil der Anwendung . Bietet die Webanwendung keinerlei Zugriff auf schützenswerte Informationen ohne Authentifizierung , so ist die Anforderung entbehrlich . +]
Parameter	{'konf.11.4-prm1': 'Kriterien'}	{'konf.11.4-prm1': 'einen automatisierten Mechanismus'}
Präzisierung	anhand von {{Kriterien}}	durch {{einen automatisierten Mechanismus}}
Tags	Produktbeschreibung, Data Leak, Recon	Produktbeschreibung, Brute-Force-Attacke
Text	Konfiguration für DNS-Server SOLLTE die Veröffentlichung von Domain-Infomationen anhand von {{insert: param, konf.11.4-prm1 }} einschränken.	Konfiguration für Webanwendungen SOLLTE das Durchprobieren von Zugriffslinks durch {{insert: param, konf.11.4-prm1 }} blockieren.
Titel	Veröffentlichung von Domain-Infomationen	Erraten von Zugriffslinks
UUID	24d7bd4d-9ae9-4871-b6da-4c5186351b46 (gleicht KONF.11.3 UUID vom 01.07.26)	951aea5d-e4c2-47c8-9a21-b1d00e3d499f (gleicht KONF.11.5 UUID vom 29.05.26)
Zielobjekte	DNS-Server	Webanwendungen

KONF.11.5 Einschränkung unauthentifizierter Anschlüsse (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	4	3
Ergebnis	das Durchprobieren von Zugriffslinks	von unauthentifizierten Anschlüssen erreichbare Gegenstellen
Handlungswort	blockieren	einschränken
Hinweis	Ermöglichen [- Links -] den [- Zugriff auf vertrauliche Daten -] ohne [- Authentifizierung -], [- so könnten Angreifer versuchen diese zu finden , z . B . mit Durchprobieren von -] Meeting- [- Links -] oder Ressourcen- [- URLs . Mögliche Maßnahmen sind Nicht - Sequentielle IDs mit hoher Entropie , Rate Limiting von Anfragen oder CAPTCHA . Hierbei bietet sich eine Kombination von Maßnahmen an , die Anzahl erwarteter Zugriffe , Verfügbarkeits - und Usability - Kriterien ebenso beachtet wie das Risikoprofil der Anwendung . Bietet die Webanwendung keinerlei Zugriff auf schützenswerte Informationen ohne Authentifizierung , so ist die Anforderung entbehrlich . -]	[+ Als unauthentifizierte Anschlüsse (engl . unauthenticated connections) sind hier alle Endpunkte zu verstehen , die eine Kommunikation ohne Anmeldung +] ermöglichen [+ . Dies umfasst beispielsweise Notfalltelefone in Aufzügen , öffentlich zugängliche Telefone oder auch Faxgeräte in ungesicherten Bereichen . Aber auch an Konferenzraum - Systeme für Videokonferenzen oder +] den [+ anonymen Gast - Zugang zu Online - Meetings ist zu denken . Die Anforderung zielt darauf ab , den Missbrauch dieser Kommunikationskanäle zu unterbinden , deren Nutzung nicht eindeutig einem authentifizierten Benutzer zugeordnet werden kann . +] Ohne [+ eine Einschränkung der erreichbaren Gegenstellen – also der kontaktierbaren externen Domänen +], Meeting- [+ IDs +] oder [+ Benutzerkonten – könnte ein Angreifer vertrauliche interne Besprechungen ausspähen oder ein unautorisierter Gast könnte von einem Konferenzraum aus sensible Daten per Bildschirmübertragung an externe Dritte weitergeben . Ohne eine solche Einschränkung könnte ein unberechtigter Nutzer auf Kosten der Institution kostenpflichtige Mehrwertdienste oder teure Auslandsnummern anwählen und so erheblichen finanziellen Schaden verursachen . Ebenso könnte eine missbräuchliche Nutzung zur Belästigung Dritter oder zur Absetzung von böswilligen Notrufen erfolgen , was die Verfügbarkeit kritischer +] Ressourcen [+ beeinträchtigen könnte +].
Parameter	{'konf.11.5-prm1': 'einen automatisierten Mechanismus'}	

Attribut	29.05.26	01.07.26
Präzisierung	durch {{einen automatisierten Mechanismus}}	
Tags	Produktbeschreibung, Brute-Force-Attacke	Produktbeschreibung
Text	Konfiguration für Webanwendungen SOLLTE das Durchprobieren von Zugriffslinks durch {{ insert: param, konf.11.5-prm1 }} blockieren.	Konfiguration für TK-Anwendungen SOLLTE von unauthentifzierten Anschlüssen erreichbare Gegenstellen einschränken.
Titel	Erraten von Zugriffslinks	Einschränkung unauthentifizierter Anschlüsse
UUID	951aea5d-e4c2-47c8-9a21-b1d00e3d499f (gleicht KONF.11.4 UUID vom 01.07.26)	09f3cad1-7245-42f4-a62c-e48ce193ce8a (gleicht KONF.11.6 UUID vom 29.05.26)
Zielobjekte	Webanwendungen	TK-Anwendungen

KONF.11.6 Übersicht angemeldeter Verbindungen (erhöht)

Attribut	29.05.26	01.07.26
Aufwand	3	5
Ergebnis	von unauthentifzierten Anschlüssen erreichbare Gegenstellen	eine Übersicht angemeldeter Verbindungen
Handlungswort	einschränken	aktivieren
Hinweis	[- Als unauthentifizierte Anschlüsse -] ([- engl -]. [- unauthenticated connections -]) [- sind hier alle Endpunkte zu verstehen -], [- die eine Kommunikation ohne Anmeldung ermöglichen -]. [- Dies umfasst beispielsweise Notfalltelefone in Aufzügen , öffentlich zugängliche Telefone oder auch Faxgeräte in ungesicherten Bereichen . Aber auch an Konferenzraum - Systeme für Videokonferenzen oder den anonymen Gast - Zugang zu Online - Meetings ist zu denken . Die Anforderung zielt darauf ab , den Missbrauch dieser Kommunikationskanäle zu unterbinden , deren Nutzung nicht eindeutig einem authentifzierten Benutzer zugeordnet werden kann . Ohne eine Einschränkung der erreichbaren Gegenstellen – also der kontaktierbaren externen Domänen , Meeting - IDs oder Benutzerkonten – könnte ein Angreifer vertrauliche	[+ Je nach Anwendung können dabei Informationen wie Gerätename +], [+ Betriebssystemtyp +], [+ Browser +]- [+ Agent oder IP +]- [+ Adresse angezeigt werden +].

Attribut	29.05.26	01.07.26
	interne Besprechungen ausspähen oder ein unautorisierter Gast könnte von einem Konferenzraum aus sensible Daten per Bildschirmübertragung an externe Dritte weitergeben . Ohne eine solche Einschränkung könnte ein unberechtigter Nutzer auf Kosten der Institution kostenpflichtige Mehrwertdienste oder teure Auslandsnummern anwählen und so erheblichen finanziellen Schaden verursachen . Ebenso könnte eine missbräuchliche Nutzung zur Belästigung Dritter oder zur Absetzung von böswilligen Notrufen erfolgen , was die Verfügbarkeit kritischer Ressourcen beeinträchtigen könnte . -]	
Modalverb	SOLLTE	KANN
Sicherheitsniveau	normal-SdT	erhöht
Text	Konfiguration für TK-Anwendungen SOLLTE von unauthentifzierten Anschlüssen erreichbare Gegenstellen einschränken.	Konfiguration für Anwendungen KANN eine Übersicht angemeldeter Verbindungen aktivieren.
Titel	Einschränkung unauthentifzierter Anschlüsse	Übersicht angemeldeter Verbindungen
UUID	09f3cad1-7245-42f4-a62c-e48ce193ce8a (gleicht KONF.11.5 UUID vom 01.07.26)	eca3e9a0-b7b5-4e74-9c3e-1108c268246e (gleicht KONF.11.7 UUID vom 29.05.26)
Zielobjekte	TK-Anwendungen	Anwendungen

KONF.11.7 Einschränkung von Schnittstellen (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	5	3
Ergebnis	eine Übersicht angemeldeter Verbindungen	aktivierte Schnittstellen
Handlungswort	aktivieren	einschränken
Hinweis	[- Je nach -] Anwendung [-	[+ Die Einschränkung von Schnittstellen hilft , ungewollte oder böswillige Zugriffe auf Anwendungen

Attribut	29.05.26	01.07.26
	können dabei Informationen wie Geräte name , Betriebssystemtyp , Browser - Agent oder IP - Adresse angezeigt -] werden.	und Daten zu verhindern . Durch das Festlegen klarer Regeln welche Systeme oder Anwendungen über welche Schnittstellen auf welche Daten zugreifen können wir das "Need to know " Prinzip in der Kommunikation umgesetzt . Ferner kann ein solcher Ansatz dazu beitragen , die Integrität und Vertraulichkeit von Informationen zu wahren , indem nur autorisierte Kommunikationspartner berechtigt werden , Daten zu lesen , zu schreiben oder Funktionalitäten aufzurufen . Beispiele sind die Synchronisierung von Lesezeichen und Historie im Browser , die Anbindung von Cloud - Funktionen , etwa eine serverless Image - Processing - API , für die ein entsprechendes Rollenkonzept noch nicht hinterlegt und von der Sicherheitsverantwortlichen geprüft wurde , oder die Installation einer Browsererweiterungen . Erweiterungen (Plugins , AddOns) , die nicht von der Institution für die Verwendung autorisiert wurden , können zu ungewollten Datenabflüssen führen und Schadcode enthalten . Zur Umsetzung kann es hilfreich sein , standardisierte Formulare oder digitale Workflows zu etablieren , in denen die Notwendigkeit , der Umfang und die Verantwortlichen für jede neue Schnittstelle dokumentiert werden . Die Einschränkung kann auch durch Komponenten außerhalb der +] Anwendung [+ erfolgen , zum Beispiel durch API - Gateways , die nur auf Whitelists registrierter Endpunkte reagieren , oder durch Einsatz von Zertifikaten und OAuth - Scopes . Um unautorisierte Erweiterungen technisch zu unterbinden kann die Deinstallation oder Deaktivierung der Erweiterungen , sowie das Setzen von Berechtigungen zur Installation nur für Administrierende umgesetzt +] werden.
Modalverb	KANN	SOLLTE
Präzisierung		einschließlich denen zu anderen Anwendungen, Cloud-Funktionen oder Erweiterungen
Sicherheitsniveau	erhöht	normal-SdT
Text	Konfiguration für Anwendungen KANN eine Übersicht angemeldeter Verbindungen aktivieren.	Konfiguration für Anwendungen SOLLTE aktivierte Schnittstellen einschließlich denen zu anderen Anwendungen, Cloud-Funktionen oder Erweiterungen einschränken.

Attribut	29.05.26	01.07.26
Titel	Übersicht angemeldeter Verbindungen	Einschränkung von Schnittstellen
UUID	eca3e9a0-b7b5- 4e74-9c3e- 1108c268246e (gleicht KONF.11.6 UUID vom 01.07.26)	e9c7f783-cc8f-499c-b556-8748f9420459 (gleicht KONF.11.8 UUID vom 29.05.26)
Verbesserung		KONF.11.7.1, KONF.11.7.2, KONF.11.7.2.1

KONF.11.8 Verschlüsselung schützenswerter Daten (at-rest) (erhöht)

Attribut	29.05.26	01.07.26
Aufwand	3	5
Ergebnis	aktivierte Schnittstellen	schützenswerte Daten
Handlungswort	einschränken	verschlüsseln
Hinweis	[- Die Einschränkung von Schnittstellen hilft , ungewollte oder böswillige Zugriffe auf Anwendungen und Daten -] zu [- verhindern . Durch das Festlegen klarer Regeln welche Systeme oder Anwendungen über welche Schnittstellen auf welche Daten zugreifen können wir das "Need to know " Prinzip in der Kommunikation umgesetzt . Ferner kann ein solcher Ansatz dazu beitragen -], die [- Integrität -] und [- Vertraulichkeit von Informationen zu wahren , indem nur autorisierte Kommunikationspartner berechtigt werden , Daten zu lesen , zu schreiben oder Funktionalitäten aufzurufen . Beispiele -] sind [- die Synchronisierung von Lesezeichen und Historie im Browser , die Anbindung von Cloud - Funktionen , etwa eine serverless Image - Processing - API , für die ein entsprechendes Rollenkonzept noch nicht hinterlegt und von der Sicherheitsverantwortlichen geprüft wurde , oder die Installation einer Browsererweiterungen . Erweiterungen (Plugins , AddOns) , die nicht von der Institution für die Verwendung autorisiert wurden , können zu ungewollten Datenabflüssen führen und Schadcode enthalten -]. Zur Umsetzung [- kann es hilfreich sein -], [- standardisierte Formulare oder digitale Workflows zu etablieren -], [- in denen die	[+ Hierbei ist insbesondere an Zugangsdaten +] zu [+ denken +]. Die [+ Anforderung ist auch dann erfüllt , wenn Daten statt einer Verschlüsselung mit Hash +] und [+ Salt versehen +] sind. Zur Umsetzung [+ siehe BSI TR +]- [+ 02102 +].

Attribut	29.05.26	01.07.26
	Notwendigkeit , der Umfang und die Verantwortlichen für jede neue Schnittstelle dokumentiert werden . Die Einschränkung kann auch durch Komponenten außerhalb der Anwendung erfolgen , zum Beispiel durch API - Gateways , die nur auf Whitelists registrierter Endpunkte reagieren , oder durch Einsatz von Zertifikaten und OAuth - Scopes . Um unautorisierte Erweiterungen technisch zu unterbinden kann die Deinstallation oder Deaktivierung der Erweiterungen , sowie das Setzen von Berechtigungen zur Installation nur für Administrierende umgesetzt werden . -]	
Modalverb	SOLLTE	KANN
Präzisierung	einschließlich denen zu anderen Anwendungen, Cloud-Funktionen oder Erweiterungen	bei der Speicherung (at-rest)
Sicherheitsniveau	normal-SdT	erhöht
Tags	Produktbeschreibung	Produktbeschreibung, Cryptography
Text	Konfiguration für Anwendungen SOLLTE aktivierte Schnittstellen einschließlich denen zu anderen Anwendungen, Cloud-Funktionen oder Erweiterungen einschränken.	Konfiguration für Anwendungen KANN schützenswerte Daten bei der Speicherung (at-rest) verschlüsseln.
Titel	Einschränkung von Schnittstellen	Verschlüsselung schützenswerter Daten (at-rest)
UUID	e9c7f783-cc8f-499c-b556-8748f9420459 (gleich KONF.11.7 UUID vom 01.07.26)	d3e4416f-e997-4aec-a45b-eade4316d896 (gleich KONF.11.9 UUID vom 29.05.26)
Verbesserung	KONF.11.8.1, KONF.11.8.2, KONF.11.8.2.1	

KONF.12.1 Eingabevalidierung (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	3	1

KONF.13.2 Authentizität von Nachrichten (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	4	2

KONF.13.2.1 Verifikation der Sendeberechtigung (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	3	2

KONF.13.2.2 Verifikation der Serversignatur (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	3	2

PERF.1.1 Verfahren und Regelungen (normal-SdT)

Attribut	29.05.26	01.07.26
Verbesserung	PERF.1.1.1, PERF.1.1.2, PERF.1.1.3, PERF.1.1.4	

PERF.2.1 Überwachung der Einhaltung von Verpflichtungen (normal-SdT)

Attribut	29.05.26	01.07.26
Hinweis	[- Im Rahmen der -] Compliance-Überwachung [- sollte die Einhaltung von Verpflichtungen regelmäßig sowie anlassbezogen überprüft werden . Dies -] umfasst regelmäßige Kontrollen zur Überprüfung der Einhaltung dokumentierter gesetzlicher und vertraglicher Anforderungen, anlassbezogene Überprüfungen bei Änderungen des regulatorischen Umfelds, bei Hinweisen auf mögliche Verstöße oder nach durchgeführten Änderungen in relevanten Systemen oder Prozessen, die Identifikation von Compliance- Lücken und deren systematische Dokumentation sowie die Entwicklung und Umsetzung von Maßnahmen zur Schließung identifizierter Compliance- Lücken.	[+ Die +] Compliance- Überwachung umfasst regelmäßige Kontrollen zur Überprüfung der Einhaltung dokumentierter gesetzlicher und vertraglicher Anforderungen, anlassbezogene Überprüfungen bei Änderungen des regulatorischen Umfelds, bei Hinweisen auf mögliche Verstöße oder nach durchgeführten Änderungen in relevanten Systemen oder Prozessen, die Identifikation von Compliance- Lücken und deren systematische Dokumentation sowie die Entwicklung und Umsetzung von Maßnahmen zur Schließung identifizierter Compliance- Lücken.
Thema	PERF.2 Überwachung der Compliance	PERF.2 Compliance-Management
Verwandte	#GC.7.1, #UMS.7.1	#GC.3.1, #UMS.7.1

PERF.3.1 Aufbau und Pflege eines Auditprogramms (normal-SdT)

Attribut	29.05.26	01.07.26
Thema	PERF.3 Auditprogramm und -durchführung	PERF.3 Audits

PERF.3.1.1 Erstellen eines Auditsplans (normal-SdT)

Attribut	29.05.26	01.07.26
Thema	PERF.3 Auditprogramm und -durchführung	PERF.3 Audits

PERF.3.1.2 Planen von internen Audits (normal-SdT)

Attribut	29.05.26	01.07.26
Thema	PERF.3 Auditprogramm und -durchführung	PERF.3 Audits

PERF.3.1.3 Auswahl des Auditteams (normal-SdT)

Attribut	29.05.26	01.07.26
Thema	PERF.3 Auditprogramm und -durchführung	PERF.3 Audits

PERF.3.1.4 Umfang von Audits (normal-SdT)

Attribut	29.05.26	01.07.26
Thema	PERF.3 Auditprogramm und -durchführung	PERF.3 Audits

PERF.4.1 Eignungsprüfung (normal-SdT)

Attribut	29.05.26	01.07.26
Dokumentation	Auditbericht	Managementbericht
Ergebnis	ein Verfahren zur Erstellung aussagekräftiger Auditberichte	Ergebnisse der Überprüfungen der Eignung, Angemessenheit und Wirksamkeit des ISMS der Institution
Handlungswort	verankern	dokumentieren
Hinweis	Ein [- Auditbericht muss nachvollziehbar -], [- vollständig -] und [- strukturiert dokumentieren -], [- wie das Audit durchgeführt wurde und welche Ergebnisse erzielt wurden -]. [- Er enthält Angaben zum Auditziel -], [- Auditumfang -], [- Auditteam , Auditmethoden -], den [- bewerteten Bereichen sowie eine	[+ Damit die Institutionsleitung fundierte Entscheidungen zur Steuerung des Informationssicherheitsprozesses treffen kann , ist +] ein [+ prägnanter Managementbericht erforderlich +] . [+ Darin werden die wesentlichen Eckpunkte zum Stand der Informationssicherheit übersichtlich aufbereitet . Der Bericht SOLL : kurz , klar +] und [+ verständlich sein +] , [+ relevante Informationen bzw +] . [+

Attribut	29.05.26	01.07.26
	übersichtliche Darstellung -] der [- Feststellungen inklusive Abweichungen -], [- Verbesserungspotenzialen und der Bewertung der Wirksamkeit der umgesetzten Sicherheitsmaßnahmen . Die Auditberichte sollten neben den identifizierten Schwachstellen auch positive Feststellungen enthalten , um ein ausgewogenes Bild zu vermitteln und Best Practices zu fördern . -]	Entwicklungen enthalten +], [+ nicht überfrachtet sein d +]. [+ h +]. den [+ Fokus auf das Wesentliche legen . So kann die Leitung gezielt Maßnahmen priorisieren und Ressourcen effektiv einsetzen . Es muss unter anderem deutlich werden , ob +] der [+ beabsichtigte Sicherheitszweck wirksam erfüllt wird +].
Parameter		{'perf.4.1-prm1': 'regelmäßig'}
Präzisierung		{{regelmäßig}} sowie anlassbezogen in einem Managementbericht
Text	Monitoring-Evaluation MUSS ein Verfahren zur Erstellung aussagekräftiger Auditberichte verankern.	Monitoring-Evaluation MUSS Ergebnisse der Überprüfungen der Eignung, Angemessenheit und Wirksamkeit des ISMS der Institution {{ insert: param, perf.4.1-prm1 }} sowie anlassbezogen in einem Managementbericht dokumentieren.
Thema	PERF.4 Bewertungsschema und Auditberichte	PERF.4 Managementbewertungen
Titel	Dokumentation von Auditergebnissen	Eignungsprüfung
UUID	d173c0e0-9c22-414c-b4c8-633c7a75a406 (gleicht PERF.3.2 UUID vom 01.07.26)	f9cf8bd8-9a68-4294-9e33-ab7b4f28c68c (gleicht PERF.5.1 UUID vom 29.05.26)
Verbesserung	PERF.4.1.1, PERF.4.1.2	PERF.4.1.1, PERF.4.1.2, PERF.4.1.3, PERF.4.1.4, PERF.4.1.5, PERF.4.1.6, PERF.4.1.7, PERF.4.1.8, PERF.4.1.9
Verwandte	#PERF.3.1	

PERF.4.1.1 Ergebnisse von Folgemaßnahmen (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	3	1
Dokumentation	Auditbericht	Managementbericht

Attribut	29.05.26	01.07.26
Ergebnis	für Feststellungen in Audits ein einheitliches Bewertungsschema	den Status von Folgemaßnahmen vorangegangener Managementbewertungen
Handlungswort	festlegen	dokumentieren
Hinweis	[- Das Bewertungsschema soll -] die [- einheitliche Bewertung -], die [- Wirksamkeit -] der [- Auditprozesse und die Vergleichbarkeit von Auditergebnissen sicherstellen -].	Die [+ Evaluierung von Folgemaßnahmen früherer Managementbewertungen dient der Prüfung , ob geplante Maßnahmen umgesetzt und ihre Ziele erreicht wurden . Dabei müssen Status , Wirksamkeit und mögliche Abweichungen nachvollziehbar dokumentiert und in die aktuelle Managementbewertung eingebunden werden +] . Die [+ Ergebnisse dieser Überprüfungen basieren auf den vorab erstellten Auditberichten sowie +] der [+ geforderten Eignungsprüfung +] .
Präzisierung		als Ergebnis der Überprüfung in einem Managementbericht
Text	Monitoring-Evaluation SOLLTE für Feststellungen in Audits ein einheitliches Bewertungsschema festlegen.	Monitoring-Evaluation SOLLTE den Status von Folgemaßnahmen vorangegangener Managementbewertungen als Ergebnis der Überprüfung in einem Managementbericht dokumentieren.
Thema	PERF.4 Bewertungsschema und Auditberichte	PERF.4 Managementbewertungen
Titel	Einheitliches Bewertungsschema	Ergebnisse von Folgemaßnahmen
UUID	cbd3ce59-8979-4ae0-a6ee-f0779d9a2598 (gleicht PERF.3.2.1 UUID vom 01.07.26)	917cda33-b472-4526-bdee-db022ffa506c (gleicht PERF.5.1.1 UUID vom 29.05.26)
Verwandte	#PERF.3.1	

PERF.4.1.2 Geänderte Rahmenbedingungen (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	0	1
Dokumentation	Auditbericht	Managementbericht
Ergebnis	eine angemessene Kommunikation an alle relevanten Stakeholder	veränderte Rahmenbedingungen mit Auswirkungen auf das Informationssicherheitsmanagement

Attribut	29.05.26	01.07.26
Handlungswort	ausführen	dokumentieren
Hinweis	[- Eine angemessene Kommunikation -] der [- Auditergebnisse an alle relevanten Stakeholder muss sichergestellt -] werden, [- um das Bewusstsein für identifizierte Risiken zu schärfen -] und die [- Umsetzung von Verbesserungsmaßnahmen zu fördern -].	[+ Die Ergebnisse +] der [+ Überprüfung der Rahmenbedingungen – wie rechtliche , organisatorische , technische oder wirtschaftliche Veränderungen – müssen systematisch erfasst und auf ihre Auswirkungen auf das ISMS bewertet +] werden. [+ Relevante Änderungen sind in der Managementbewertung einzubeziehen , da sie Einfluss auf die Risikobetrachtung +] und [+ erforderliche Anforderungen bzw . Sicherheitsmaßnahmen haben können . +] Die [+ Ergebnisse dieser Überprüfungen basieren auf den vorab erstellten Auditberichten sowie der geforderten Eignungsprüfung +].
Modalverb	MUSS	SOLLTE
Präzisierung		als Ergebnis der Überprüfung in einem Managementbericht
Text	Monitoring-Evaluation MUSS eine angemessene Kommunikation an alle relevanten Stakeholder ausführen.	Monitoring-Evaluation SOLLTE veränderte Rahmenbedingungen mit Auswirkungen auf das Informationssicherheitsmanagement als Ergebnis der Überprüfung in einem Managementbericht dokumentieren.
Thema	PERF.4 Bewertungsschema und Auditberichte	PERF.4 Managementbewertungen
Titel	Kommunikation an Stakeholder	Geänderte Rahmenbedingungen
UUID	3f9935bd-65fa-4212-a7e7-726f39933c7d (gleich PERF.3.2.2 UUID vom 01.07.26)	a45c5319-e786-4c30-868e-84416d2f0fe4 (gleich PERF.5.1.2 UUID vom 29.05.26)
Verwandte	#PERF.3.1	

PERF.5.1 Methoden und Tools (normal-SdT)

Attribut	29.05.26	01.07.26
Dokumentation	Managementbericht	
Ergebnis	das ISMS der Institution hinsichtlich Eignung, Angemessenheit und Wirksamkeit	effektive Monitoring-Methoden und -tools

Attribut	29.05.26	01.07.26
Handlungswort	überprüfen	verankern
Hinweis	[- Damit -] die [- Institutionsleitung fundierte Entscheidungen zur Steuerung des Informationssicherheitsprozesses treffen kann -], [- ist ein prägnanter Managementbericht erforderlich -]. [- Darin werden -] die [- wesentlichen Eckpunkte zum Stand -] der [- Informationssicherheit übersichtlich aufbereitet . Der Bericht SOLL : kurz , klar und verständlich -] sein, [- relevante Informationen bzw -]. [- Entwicklungen enthalten -], [- nicht überfrachtet sein d -]. [- h . den Fokus auf das Wesentliche legen . So kann die Leitung gezielt Maßnahmen priorisieren -] und [- Ressourcen effektiv einsetzen . Es muss unter anderem deutlich -] werden, [- ob -] der [- beabsichtigte Sicherheitszweck wirksam erfüllt wird -].	Die [+ Implementierung von Monitoring +]- [+ Methoden und +]- [+ tools sollte an +] die [+ individuellen Bedürfnisse und Möglichkeiten +] der [+ Institution angepasst +] sein. [+ Während kleinere Institutionen mit einfacheren Lösungen arbeiten können +], [+ benötigen größere und komplexere Umgebungen oft umfassendere und stärker automatisierte Ansätze +]. [+ Die gewonnenen Monitoring +]- [+ Daten sollten systematisch ausgewertet +] und [+ für verschiedene Zwecke genutzt +] werden, [+ darunter die Erstellung von Kennzahlen und Berichten , die Früherkennung von Sicherheitsrisiken , die Unterstützung +] der [+ Incident Response und die kontinuierliche Verbesserung des ISMS +]. [+ Beispielhafte Tools für die Überwachung von Informationssicherheit sind Security Information and Event Management (SIEM) Systeme für die zentrale Sammlung , Korrelation und Analyse von Sicherheitsereignissen aus verschiedenen Quellen ; Intrusion Detection / Prevention Systeme (IDS / IPS) zur Erkennung und Abwehr verdächtiger Netzwerkaktivitäten ; Vulnerability Management Systeme zur systematischen Identifikation und Behandlung von Schwachstellen sowie Configuration Monitoring Tools zur Überwachung von Konfigurationsänderungen in Systemen und Anwendungen . +]
Parameter	{'perf.5.1-prm1': 'regelmäßig'}	{'perf.5.1-prm1': 'regelmäßigen'}
Präzisierung	{{regelmäßig}} sowie anlassbezogen	zur {{regelmäßigen}} Überwachung der Informationssicherheit

Attribut	29.05.26	01.07.26
Text	Monitoring-Evaluation MUSS das ISMS der Institution hinsichtlich Eignung, Angemessenheit und Wirksamkeit {{ insert: param, perf.5.1-prm1 }} sowie anlassbezogen überprüfen.	Monitoring-Evaluation MUSS effektive Monitoring-Methoden und -tools zur {{ insert: param, perf.5.1-prm1 }} Überwachung der Informationssicherheit verankern.
Thema	PERF.5 Managementbewertungen	PERF.5 Monitoring
Titel	Eignungsprüfung	Methoden und Tools
UUID	f9cf8bd8-9a68-4294-9e33-ab7b4f28c68c (gleicht PERF.4.1 UUID vom 01.07.26)	17e221bd-3b74-453a-ad4e-e2cb346b6af5 (gleicht PERF.6.1 UUID vom 29.05.26)
Verbesserung	PERF.5.1.1, PERF.5.1.2, PERF.5.1.3, PERF.5.1.4, PERF.5.1.5, PERF.5.1.6, PERF.5.1.7, PERF.5.1.8, PERF.5.1.9	

PERS.6.1.1 Entzug von Berechtigungen gemäß BER (normal-SdT)

Attribut	29.05.26	01.07.26
Verwandte	#BER.5.8	#BER.4.8

SENS.4.1 Personengebundene Authentisierungsmittel (normal-SdT)

Attribut	29.05.26	01.07.26
Abhängigkeit	#BER.7.5	#BER.6.5

SENS.4.1.3 Wahl von Passwörtern (normal-SdT)

Attribut	29.05.26	01.07.26
Abhängigkeit	#BER.6.8	#BER.5.8

STM.1.1 Definition und Abgrenzung des Informationsverbunds (normal-SdT)

Attribut	29.05.26	01.07.26
Abhängigkeit	#GC.4.1	#GC.6.1
Hinweis	[- Definieren und dokumentieren Sie den -] Informationsverbund [- . Dieser bildet den Geltungsbereich inhaltlich - technisch ab und umfasst -] die informationsverarbeitenden Systeme, Prozesse und Komponenten [- , die -] innerhalb des festgelegten Geltungsbereichs betrachtet werden [- . Dokumentieren Sie	[+ Im +] Informationsverbund [+ werden +] die informationsverarbeitenden Systeme, Prozesse [+ , Personen +] und Komponenten innerhalb des festgelegten Geltungsbereichs [+ des ISMS +] betrachtet [+ . Hierbei wird festgelegt welche organisatorischen , technischen und infrastrukturellen Anteile intern

Attribut	29.05.26	01.07.26
	-], welche Institutionsbereiche [- , Rollen und Personen -] zum Informationsverbund gehören [- für die organisatorische Abgrenzung . Grenzen Sie zusätzlich aus technischer Perspektive ab -], welche Anwendungen, Systeme und Netze Bestandteil [- Ihres -] Informationsverbundes sind. [- Dokumentieren Sie weiterhin , welche Betriebsanteile an externe Parteien outgessourced - bsw . -] welche Cloud-Dienste genutzt [- - -] werden. [- In der Praxis kann es in einem Geltungsbereich auch mehrere Informationsverbünde geben -].	betrieben +] werden [+ und welche an externe Parteien ausgelagert werden +] ; welche Institutionsbereiche zum Informationsverbund gehören; welche Anwendungen, Systeme und Netze Bestandteil [+ des +] Informationsverbundes sind; [+ wo die technischen Grenzen verlaufen und wenn zutreffend +] welche Cloud-Dienste genutzt werden; [+ welche Standorte +] , [+ Gebäude und Räumlichkeiten zum Informationsverbund gehören . +]
Thema	STM.1 Definition und Abgrenzung des Informationsverbunds	STM.1 Informationsverbund

STM.1.2 Dokumentation der externen Schnittstellen (normal-SdT)

Attribut	29.05.26	01.07.26
Hinweis	[- Im -] Informationsverbund [- sind -] die organisatorischen, technischen und infrastrukturellen Schnittstellen dargestellt. [- Für eine eindeutige Abgrenzung sind im Informationsverbund die Schnittstellen definiert . -] Wie bei der Beschreibung des Informationsverbunds selbst, [- sind -] auch hier organisatorische, technische sowie infrastrukturelle Schnittstellen berücksichtigt.	[+ Zum +] Informationsverbund [+ werden +] die organisatorischen, technischen und infrastrukturellen Schnittstellen dargestellt. Wie bei der Beschreibung des Informationsverbunds selbst, [+ werden +] auch hier organisatorische, technische sowie infrastrukturelle Schnittstellen berücksichtigt.
Thema	STM.1 Definition und Abgrenzung des Informationsverbunds	STM.1 Informationsverbund

STM.2.1 Erstellung eines Anforderungspakets (normal-SdT)

Attribut	29.05.26	01.07.26
Dokumentation		Anforderungspaket
Ergebnis	in ein zu erstellendes Anforderungspaket alle Anforderungen	ein Anforderungspaket
Handlungswort	platzieren	modellieren

Attribut	29.05.26	01.07.26
Hinweis	Das Anforderungspaket enthält alle Anforderungen, die für den betrachteten Informationsverbund und den priorisierten [- Geschäftsprozesse -] relevant sind [- sowie wenn erforderlich zusätzlichen -] Anforderungen. Diese Anforderung dient der grundsätzlichen Vorgabe ein Anforderungspaket zu erstellen. Weitere Details sind den folgenden Anforderungen dieser Praktik zu entnehmen.	Das Anforderungspaket enthält alle Anforderungen, die für den betrachteten Informationsverbund und den priorisierten [+ Geschäftsprozess +] relevant sind [+ . Diese stammen zum Großteil aus dem GS + + , können jedoch bei Bedarf durch individuelle +] Anforderungen [+ ergänzt werden +] . Diese Anforderung dient der grundsätzlichen Vorgabe ein Anforderungspaket zu erstellen. Weitere Details sind den folgenden Anforderungen dieser Praktik zu entnehmen.
Präzisierung	die für den betrachteten Informationsverbund relevant sind	für den betrachteten Informationsverbund
Text	Strukturmodellierung MUSS in ein zu erstellendes Anforderungspaket alle Anforderungen die für den betrachteten Informationsverbund relevant sind platzieren.	Strukturmodellierung MUSS ein Anforderungspaket für den betrachteten Informationsverbund modellieren.
Thema	STM.2 Erstellung eines Anforderungspakets	STM.2 Anforderungspaket
Verbesserung		STM.2.1.1, STM.2.1.2, STM.2.1.3, STM.2.1.4, STM.2.1.4.1, STM.2.1.4.2, STM.2.1.5, STM.2.1.6, STM.2.1.7

STM.3.1 Überprüfung des gesetzten Sicherheitsniveaus (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	0	2
Ergebnis	alle Anforderungen der ISMS-Praktiken	die initiale Einstufung der Sicherheitsniveaus der Anforderungen im Anforderungspaket
Handlungswort	platzieren	überprüfen
Hinweis	[- Neben den zielobjektgebundenen Anforderungen enthält das Kompendium -] [- GS -] ++ auch [- Anforderungen ohne explizite Zielobjektzuordnung -] . [- Diese werden im Anforderungspaket ergänzend berücksichtigt -] . [- Für die Anforderungen der ISMS - Praktiken	[+ Diese Anforderung ist besonders dann erforderlich +] , [+ wenn Geschäftsprozesse oder die darin verarbeiteten Informationen einen hohen Schutzbedarf aufweisen +] . [+

Attribut	29.05.26	01.07.26
	(GC , STM , PERF , VRB , UMS) gilt dabei Folgendes : Die Anforderungen der ISMS - Praktiken sind übergreifend und keinem einzelnen Zielobjekt zugewiesen . Sie bauen den PDCA - Zyklus des Managementsystems auf und gelten deshalb einmalig für den gesamten Informationsverbund . Alle Anforderungen der ISMS - Praktiken werden ohne weitere Selektion auf den Informationsverbund modelliert . Sie werden als „ verbundweite Anforderungen “ im Anforderungspaket geführt , da sie Governance - , Steuerungs - , Kontroll - und Verbesserungsprozesse definieren . -]	In diesem Teilschritt der Anforderungsanalyse ´ wird die initiale Einstellung des Sicherheitsniveaus überprüft und bei Bedarf +], auch [+ bei einzelnen Assets +], [+ geändert +].
Modalverb	MUSS	SOLLTE
Präzisierung	modelliert auf den vorliegenden Informationsverbund	bei Abweichungen des Kontextes der Institution
Text	Strukturmodellierung MUSS alle Anforderungen der ISMS-Praktiken modelliert auf den vorliegenden Informationsverbund platzieren.	Strukturmodellierung SOLLTE die initiale Einstufung der Sicherheitsniveaus der Anforderungen im Anforderungspaket bei Abweichungen des Kontextes der Institution überprüfen.
Thema	STM.3 ISMS-Anforderungen des Informationsverbundes	STM.3 Sicherheitsniveau
Titel	ISMS-Anforderungen des Informationsverbundes	Überprüfung des gesetzten Sicherheitsniveaus
UUID	92bc2497-1440-4718-b35b-9648b3efc4fd (gleicht STM.2.1.1 UUID vom 01.07.26)	ba3059a8-7745-451a-9601-f4c19c2b4b87 (gleicht STM.7.1 UUID vom 29.05.26)
Verwandte		#GC.7.1

STM.4.1 Durchführung der Risikobetrachtung (normal-SdT)

Attribut	29.05.26	01.07.26
Ergebnis	alle relevanten Assets für die betrachteten Geschäftsprozesse	eine Risikobetrachtung
Handlungswort	festlegen	ausführen

Attribut	29.05.26	01.07.26
Hinweis	[- Die Asset - Modellierung ist der zentrale Schritt , um den zuvor festgelegten Informationsverbund strukturiert und nachvollziehbar in sicherheitsrelevante Bestandteile zu zerlegen . Ziel ist es -], die [- für den betrachteten Geschäftsprozess relevanten -] Assets [- zu identifizieren -], [- zu dokumentieren und so zu modellieren -], [- dass daraus automatisiert -] oder [- manuell -] passende Anforderungen [- abgeleitet werden können . Assets sind dabei alle materiellen oder immateriellen Werte , die zur Aufgabenerfüllung und zur Erreichung der Geschäftsziele benötigt werden . Die Asset - Modellierung fokussiert auf jene Assets , die -] im [- Rahmen der priorisierten Geschäftsprozesse Informationen verarbeiten , speichern , übertragen oder deren Schutz unterstützen . Relevante Assets können insbesondere Informationswerte , Systeme und Anwendungen (System Assets -)], [- Netz -]- [- und Kommunikationskomponenten , infrastrukturelle und physische Assets sowie personelle und organisatorische Assets sein -]	[+ Diese Anforderung beschreibt Szenarien +], die [+ einen Aussprung in eine separate Risikobetrachtung erfordern . Eine Risikobetrachtung ist insbesondere notwendig bei Geschäftsprozessen oder +] Assets [+ mit hohem Schutzbedarf +], [+ bei Herabstufung des Sicherheitsniveaus +] ([+ von erhöht auf normal - SdT) +] oder [+ bei Nicht - Umsetzung von Anforderungen . Zuletzt ist eine Risikobetrachtung zur Ergänzung des Anforderungspakets z . B . bei Assets ohne +] passende Anforderungen im [+ GS +]++ [+ erforderlich +].
Präzisierung	modelliert auf den vorliegenden Informationsverbund	bei durch die GS++-Methodik festgelegter Notwendigkeit
Text	Strukturmodellierung MUSS alle relevanten Assets für die betrachteten Geschäftsprozesse modelliert auf den vorliegenden Informationsverbund festlegen.	Strukturmodellierung MUSS eine Risikobetrachtung bei durch die GS++-Methodik festgelegter Notwendigkeit ausführen.
Thema	STM.4 Asset-Modellierung	STM.4 Risiko
Titel	Erfassung relevanter Assets	Durchführung der Risikobetrachtung
UUID	10e75c93-320b-4d4d-baaa-ed7392b274cf (gleich STM.2.1.2 UUID vom 01.07.26)	42cc5d6f-e4f8-4247-a8fa-f90988af02cb (gleich STM.8.1 UUID vom 29.05.26)
Verwandte		#STM.2.1.6, #STM.3.1, #GC.7.2, #UMS.5.1

STM.5.1 Setzen von Parametern (normal-SdT)

Attribut	29.05.26	01.07.26
Abhängigkeit	#STM.4.3	
Ergebnis	die Modellierung der Anforderung aus den Zielobjektkategorien auf die zugeordneten Assets	bei Anforderungen mit Parametern
Handlungswort	ausführen	zuweisen
Hinweis	[- Nun -] werden die [- Anforderungen -] aus [- dem GS -] ++ [- auf die identifizierten Zielobjekte modelliert -]. [- Gemäß dem Schutzbedarf der Institution für den Geschäftsprozess , werden die Anforderungen für eine entsprechendes Sicherheitsniveau gewählt . Die modellierten Anforderungen bilden das individuelle Anforderungspaket des festgelegten Informationsverbund in Bezug auf den ausgewählten Geschäftsprozess . -]	[+ Ausgewählte Anforderungen enthalten Parameter zur Belegung mit individuellen Angaben . Diese können z . B . durch Normen und Standards belegt +] werden [+ oder enthalten Platzhalter für Rollen und Zuständigkeiten in der eigenen Institution . Beispielsweise enthält jede technische oder organisatorische Praktik im Abschnitt „ Grundlagen “ eine Anforderung zur Zuweisung einer Zuständigkeit zu bestimmten Personen oder Rollen . Durch das Setzen dieser Parameter wird festgelegt , welche Personen oder Rollen +] die [+ führende Zuständigkeit für den zugeordneten Prozess erhalten . Dies wirkt sich auch auf das Anforderungspaket für Zielobjekte +] aus [+ : Hier ist die Zuständigkeit für jede Anforderung anhand ihrer Praktik erkennbar . Ein anderer beispielhafter Typ sind zeitliche Parameter , z . B . kann das Wort "regelmäßig " durch Parametrisierung konkretisiert werden (z . B . täglich , wöchentlich , monatlich +)]. [+ Parametrisierung kann in Form von Auswahlfeldern oder aber von Freitextbelegung erfolgen +].
Präzisierung		konkrete Werte
Text	Strukturmodellierung MUSS die Modellierung der Anforderung aus den Zielobjektkategorien auf die zugeordneten Assets ausführen.	Strukturmodellierung MUSS bei Anforderungen mit Parametern konkrete Werte zuweisen.
Thema	STM.5 Anforderungsmodellierung auf die Assets	STM.5 Parametrisierung
Titel	Modellierung der Anforderungen mit Zielobjekt	Setzen von Parametern

Attribut	29.05.26	01.07.26
UUID	11fe535b-f1f3-49d2-ab01-65fc651281b5 (gleich STM.2.1.4 UUID vom 01.07.26)	422b1228-e297-49a5-a3ad-29349c2ca03e (gleich STM.9.2 UUID vom 29.05.26)
Verwandte	#STM.5.2, #STM.5.3, #STM.5.4	

UMS.1.1 Ermittlung des Umsetzungsstatus (normal-SdT)

Attribut	29.05.26	01.07.26
Ergebnis	den Umsetzungsstatus der Anforderungen der verschiedenen Praktiken	den Umsetzungsstatus der Anforderungen
Parameter		{'ums.1.1-prm1': 'regelmäßig'}
Präzisierung	vollständig	im Anforderungspaket vollständig {{regelmäßig}}
Text	Umsetzung MUSS den Umsetzungsstatus der Anforderungen der verschiedenen Praktiken vollständig überprüfen.	Umsetzung MUSS den Umsetzungsstatus der Anforderungen im Anforderungspaket vollständig {{ insert: param, ums.1.1-prm1 }} überprüfen.
Thema	UMS.1 Ermittlung des Umsetzungsstatus	UMS.1 Umsetzungsstatus

UMS.2.1 Umsetzungsplanung (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	2	0
Dokumentation		Umsetzungsplan
Ergebnis	das bestehende Restrisiko durch die nicht umgesetzten Anforderungen	Maßnahmen für die Umsetzung der bisher nicht umgesetzten Anforderungen des Anforderungspakets
Hinweis	Die [- Risiken der Nichtumsetzung von -] Anforderungen [- können auch konsolidiert -] werden, [- um diese für -] die [- Institutionsleitung nachvollziehbarer -] zu [- machen -] .	[+ Je nach Organisation ist eine strukturierte Vorgehensweise festzulegen . Dabei empfiehlt es sich zu prüfen , ob Maßnahmen etabliert sind , +] die [+ mehrere +] Anforderungen [+ zugleich abdecken . Ebenso werden Synergieeffekte erschlossen , indem ähnliche Defizite in anderen Bereichen identifiziert und mit gemeinsamen Lösungen adressiert +] werden. [+ Das Ergebnis dieser Anforderung ist +] die [+ Überführung des

Attribut	29.05.26	01.07.26
		unstrukturierten Anforderungspakets hin +] zu [+ einem strukturierten Umsetzungsplans +].
Modalverb	SOLLTE	MUSS
Präzisierung		gemäß einer strukturierten Vorgehensweise
Text	Umsetzung SOLLTE das bestehende Restrisiko durch die nicht umgesetzten Anforderungen festlegen.	Umsetzung MUSS Maßnahmen für die Umsetzung der bisher nicht umgesetzten Anforderungen des Anforderungspakets gemäß einer strukturierten Vorgehensweise festlegen.
Thema	UMS.2 Bewertung fehlender Umsetzungen	UMS.2 Umsetzungsplanung
Titel	Bewertung des Restrisikos	Umsetzungsplanung
UUID	8b7626ab-3fcf-45bd-a7ba-45705436c909 (gleicht UMS.1.2 UUID vom 01.07.26)	c179a2e9-4e6e-4115-a85e-d66ac93b00e8 (gleicht UMS.3.1 UUID vom 29.05.26)

UMS.3.1 Benennung von Umsetzungszuständigen (normal-SdT)

Attribut	29.05.26	01.07.26
Ergebnis	ein Verfahren zur Festlegung von Maßnahmen für die Umsetzung der bisher nicht umgesetzten Anforderungen	Zuständige für die Umsetzung der bisher nicht erfüllten Anforderungen
Handlungswort	verankern	zuweisen
Hinweis	[- Das Verfahren ist auf -] die [- Organisation abzustimmen -]. [- Dabei empfiehlt es sich zu prüfen , ob Maßnahmen etabliert sind -], die [- mehrere Anforderungen zugleich abdecken . Ebenso kann das Verfahren genutzt werden -], um [- Synergieeffekte -] zu [- erschließen -], [- indem ähnliche Defizite in anderen Bereichen identifiziert -] und mit [- gemeinsamen Lösungen adressiert werden . -]	Die [+ Zuständigen für die Umsetzung der Priorisierungen müssen eindeutig zugewiesen werden +], [+ wobei die zugewiesenen Personen oder Teams über die erforderlichen Kompetenzen und Ressourcen verfügen sollten +]. Die [+ Zuweisung von Zuständigkeiten sollte in Abstimmung mit den betroffenen Bereichen erfolgen +], um [+ Akzeptanz und Commitment +] zu [+ fördern +]. [+ Insbesondere bei komplexeren Maßnahmen kann es sinnvoll sein , sowohl eine fachliche als auch eine operative Verantwortung zu definieren +] und [+ bei Bedarf Teilaufgaben +] mit [+ eigenen Verantwortlichkeiten zu bilden +]

Attribut	29.05.26	01.07.26
Präzisierung	des Anforderungspakets als Ergebnis der Praktik Strukturmodellierung	eindeutig
Text	Umsetzung MUSS ein Verfahren zur Festlegung von Maßnahmen für die Umsetzung der bisher nicht umgesetzten Anforderungen des Anforderungspakets als Ergebnis der Praktik Strukturmodellierung verankern.	Umsetzung MUSS Zuständige für die Umsetzung der bisher nicht erfüllten Anforderungen eindeutig zuweisen.
Thema	UMS.3 Umsetzungsplanung und Priorisierung	UMS.3 Umsetzungszuständige
Titel	Umsetzungsplanung	Benennung von Umsetzungszuständigen
UUID	c179a2e9-4e6e-4115-a85e-d66ac93b00e8 (gleich UMS.2.1 UUID vom 01.07.26)	0ea195d5-64a3-4c83-84a4-7acb976a0f26 (gleich UMS.4.1 UUID vom 29.05.26)
Verwandte		#UMS.2.1

UMS.4.1 Festlegung von Umsetzungsfristen (normal-SdT)

Attribut	29.05.26	01.07.26
Ergebnis	Zuständige für die Umsetzung der bisher nicht erfüllten Anforderungen	ein realistisches Zieldatum für die Umsetzung der bisher nicht umgesetzten Anforderungen
Handlungswort	zuweisen	festlegen
Hinweis	[- Die Zuständigen -] für [- die Umsetzung der Priorisierungen müssen eindeutig zugewiesen -] werden, [- wobei die zugewiesenen Personen oder Teams über die erforderlichen Kompetenzen und Ressourcen verfügen sollten -]. Die [- Zuweisung von Zuständigkeiten sollte in Abstimmung mit den betroffenen Bereichen erfolgen -], [- um Akzeptanz und Commitment zu fördern -]. [- Insbesondere -] bei [- komplexeren -] Maßnahmen [- kann es sinnvoll sein -], [- sowohl eine fachliche als auch eine operative Verantwortung zu definieren und bei Bedarf Teilaufgaben mit eigenen Verantwortlichkeiten zu bilden -]	Für [+ jede umzusetzende Maßnahme muss ein realistisches Zieldatum festgelegt +] werden, [+ das den Umfang +], die [+ verfügbaren Ressourcen und mögliche Abhängigkeiten berücksichtigt +]. [+ Die Einhaltung dieser Fristen muss nachgehalten werden +]. Bei [+ Überschreitung der Fristen sind geeignete +] Maßnahmen [+ einzuleiten +].

Attribut	29.05.26	01.07.26
Präzisierung	eindeutig	
Text	Umsetzung MUSS Zuständige für die Umsetzung der bisher nicht erfüllten Anforderungen eindeutig zuweisen.	Umsetzung MUSS ein realistisches Zieldatum für die Umsetzung der bisher nicht umgesetzten Anforderungen festlegen.
Thema	UMS.4 Zuständigkeiten und Umsetzungsfristen	UMS.4 Umsetzungsfristen
Titel	Benennung von Umsetzungszuständigen	Festlegung von Umsetzungsfristen
UUID	0ea195d5-64a3-4c83-84a4-7acb976a0f26 (gleich UMS.3.1 UUID vom 01.07.26)	3c10793d-1a2d-490c-9c7d-479f8f2c102b (gleich UMS.4.2 UUID vom 29.05.26)
Verwandte	#UMS.3.1	#UMS.2.1

UMS.5.1 Autorisierung von Ausnahmen (normal-SdT)

Attribut	29.05.26	01.07.26
Hinweis	Bei Zielkonflikten zwischen Verpflichtungen müssen diese gegeneinander abgewogen und falls erforderlich Ausnahmegenehmigungen eingeholt werden. Zur Entscheidungsfindung kann eine Risikobetrachtung vorgenommen werden. [- Hierbei sind auch -] die Anforderungen zur "[- Aufgabenzuweisung -] " [- und "Anweisung zur Einhaltung " zu berücksichtigen . -]	Bei Zielkonflikten zwischen Verpflichtungen müssen diese gegeneinander abgewogen und falls erforderlich Ausnahmegenehmigungen [+ von der zuständigen Person oder Rolle +] eingeholt werden. Zur Entscheidungsfindung kann eine Risikobetrachtung vorgenommen werden. [+ Es ist zu prüfen ob +] die [+ Nicht - Umsetzung von +] Anforderungen zur [+ Erforderlichkeit einer Risikobetrachtung führt +] , [+ siehe verwandte Anforderung +] .
Parameter		{'ums.5.1-prm1': 'eine zuständige Person oder Rolle'}
Präzisierung	durch eine zuständige Person oder Rolle	durch {{eine zuständige Person oder Rolle}}
Text	Umsetzung MUSS Ausnahmegenehmigungen für Verpflichtungen durch eine zuständige Person oder Rolle autorisieren.	Umsetzung MUSS Ausnahmegenehmigungen für Verpflichtungen durch {{ insert: param, ums.5.1-prm1 }} autorisieren.
Thema	UMS.5 Freigabeverfahren und Ausnahmemanagement	UMS.5 Ausnahmemanagement

Attribut	29.05.26	01.07.26
Verwandte		#STM.4.1

UMS.5.2 Dokumentation von Ausnahmen (normal-SdT)

Attribut	29.05.26	01.07.26
Thema	UMS.5 Freigabeverfahren und Ausnahmemanagement	UMS.5 Ausnahmemanagement

UMS.6.1 Nachverfolgung des Umsetzungsfortschritts (normal-SdT)

Attribut	29.05.26	01.07.26
Abhängigkeit	#UMS.3.1	#UMS.2.1
Thema	UMS.6 Fortschrittsverfolgung der Realisierung	UMS.6 Umsetzungsfortschrittsverfolgung

UMS.6.2 Fortschreibung des Umsetzungsplans (normal-SdT)

Attribut	29.05.26	01.07.26
Abhängigkeit	#UMS.3.1	#UMS.2.1
Thema	UMS.6 Fortschrittsverfolgung der Realisierung	UMS.6 Umsetzungsfortschrittsverfolgung

UMS.7.1 Wahrung von Compliance in der Umsetzung (normal-SdT)

Attribut	29.05.26	01.07.26
Thema	UMS.7 Wahrung von Compliance in der Umsetzung	UMS.7 Compliance-Management
Verwandte	#PERF.2.1	#PERF.2.1, #GC.3.1

VRB.1.1 Verfahren zur kontinuierlichen Verbesserung (normal-SdT)

Attribut	29.05.26	01.07.26
Hinweis	[- In diesem Prozessschritt -] werden Erkenntnisse aus der Überwachung in konkrete Verbesserungsmaßnahmen umgesetzt. [- Dieses Verfahren ist ein Prozess , welcher sich im -] PDCA-Zyklus [- von -] der [- Praktik Strukturmodellierung über -] die [- Umsetzung bis hin zum Monitoring -] und [- der Evaluierung erstreckt -] .	[+ Im Verfahren zur Verbesserung +] werden Erkenntnisse aus der Überwachung in konkrete Verbesserungsmaßnahmen umgesetzt. [+ Die kontinuierliche Verbesserung schließt den +] PDCA- Zyklus der [+ Methodik ab und stellt sicher , dass +] die [+ Informationssicherheit stetig weiterentwickelt +] und [+ verbessert wird +] . [+ Hierbei erfolgen Änderungen im ISMS geplant und strukturiert und werden systematisch dokumentiert , um die Vergleichbarkeit und Nachvollziehbarkeit sowie

Attribut	29.05.26	01.07.26
		die kohärente Managementbewertung sicherzustellen . +]

VRB.2.1 Umgang mit Nicht-Konformitäten (normal-SdT)

Attribut	29.05.26	01.07.26
Verwandte	#VRB.2.2	#VRB.2.2, #PERF.3.2.2

VRB.2.2 Anpassung des ISMS (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	2	0
Ergebnis	Notwendigkeit zur Anpassung des ISMS	die Notwendigkeit zur Anpassung des ISMS hinsichtlich der Nicht-Konformitäten
Hinweis	Hier erfolgt eine Bewertung der Wahrscheinlichkeit des Wiederauftretens von Nicht- Konformitäten und der potenziellen Auswirkungen bei erneutem Auftreten, eine Überprüfung, ob ähnliche Nicht- Konformitäten in anderen Bereichen der Institution bestehen oder auftreten könnten und eine Analyse, inwieweit die Nicht- Konformität auf systemische Schwächen im ISMS hinweist und ob grundlegende Anpassungen des ISMS erforderlich sind. Bei wiederholten oder systematischen Nicht- Konformitäten [- sollten -] jedoch die zugrundeliegenden Prozesse, Richtlinien oder Verantwortlichkeiten überprüft und bei Bedarf angepasst [- werden -].	Hier erfolgt eine Bewertung der Wahrscheinlichkeit des Wiederauftretens von Nicht- Konformitäten und der potenziellen Auswirkungen bei erneutem Auftreten, eine Überprüfung, ob ähnliche Nicht- Konformitäten in anderen Bereichen der Institution bestehen oder auftreten könnten und eine Analyse, inwieweit die Nicht- Konformität auf systemische Schwächen im ISMS hinweist und ob grundlegende Anpassungen des ISMS erforderlich sind. Bei wiederholten oder systematischen Nicht- Konformitäten [+ werden +] jedoch die zugrundeliegenden Prozesse, Richtlinien oder Verantwortlichkeiten überprüft und bei Bedarf angepasst.
Modalverb	SOLLTE	MUSS
Parameter		{'vrb.2.2-prm1': 'regelmäßig'}
Präzisierung	hinsichtlich der Nicht-Konformitäten	{{regelmäßig}}
Text	Verbesserung SOLLTE Notwendigkeit zur Anpassung des ISMS hinsichtlich der Nicht-Konformitäten überprüfen.	Verbesserung MUSS die Notwendigkeit zur Anpassung des ISMS hinsichtlich der Nicht-Konformitäten {{ insert: param, vrb.2.2-prm1 }} überprüfen.

VRB.3.1 Identifikation von Verbesserungspotenzialen (normal-SdT)

Attribut	29.05.26	01.07.26
Aufwand	3	0
Handlungswort	verankern	festlegen
Hinweis	Die Methode beinhaltet beispielsweise die Bewertung des Umfelds der Institution (einschließlich der Bewertung der Gefährdungslage), die Auswertung des Umsetzungsplans, die Auswertung von Auditergebnissen und Sicherheitsvorfällen sowie die Berücksichtigung von Ad hoc- Eingaben (z. B. akute Verbesserungspotentiale).	[+ Im Gegensatz zum reaktiven Umgang mit Nicht - Konformitäten zielt die Identifikation von Verbesserungspotentialen darauf ab , auch ohne vorangegangene Probleme oder Abweichungen Optimierungsmöglichkeiten zu erkennen und zu nutzen . Für Verbesserungen zur Nutzung identifizierter Potenziale wird ein strukturierter Ansatz verfolgt . +] Die Methode beinhaltet beispielsweise die Bewertung des Umfelds der Institution (einschließlich der Bewertung der Gefährdungslage), die Auswertung des Umsetzungsplans, die Auswertung von Auditergebnissen und Sicherheitsvorfällen sowie die Berücksichtigung von Ad hoc- Eingaben (z. B. akute Verbesserungspotentiale). [+ Die Verbesserungspotenziale zielen auf die proaktive Weiterentwicklung des ISMS ab . Sie können beispielsweise den Einsatz neuer oder verbesserter Technologien und Methoden , die Stärkung der Sicherheitskultur und des Sicherheitsbewusstseins , die Erweiterung des Anwendungsbereiches des ISMS oder die Verbesserung der Integration des ISMS in andere Managementsysteme und Geschäftsprozesse betreffen . Nicht jede Verbesserungsmöglichkeit bietet denselben Mehrwert für die Institution . Die Bewertung sollte das Potenzial zur Risikoreduktion , den erwarteten Ressourcenaufwand , die strategische Bedeutung für die Informationssicherheitsziele , mögliche Synergien mit anderen Verbesserungsmaßnahmen oder Projekten und die Nachhaltigkeit der Verbesserung berücksichtigen . +]
Modalverb	SOLLTE	MUSS
Präzisierung	unter Berücksichtigung der damit verbundenen Risiken	unter Berücksichtigung der damit verbundenen Vor- und Nachteile
Text	Verbesserung SOLLTE eine Methode zur Überprüfung und Bewertung von Verbesserungspotentialen unter Berücksichtigung der	Verbesserung MUSS eine Methode zur Überprüfung und Bewertung von Verbesserungspotentialen unter Berücksichtigung der damit verbundenen Vor- und Nachteile festlegen.

Attribut	29.05.26	01.07.26
	damit verbundenen Risiken verankern.	
Thema	VRB.3 Identifikation von Verbesserungspotenzialen	VRB.3 Verbesserungspotenziale

VRB.4.1 Korrekturmaßnahmen (normal-SdT)

Attribut	29.05.26	01.07.26
Hinweis	[- Im Gegensatz -] zum [- reaktiven Umgang mit -] Nicht- [- Konformitäten zielt dieser Ansatz darauf ab , auch ohne vorangegangene Probleme oder Abweichungen Optimierungsmöglichkeiten zu erkennen und zu nutzen . Bei der Bewertung von Verbesserungspotenzialen ist eine risikoorientierte Herangehensweise wichtig . Nicht jede Verbesserungsmöglichkeit bietet denselben Mehrwert für die Institution -]. Die [- Bewertung sollte das Potenzial zur Risikoreduktion -], [- den erwarteten Ressourcenaufwand -], die [- strategische Bedeutung für die Informationssicherheitsziele -], [- mögliche Synergien mit anderen Verbesserungsmaßnahmen oder Projekten und die Nachhaltigkeit der Verbesserung berücksichtigen . -]	[+ Bei der Entwicklung von Korrekturvorschlägen zur Beseitigung von Fehlerursachen sollten folgende Aspekte berücksichtigt werden : Die vorgeschlagenen Korrekturen müssen die identifizierten Grundursachen adressieren und nicht nur die Symptome beheben . Die Korrekturen sollten angemessen und verhältnismäßig sein , also in einem sinnvollen Verhältnis +] zum [+ Risiko oder zur Bedeutung der +] Nicht- [+ Konformität stehen +]. Die [+ Korrekturen sollten nachhaltig wirken und wiederkehrende Probleme verhindern +]. [+ Je nach Ursache können unterschiedliche Arten von Korrekturen erforderlich sein bspw . organisatorische Anpassungen wie die Überarbeitung von Prozessen , Richtlinien oder Zuständigkeiten ; personelle oder disziplinarische Maßnahmen ; infrastrukturelle Änderungen wie bauliche Anpassungen oder Verbesserungen der physischen Sicherheit ; technische Anpassungen an Hardware , Software oder Netzwerkinfrastruktur ; strategische Maßnahmen +], die [+ eine Entscheidung oder Unterstützung der Institutionsleitung erfordern +].

VRB.4.2 Verbesserungsmaßnahmen (normal-SdT)

Attribut	29.05.26	01.07.26
Hinweis	[- Für -] Verbesserungen [- zur Nutzung identifizierter Potenziale sollte ein strukturierter Ansatz verfolgt werden -].	Verbesserungen [+ zielen nicht primär auf die Behebung von Problemen +], [+ sondern +] auf die proaktive

Attribut	29.05.26	01.07.26
	[- Diese zielen -] auf die proaktive Weiterentwicklung des ISMS ab. Sie können beispielsweise [- den Einsatz -] neuer oder verbesserter Technologien und Methoden, [- die -] Stärkung der Sicherheitskultur und des Sicherheitsbewusstseins, [- die -] Erweiterung des Anwendungsbereiches des ISMS [- oder die -] Verbesserung der Integration des ISMS in andere Managementsysteme und Geschäftsprozesse [- betreffen -] .	Weiterentwicklung des ISMS ab. Sie können beispielsweise [+ folgende Bereiche adressieren : Optimierung von Prozessen und Abläufen im ISMS ; Einführung +] neuer oder verbesserter Technologien und Methoden; Stärkung der Sicherheitskultur und des Sicherheitsbewusstseins; Erweiterung des Anwendungsbereiches des ISMS [+ ; +] Verbesserung der Integration des ISMS in andere Managementsysteme und Geschäftsprozesse.
Präzisierung	unter Berücksichtigung der damit verbundenen Risiken	unter Berücksichtigung der damit verbundenen Vor- und Nachteile
Text	Verbesserung MUSS angemessene Maßnahmen zur Nutzung von Verbesserungspotentialen unter Berücksichtigung der damit verbundenen Risiken festlegen.	Verbesserung MUSS angemessene Maßnahmen zur Nutzung von Verbesserungspotentialen unter Berücksichtigung der damit verbundenen Vor- und Nachteile festlegen.

VRB.5.1 Priorisierung von Maßnahmen (normal-SdT)

Attribut	29.05.26	01.07.26
Verwandte		#VRB.4.1, #VRB.4.2

VRB.6.1 Überprüfung der erreichten Verbesserung (normal-SdT)

Attribut	29.05.26	01.07.26
Ergebnis	die Wirksamkeit der umgesetzten Maßnahmen	die Wirksamkeit der umgesetzten Korrektur- und Verbesserungsmaßnahmen
Handlungswort	überprüfen	testen
Hinweis	Die [- Wirksamkeit bewertet -] , [- ob -] die [- Maßnahmen -] den [- beabsichtigten Effekt erzielt haben -] . [- Hierfür sollten die Definition klarer , messbarer Kriterien für die Wirksamkeit jeder Maßnahme , die Durchführung gezielter Tests , Audits oder Überprüfungen nach Abschluss der Umsetzung , die Bewertung , ob die identifizierten Nicht - Konformitäten tatsächlich beseitigt oder die angestrebten Verbesserungen erreicht	Die [+ Wirksamkeitsprüfung stellt sicher +] , [+ dass der kontinuierliche Verbesserungsprozess zu messbaren und nachhaltigen Fortschritten führt . Sie schaffen Transparenz über den aktuellen Status und unterstützen +] die [+ Institution dabei , ihre Ressourcen optimal einzusetzen und +] den [+ Erfolg ihrer Verbesserungsbemühungen zu demonstrieren +] .

Attribut	29.05.26	01.07.26
	wurden sowie die Dokumentation der Ergebnisse der Wirksamkeitsprüfung berücksichtigt werden . -]	
Text	Verbesserung MUSS die Wirksamkeit der umgesetzten Maßnahmen {{ insert: param, vrb.6.1-prm1 }} überprüfen.	Verbesserung MUSS die Wirksamkeit der umgesetzten Korrektur- und Verbesserungsmaßnahmen {{ insert: param, vrb.6.1-prm1 }} testen.
Titel	Wirksamkeitsprüfung	Überprüfung der erreichten Verbesserung

VRB.7.1 Behandlung von Compliance-Verstößen (normal-SdT)

Attribut	29.05.26	01.07.26
Dokumentation		Compliance-Verpflichtungen
Ergebnis	ein Verfahren zur Bewertung der erreichten Verbesserung	ein Verfahren zur Behandlung von Verstößen
Hinweis	Die [- Bewertung kann beispielsweise durch interne Audits -], die [- Messung von Key Performance Indicators -] ([- KPIs) vor und nach der Maßnahmenumsetzung oder durch technische Überprüfungen erfolgen . Im Ergebnis ist das Sicherheitsniveau der Institution transparent dargestellt und Trends der Verbesserung des Sicherheitsniveaus , insbesondere auch durch die Vergleichbarkeit mit vorigen Bewertungen , ableitbar . -]	[+ Das Verfahren sollte eine klare Definition enthalten , was als Verstoß gilt und +] die [+ verschiedenen Arten von Verstößen kategorisieren +]. [+ Es sollten Melde - und Eskalationswegen für erkannte oder vermutete Verstöße festgelegt werden , ein systematischer Prozess zur Untersuchung und Dokumentation von Verstößen etabliert werden , eine Entscheidungsfindung über angemessene Reaktionen und Konsequenzen stattfinden und +] die [+ Umsetzung beschlossener Maßnahmen sollte nachverfolgt werden +].
Präzisierung	unter Berücksichtigung der damit verbundenen Risiken	unter Berücksichtigung der Betroffenenrechte
Text	Verbesserung SOLLTE ein Verfahren zur Bewertung der erreichten Verbesserung unter Berücksichtigung der damit verbundenen Risiken verankern.	Verbesserung SOLLTE ein Verfahren zur Behandlung von Verstößen unter Berücksichtigung der Betroffenenrechte verankern.
Thema	VRB.7 Bewertung der erreichten Verbesserung	VRB.7 Compliance-Management
Titel	Bewertung der erreichten Verbesserung	Behandlung von Compliance-Verstößen

Attribut	29.05.26	01.07.26
UUID	148975f6-1a20-4fe6-9d3b-b6e69ec80ec5 (gleich VRB.6.2 UUID vom 01.07.26)	8a5be79d-22b6-4a78-a87e-6445c9fdd20d (gleich VRB.8.1 UUID vom 29.05.26)
Verwandte		#GC.3.1.1, #UMS.7.1, #PERF.2.1